FROM MANUAL OPERATIONS TO SECURE DIGITAL INFRASTRUCTURE: A CYBERSECURITY INTEGRATION MODEL FOR MEDICAL SUPPLY ENTERPRISES

CAPSTONE PROJECT DOCUMENTATION

A Capstone Project
Presented to the Faculty of the
Bachelor of Science in Information Technology
PHINMA University of Iloilo
Iloilo City, Philippines

In Partial Fulfillment
of the Requirements for the Degree of
Bachelor of Science in Information Technology

By:
CHRISTIAN JAMES DEJAPON
CHARLES CABIRA
ARJUN DELOTERIO
AMIEL CHRISTOPHER CASTRO
JULES ARCHANGEL DUNCA

2026

TABLE OF CONTENTS

CHAPTER I **10**

INTRODUCTION 10

1.1 Background of the Study 10

1.2 Statement of the Problem 22

1.3 Objectives of the Study 27

1.3.1 General Objective: 27

1.3.2 Specific Objectives: 28

1.4 Scope and Delimitation 31

1.4.1 Scope of the Study: 31

1.4.2 Delimitations of the Study: 35

1.5 Significance of the Study 38

1.6 Definition of Terms 44

REFERENCES **60**

CHAPTER II **61**

REVIEW OF RELATED LITERATURE AND STUDIES 61

2.1 Foreign Studies 62

2.1.1 Cybersecurity of Small-to-Medium Businesses: 63

2.1.2 Systematic Review of SME Cybersecurity Challenges: 65

2.1.3 Agile Development of Secure Software for SMEs: 67

2.1.4 Efficacy, Reliability, and Accuracy of Inventory Systems in SMEs: 69
2.1.5 Design of a Web-Based Inventory Management System for SMEs: 70
2.1.6 Development of a Web-Based Inventory Management System for Small Businesses: 72
2.1.7 Digitalization of the Healthcare Supply Chain: 73
2.1.8 Global Medical Equipment Rental Market Trends: 75
2.1.9 Comparative Analysis of Agile and Waterfall Development Methodologies: 76
2.1.10 Security Assessment in Web-Based Rental Management Systems: 78
2.1.11 User Acceptance Testing in Management Information Systems: 79
2.1.12 SQL Injection and Input Validation Security in Web Applications: 81
2.1.13 Session Management and Authentication Best Practices: 82
2.1.14 Cross-Site Scripting (XSS) and CSRF Attack Prevention: 84
2.2 Local Studies 85
2.2.1 Web-Based Inventory Management System for a Philippine Small Enterprise: 86
2.2.2 Cybersecurity Landscape in the Philippines: 87
2.2.3 Digital Transformation in Philippine Organizations: 89
2.2.4 IoT Adoption and Supply Chain Management in Philippine SMEs: 91

2.2.5 User Requirements for Inventory Systems in Philippine Micro and Small Enterprises: 92
2.2.6 National Privacy Commission Enforcement and Compliance Guidance: 93
2.2.7 Digital Literacy and Technology Adoption Among Filipino SME Staff: 95
2.2.8 Home-Based Care and Medical Equipment Supply in the Philippine Context: 96
2.3 Related Literature 97
2.3.1 Management Information Systems: 98
2.3.2 Network Security Essentials: 100
2.3.3 Philippine Data Privacy Act of 2012 (Republic Act No. 10173): 101
2.3.4 OWASP Top 10 Web Application Security Risks: 103
2.3.5 NIST Cybersecurity Framework 2.0: 105
2.3.6 Role-Based Access Control (RBAC) Theory and Implementation: 106
2.3.7 Password Hashing and Credential Security: 108
2.3.8 ISO/IEC 25010 Software Product Quality Model: 109
2.3.9 Python Flask Framework for Web Application Development: 111
2.3.10 MySQL Relational Database Management System: 112
2.3.11 Client-Server Architecture for Web Applications: 114
2.3.12 Database Design and Normalization for Transaction Processing Systems: 115
2.3.13 Responsive Web Design for Mobile-First Business Applications: 116

2.3.14 Audit Trail Logging and Non-Repudiation in Information Systems: 118
2.3.15 Inventory Economic Order Quantity and Stock Management Theory: 119
2.4 Synthesis of the Reviewed Literature and Studies 121
2.4.1 Convergence on the Vulnerability of Manual Small Enterprise Systems: 121
2.4.2 Convergence on the Security Gap in SME Digital Adoption: 122
2.4.3 The Philippine Regulatory Imperative: 124
2.4.4 Technical Framework Convergence: 125
2.4.5 The Research Gap: 126
REFERENCES 129
CHAPTER III 133
METHODOLOGY 133
3.1 Research Design 133
3.2 System Development Methodology 135
3.2.1 Agile Development Phases: 136
Phase 0: Planning and Requirements Gathering 137
Phase 1: Database Design and Core Setup 138
Phase 2: Authentication and User Management 138
Phase 3: Inventory and Product Catalog 139
Phase 4: Cart, Order and Payment System 140
Phase 5: Rental Management and Invoicing 140
Phase 6: Security, Reports and Dashboard 141

Phase 7: Testing and Quality Assurance 141

3.3 System Architecture 142

3.3.1 Three-Tier Architecture Overview: 142

3.3.2 Model-View-Controller Pattern: 143

3.3.3 Integrated Security Layer: 144

3.3.4 External Service Integrations: 145

3.3.5 System Architecture Diagram: 146

3.4 Tools and Technologies Used 147

3.4.1 Programming Languages: 147

3.4.2 Frameworks and Libraries: 148

3.4.3 Database Technology: 149

3.4.4 Development Tools: 150

3.4.5 External Services: 150

3.5 Data Gathering Techniques 151

3.5.1 Interview: 151

Interview Protocol 151

Key Interview Findings 152

3.5.2 Observation: 153

3.5.3 Document Analysis: 153

3.5.4 Requirements Specification: 154

3.6 Testing Procedures 154

3.6.1 Unit Testing: 155

Authentication Module Unit Tests 155

Inventory Module Unit Tests 156

Order Processing Unit Tests 156

3.6.2 Integration Testing: 157

3.6.3 System Testing: 158

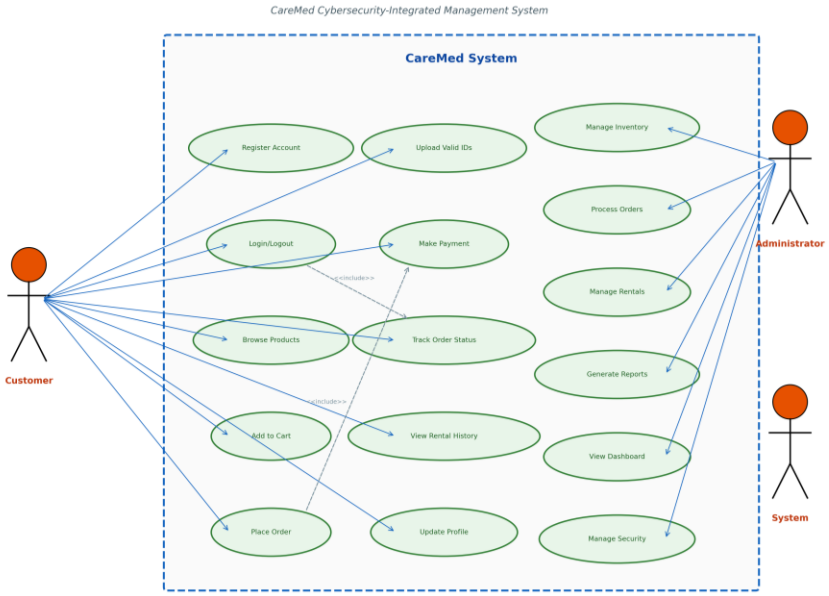
3.6.4 Security Testing: 159

3.6.5 User Acceptance Testing (UAT): 160

System Diagrams 162

Data Flow Diagrams 163

Use Case Diagram 165



..... 165

REFERENCES 166

CHAPTER IV 167

SYSTEM DEVELOPMENT, IMPLEMENTATION, TESTING, EVALUATION, RESULTS, AND DISCUSSION 167

4.1 Overview of the Developed System 167

4.1.1 System Workflow: 169

4.1.2 Sale Transaction Processing Flow: 170
4.1.3 Rental Transaction Processing Flow: 172
4.2 System Development Methodology 174
4.2.1 Requirements Gathering: 174
4.2.2 System Planning: 175
4.2.3 Software Development: 175
4.2.4 Testing: 176
4.3 System Architecture 177
4.3.1 Primary Architectural Components: 179
4.3.2 Request Processing Flow: 179
4.3.3 Security Architecture: 180
4.4 Software and Hardware Requirements 180
4.4.1 Hardware Requirements: 180
4.4.2 Software Requirements: 180
4.5 Database Design 181
4.5.1 Core Entities and Relationships: 182
4.5.2 Detailed Table Specifications: 183
4.6 Deployment and Configuration 185
4.7 Testing, Evaluation, and Results 186
4.7.1 Unit Testing: 186
4.7.2 Integration Testing: 187
4.7.3 System Testing: 187
4.7.4 Security Testing (OWASP-Oriented): 188
4.7.5 User Acceptance Testing: 189

4.8 Formal Quality Evaluation (ISO/IEC 25010) 190

4.9 Results and Discussion 191

4.10 Chapter Summary 192

REFERENCES 193

CHAPTER V 194

CONCLUSION AND RECOMMENDATIONS 194

5.1 Introduction 194

5.2 Summary of Findings 194

5.3 Conclusion 195

5.4 Recommendations 196

5.4.1 System Improvements: 197

5.4.2 Future Research Directions: 197

5.4.3 Implementation Strategies: 198

5.4.4 Alignment with Chapter 1 Objectives: 199

5.5 Impact of the Study 199

5.6 Summary 200

CHAPTER I

INTRODUCTION

1.1 Background of the Study

Medical supply enterprises played an important but often overlooked role in the Philippine healthcare system. They were the businesses that people turn to when a family member comes home from the hospital and needs a wheelchair, a hospital bed, or an oxygen concentrator to continue recovery at home. They served patients, caregivers, small clinics, and community health centers that needed equipment either for purchase or for short-term rental. In many local communities, a medical supply store was the most accessible source of these items, especially for families who cannot afford to buy expensive equipment outright and rely on rental arrangements to manage the cost. CareMed Medical Supply Enterprise was one such business — a small, locally operating enterprise that provided this kind of service to its community, offering medical equipment for both sale and rental to individuals and small healthcare facilities in its area.

Like many small businesses in the Philippines, CareMed had grown over time by relying on manual, paper-based systems to manage its day-to-day operations. Sales were recorded in handwritten logbooks. Inventory was tracked through physical stock cards and occasional manual counts. Rental agreements were written on printed forms and stored in folders. Customer information was kept in notebooks or informal notes on shared computers and messaging apps. While these methods worked well enough when the business was smaller and transactions were fewer, they had become increasingly difficult to manage as the volume of daily operations grew. The bigger the business gets,

the harder it became to keep track of everything accurately using only paper and pen.

The problems that come with manual record-keeping were not unique to CareMed. Many small businesses across the Philippines faced the same challenges. Records get lost or damaged. Information entered by one staff member may not match what another staff member recorded. Finding old transaction details takes time that could be spent serving customers. And perhaps most importantly, there was no reliable way for management to see the full picture of the business at any given moment without spending hours manually compiling data from multiple sources. For a medical supply business specifically, these problems carry extra weight—because when a customer urgently needs a rental wheelchair and staff cannot confirm whether one is available, or when an overdue rental goes unnoticed for weeks because no one checks the folder, the impact goes beyond a business inconvenience. It affects real people who depend on the equipment for their daily care and recovery.

Beyond day-to-day operational challenges, there was growing concern about how customer information was stored and protected. Because CareMed collected personal details from its customers — names, contact numbers, home addressed, and records of what equipment they had rented or purchased — it had a legal obligation under the Philippine Data Privacy Act of 2012 to protect that information from unauthorized access. At present, however, that information was stored in unprotected notebooks, shared computers with no login controls, and messaging app conversations that anyone with access to the device can read. This was not a situation that was created with bad intentions; it was simply how small businesses had always operated. But as data privacy regulations in the Philippines became more actively enforced, and as the consequences of data breaches became more serious,

continuing to manage customer information this way was a risk that CareMed can no longer afford to ignore.

This study was conducted in response to exactly these challenges. The goal was to design and develop a web-based management system for CareMed that handles its core business operations digitally — covering inventory, sales, rental tracking, customer records, and reporting — while also building in proper cybersecurity protections from the ground up. Rather than treating operations and security as two separate concerns to be addressed one after the other, this study treats them as equally important from the very start of the design process. The result was a system that makes CareMed run more efficiently while also ensuring that customer data was handled with the care and protection the law required.

To understand why a system like this was needed, it helps to look at the broader environment CareMed operated in. The Philippine healthcare system had been undergoing major changes in recent years. The Universal Health Care Act of 2019 (Republic Act No. 11223 [1]) expanded health insurance coverage to all Filipinos, which had gradually increased the number of people accessing healthcare services across the country. More patients receiving care — especially in community settings and at home after hospital discharge — means more demand for the kind of equipment that medical supply businesses like CareMed provided. What used to be a modest local operation serving a small and predictable customer base was now expected to served more customers, manage more rentals simultaneously, and respond faster and more reliably than before. Manual systems that were once manageable were struggling to keep up.

The Philippines also had a large and economically significant small business sector. According to the Philippine Statistics Authority's 2021 MSME Survey [2], micro, small, and

medium enterprises account for about 99.5 percent of all registered businesses and employ nearly 63 percent of the business sector workforce. Most of these businesses, including most medical supply stores, still rely heavily on manual processes and had been slow to adopt digital tools. This was not because business owners did not want to improve — it was largely because the available options were often expensive, complex, or designed for much larger organizations. There was a real need for practical, affordable digital solutions that fit the scale and budget of a small Filipino business, and this study aimed to contribute exactly that.

The specific operational challenges of medical supply enterprises within the broader MSME landscape were shaped by the unique combination of product categories and transaction types these enterprises manage simultaneously. Unlike a purely transactional retail business that completes its operational obligation to a customer at the point of sale, a medical supply enterprise with a rental operation maintained an ongoing, relationship-intensive operational commitment to each rental customer throughout the rental period — a commitment requiring continuous monitoring of equipment location and availability status, systematic tracking of return dates and overdue obligations, reliable communication with customers about return reminders, and accurate financial tracking of rental fee accrual and deposit management. The simultaneous management of multiple concurrent rental agreements, each with its own timeline, product commitment, customer relationship, and payment status, created an administrative complexity that scales non-linearly with business volume: as the number of concurrent rentals grew, the cognitive and organizational burden of managing them under a paper-based system grew disproportionately, because the cross-referencing and synthesis required to produce an accurate overview of the rental portfolio from dispersed physical records became

progressively more difficult and error-prone. This complexity scaling dynamic was the primary structural driver of operational failure risk in manual rental management systems as the business grew, and represented the most urgent operational problem that the proposed digital system was designed to addressed.

CareMed Medical Supply Enterprise was a small business operating within the Philippine healthcare supply sector, offering durable medical equipment for both outright sale and rental to a diverse customer base comprising individual patients managing recovery or chronic conditions at home, family caregivers supporting elderly or ill relatives, and small healthcare institutions in its local service area. The enterprise operated from a single physical location serving both as a customer-facing display and sales environment and as a storage facility for the full scope of its inventory. Despite the growing volume and operational complexity of its business, CareMed continues to rely entirely on manual, paper-based processes for the management of all operational functions. Sales transactions were entered in handwritten logbooks maintained at the counter. Inventory was tracked through physical stock cards and periodic manual counting. Rental agreements were recorded on printed paper forms stored in folder systems. Customer information was maintained in handwritten notebooks, informal messaging application records, and unprotected digital files. Business performance information was assembled manually from these scattered sources whenever management required operational context for a decision — a process measured in hours, prone to omission, and dependent on the accuracy of the underlying records from which it was drawn.

The operational consequences of CareMed's manual system limitations were observable and recurring in its day-to-day operations. Inventory discrepancies between stock card records

and actual storage quantities were identified during periodic physical counts but cannot be systematically traced to their source without the transaction-level audit trail that a digital inventory system provided. Rental agreements involving specific items occasionally conflict because the prior commitment of an item to a current rental customer was not reflected in the availability information consulted when a subsequent customer requested the same item. Rental returns occurring outside peak operational hours or during staff transitions were occasionally not recorded promptly, creating periods of uncertainty about an item's availability status. Customer inquiries about order history or rental status required staff to manually search through multiple physical record sources, consuming time and occasionally producing incomplete or inaccurate responses when the relevant records were not readily located. Each of these failure modes, while individually manageable at a low transaction volume, accumulates into a systemic service quality and operational integrity problem as the business grew and the volume of concurrent transactions increases beyond what manual monitoring can reliably sustain.

The cybersecurity dimensions of CareMed's situation constitute a second major challenge that, while less visibly disruptive than the operational consequences of manual record-keeping in daily operations, carries potentially more severe long-term consequences for the enterprise and for its customers. As small businesses across the Philippines had progressively adopted consumer-grade digital communication tools for operational purposes — messaging platforms, email services, and generic spreadsheet applications — they had created digital repositories of sensitive organizational and customer data in environments designed for general communication rather than secure information management. These environments lack the access controls, encryption, audit

mechanisms, and security governance structures that would be expected in a purpose-built business information system. For CareMed, customer personal data including names, contact numbers, home addressed, and records of medical equipment usage were stored across messaging application histories, unprotected shared computer files, and informal note-taking tools — none of which provided the security controls that the Philippine Data Privacy Act of 2012 required all personal information controllers to implemented.

The Philippine Data Privacy Act of 2012, enacted as Republic Act No. 10173 [3] and implemented by the National Privacy Commission through a series of implementing rules, circulars, and advisory opinions, establishes a comprehensive legal framework for the protection of personal information processed by both government agencies and private sector organizations operating in the Philippines. The Act defined personal information broadly to include any data from which the identity of an individual can reasonably be ascertained, and it establishes a category of sensitive personal information — encompassing health, medical, and financial information — that attracts heightened protection requirements. All entities that determine the purposes and means of processing personal data, defined by the Act as personal information controllers, were required to implemented organizational, physical, and technical security measures appropriate to the nature and volume of personal data they process, regardless of the size of the organization or the formality of its data management infrastructure. The penalties for violations of the Act's security requirements include administrative fines of up to five million pesos per violation, civil damages claims from affected data subjects, and criminal penalties including imprisonment for willful or negligent violations. CareMed's current data management practices, characterized by the absence of any formal access

control, authentication, or security mechanism for customer personal data, represented a direct non-compliance with these obligations and expose the enterprise to material legal liability.

The broader national digital transformation context added a further dimension of relevance to the proposed system's development. The Philippine Digital Transformation Strategy 2022-2025, developed by the Department of Information and Communications Technology [4], identified the digitalization of small enterprises as a core component of the country's economic development agenda, recognizing that the productivity benefits of digital transformation cannot be realized at the national scale without extending digital capability to the MSME sector that employs the majority of the Filipino workforce. The strategy specifically identified cybersecurity capability — the ability to not merely adopt digital tools but to use them securely — as a prerequisite for sustainable digital transformation that created lasting value rather than creating new risks. This policy context positions the proposed system as aligned with and contributing to a stated national priority, and situates the study's contribution not merely as a solution to CareMed's specific operational problems but as a demonstration of a replicable approach to secure MSME digitalization that the broader policy agenda required.

It was against this multifaceted backdrop — encompassing the expanding service obligations of the Philippine healthcare supply sector under universal health care policy, the operational limitations of manual management in a growing enterprise, the cybersecurity risks and legal compliance obligations arising from the Philippine Data Privacy Act, and the national priority of secure and inclusive digital transformation — that this study proposes the development of a Cybersecurity-Integrated Digital Infrastructure Model for CareMed Medical Supply Enterprise. The proposed system was

designed not as a digital replica of CareMed's manual processes but as a fundamentally re-architected operational platform in which functional automation and information security were developed simultaneously as co-equal, inseparable design priorities from the earliest stage of system conception. This security-by-design approach, recognized as a best practice engineering principle in frameworks including the OWASP Top 10 and the NIST Cybersecurity Framework, distinguishes the proposed system from generic management software that automates operations without embedding the security controls necessary to protect the sensitive data those operations generate. The system was designed with generalizability as an explicit consideration, so that its architecture and methodology served as a replicable model applicable to other small Philippine medical supply enterprises facing analogous operational and cybersecurity challenges.

The management information systems literature provided extensive theoretical grounding for understanding why manual record-keeping systems fail as organizational scale increases. Researchers consistently identified five primary categories of information quality failure in manual data management: accuracy failures from transcription errors introduced each time data was physically transferred between records; completeness failures from omission of data at recording due to time pressure or workflow interruption; timeliness failures from the delay between an event's occurrence and its entry into accessible records; consistency failures from the maintenance of multiple independent record sources that diverge over time; and accessibility failures from the physical barriers to locating needed information in distributed paper storage. All five failure categories were present and observable in CareMed's current environment and

were directly addressed by the proposed digital management system.

Research conducted by the Philippine Institute for Development Studies [5] on MSME productivity constraints identified record-keeping inadequacy as one of the three most frequently cited internal barriers to small business growth, alongside limited access to credit and inadequate workforce development. Enterprises that reach the operational scale where manual record-keeping begins to fail systematically experience a characteristic sequence of consequences: increasing customer complaint rates driven by fulfillment errors; rising staff error rates driven by the cognitive overload of managing high transaction volumes manually; growing management uncertainty from the inability to generate reliable operational overviews without prohibitive staff time investment; and escalating compliance risk from the accumulation of record-keeping deficiencies. CareMed's operational situation reflected this pattern precisely, and the proposed system was designed to addressed the root cause — the absence of integrated digital management infrastructure — rather than its symptoms.

The theoretical and empirical literature on information security in small enterprises provided equally important context for the cybersecurity dimensions of this study. Bada and Nurse's [6] analysis of cybersecurity challenges in small and medium enterprises identified three structural factors that consistently generate security vulnerabilities in this organizational category: resource constraints preventing investment in dedicated security expertise; awareness deficits leaving owners and staff uninformed about specific threats and their mitigations; and cultural factors that prioritize operational convenience over security discipline, particularly when security measures were perceived as adding friction to customer-facing processes. All three factors were present in

CareMed's environment. The enterprise lacks the budget for dedicated IT security supported; management and staff had not received formal cybersecurity awareness training; and the informal digital tools currently used for business records were adopted for operational convenience without consideration of their security implications. The proposed system addressed all three dimensions: it eliminates the needed for specialized security expertise by embedding controls into the system architecture itself; it reduces the awareness burden on staff by making secure behavior the default rather than requiring active security decisions for each interaction; and it implemented security in ways that supported rather than impede operational workflows.

The growing emphasis on cybersecurity in the Philippine regulatory environment added further urgency to the security integration objectives of this study. Beyond the Data Privacy Act of 2012, the Philippine government had progressively strengthened the cybersecurity regulatory landscape through instruments including the Cybercrime Prevention Act of 2012 (Republic Act No. 10175) [7], which criminalizes unauthorized access to computer systems and the misuse of personal data obtained through digital means, and the National Cybersecurity Plan 2023-2028 [8], which articulates the government's strategy for developing national cybersecurity capability across all sectors of the economy including the MSME sector. The National Privacy Commission's series of implementing circulars and advisory opinions had progressively clarified and in some cases expanded the specific technical and organizational security measures expected of personal information controllers, reinforcing the legal context within which CareMed's current data management practices represented a compliance gap with material legal consequences.

The intersection of operational management and cybersecurity requirements in the proposed system's design

reflected a recognition in the information systems research community that these two dimensions cannot be addressed effectively in isolation. A management system that automates business processes without securing the data those processes generate created an expanded digital attack surface without the protections needed to defend it — potentially more dangerous than the manual system it replaces, because digital concentration of business data makes a successful breach more consequential. Conversely, a security framework applied to a system that fails to effectively automate and integrate business processes created compliance overhead without delivering the operational value that motivates sustained secure use. The proposed system was designed to be simultaneously operationally effective and genuinely secure, treating usability-driven adoption and security discipline as complementary design objectives and demonstrating through its architecture that these goals were achievable together within small enterprise resource constraints.

CareMed's operational profile — a small single-location enterprise managing combined sales and rental operations, employing a small staff team without IT supported, serving a local community customer base in the Philippine context — was representative of a large population of small medical supply enterprises operating across the country's cities, municipalities, and provinces. The Department of Health's licensing database for healthcare-related commercial establishments identified thousands of registered medical supply enterprises across all regions of the Philippines, the overwhelming majority of which were classified as micro or small enterprises sharing CareMed's characteristic constraints of limited capital, small staff teams, and management by owners without formal technology backgrounds. The system architecture, development methodology, security design framework, and evaluation approach documented in this study

were designed with this representative population in mind, ensuring that the solutions developed for CareMed were practically applicable to the broader sector rather than being specific to an atypical enterprise context.

1.2 Statement of the Problem

General Problem

CareMed Medical Supply Enterprise currently conducts all of its business operations — encompassing inventory management, sales transaction recording, equipment rental lifecycle management, customer record maintenance, financial tracking, and business performance reporting — through entirely manual, paper-based processes that had remained structurally unchanged since the enterprise's establishment. This sustained reliance on manual methods generates compounding, mutually reinforcing limitations across every operational dimension. Operational efficiency was constrained by the time and labor required for manual recording, physical retrieval, and data compilation tasks that consume staff capacity otherwise available for customer service. Data accuracy was repeatedly undermined by transcription errors introduced each time information was physically transferred between records, copied from one logbook to another, or verbally communicated without written verification. Record security was fundamentally compromised by the complete absence of any authentication, access control, or data protection mechanism governing who may access, modify, or remove business records and the personal information of customers they contained. Business responsiveness was limited by the multi-hour process required to compile even basic operational summaries from dispersed physical sources. The cumulative effect of these interrelated limitations created an environment where the risk of service failure, record loss, data protection non-compliance, and management decisions based

on incomplete or inaccurate information grew in direct proportion to the business's growth. There was a critical needed for a secure, integrated digital management system that can systematically automate CareMed's core business processes while incorporating cybersecurity controls to protect organizational and customer data in compliance with Philippine law.

Specific Problems

The following specific problems had been identified through structured observation of CareMed's operational environment, assessment of existing record-keeping practices, analysis of operational failures attributable to system limitations, and preliminary interviews with management and staff:

First, the complete absence of real-time inventory visibility in CareMed's current management approach created persistent operational uncertainty that directly impairs service quality and revenue realization. Inventory tracking relies exclusively on manually maintained stock cards updated at irregular intervals following transactions, combined with periodic full physical counts when management perceives a needed to verify stock positions. Between counting events — which may be separated by days or weeks depending on operational pressures — the stock card records may not accurately reflected the cumulative effect of transactions that had occurred since the last update, particularly during high-volume periods when competing demands cause staff to defer record updates. This gap between recorded and actual stock positions means that a staff member responding to a customer availability inquiry cannot reliably confirm availability from records alone and may needed to physically check the storage area, delaying service and creating inconsistencies when simultaneous transactions reference the

same inventory. The absence of automated reorder threshold monitoring means that stock depletions were detected only when a customer attempts to order an unavailable item, at which point the enterprise had already failed to maintained the proactive supply management that reliable service delivery required. Additionally, the absence of item-level tracking in the rental inventory pool created the risk that a single item may be simultaneously committed to multiple customers — a damaging outcome in a medical equipment context where no suitable substitute may be available for a patient with specific clinical requirements.

Second, the exclusively physical nature of CareMed's record system created vulnerability and accessibility limitations that compound over time as records accumulate. All business documentation — handwritten sales invoices, printed rental agreement forms, customer information notebooks, inventory logs, and payment records — exists solely in physical form, stored at a single location accessible to any person present on the business premises without authentication or access restriction. Physical records were vulnerable to irreversible loss events including water damage, fire, humidity-induced paper deterioration, accidental misplacement, or deliberate unauthorized removal, with no backup or recovery mechanism available. Retrieval of any specific historical record required manual searching through organized storage systems, creating response delays when customers or management required historical transaction data. Cross-referencing between record categories — identifying all transactions associated with a particular customer, tracing the rental history of a specific item, or compiling revenue data for a defined period — required manual compilation from multiple physical sources, a process prone to omission errors when the volume of records to be searched was large and that may

required hours of staff time that could otherwise be devoted to customer service activities.

Third, CareMed currently operated with a complete absence of cybersecurity controls governing access to the business and customer information maintained across its records. There was no authentication system controlling which individuals can access business records in any format. There were no user roles establishing differentiated access rights based on operational necessity. There was no session management governing digital access periods or enforcing termination policies. There was no audit trail documenting which individuals had accessed or modified specific records at specific times. The practical consequence was that the full scope of CareMed's information — including sensitive customer personal data such as home addressed, contact numbers, and medical equipment usage histories; commercially sensitive pricing and supplier information; and confidential financial data — was accessible without restriction to any person present on the premises or with access to any device where informal digital records were maintained. This situation was directly inconsistent with the obligations of the Philippine Data Privacy Act of 2012, which required all personal information controllers to implemented appropriate organizational, physical, and technical security measures regardless of organizational size. The current data management practices expose the enterprise to administrative sanctions, civil liability, and criminal prosecution under the Act, as well as to the reputational harm that would follow any customer data protection failure.

Fourth, the management of rental equipment under the current manual system was particularly and systematically vulnerable to operational failure as the concurrent rental portfolio grew. CareMed maintained a rotating pool of rental items lent to customers under individual paper rental

agreements specifying the customer's details, items rented, rental start and return dates, and deposit arrangements. Monitoring this portfolio for overdue returns required staff to periodically review the physical rental folder — a process that was not systematically scheduled, occurs only when competing operational demands permit, and became progressively less reliable as the number of agreements requiring review increases. Overdue returns were therefore identified sporadically and reactively rather than systematically and proactively. The operational consequences accumulate: overdue items were unavailable for subsequent customers; extended rental revenue was not systematically tracked; deposit records were not definitively linked to specific items; and the business lacks the documentation needed to supported a consistent, fair process for addressing disputed return dates. Each consequence individually represented a significant operational and financial impact; in combination, they constitute a structural revenue leakage and service quality risk that grew with the rental volume.

Fifth, the generation of business performance information under the current manual system was an entirely labor-intensive process that structurally prevents the timely, data-informed management decision-making that effective business governance required. Generating any operational summary — monthly sales figures, active rental counts, inventory valuation, or customer outstanding obligations — required staff to manually compile figures from multiple physical record sources, reconcile discrepancies between overlapping records, and produce a summary through manual calculation. This process was estimated to required a minimum of two to three hours for a basic monthly report involving only the most recent period, and significantly longer for analyses requiring comparison across multiple periods or cross-referencing between record categories. The resulting reports reflected the

state of records at the time of the most recent physical recording rather than the actual current state of operations, because transactions occurring after the last record update were not captured in the compiled summary. Management decisions made on the basis of these delayed, labor-intensive, and inherently approximate reports were therefore subject to the compounding uncertainties of manual recording errors, retrieval omissions, and the lag between operational events and their reflection in management information. This constraint on management information quality represented a fundamental limitation on the enterprise's capacity for effective governance, strategic planning, and responsive customer service management.

1.3 Objectives of the Study

1.3.1 General Objective:

The general objective of this study was to design, developed, and comprehensively evaluate a cybersecurity-integrated web-based management system for CareMed Medical Supply Enterprise that measurably improves the operational efficiency, data accuracy, information security, and regulatory compliance posture of the organization's core business processes across the domains of inventory management, sales transaction processing, equipment rental lifecycle management, customer relationship management, and business performance reporting. The proposed system was conceived not merely as a digital replacement for CareMed's existing manual processes but as a purposefully re-architected operational platform in which functional automation and information security were developed simultaneously as inseparable design priorities, guided by the security-by-design philosophy recognized in the OWASP Top 10 and ISO/IEC 27001 frameworks. The system was additionally intended to served as a practically implemented, academically documented, and replicable model that other small Philippine

enterprises in the healthcare supply sector can study, adapt, and apply within their own operational environments, demonstrating that robust operational automation and genuine cybersecurity integration were achievable within the financial, technical, and organizational resource constraints characteristic of small enterprises in this sector.

1.3.2 Specific Objectives:

In systematic pursuit of the general objective stated above, this study aims to accomplish the following five specific, measurable, and interconnected objectives:

The first specific objective was to conduct a systematic, formally documented analysis of CareMed's existing manual workflows across all five operational areas using structured management and staff interviews, direct observational assessment of business processes and record systems, and review of existing physical records, producing a formally documented requirements specification that identified the complete set of functional, non-functional, security, and interface requirements the proposed system must satisfy. This specification would be validated with CareMed management prior to the commencement of system design, ensuring that the system directly addressed operational realities and user needed with specificity and accuracy rather than imposing a generic solution that may not align with the enterprise's specific workflows and user capability profile.

The second specific objective was to design and developed a fully functional web-based management system incorporating six integrated modules: an Inventory Management Module providing real-time stock tracking, movement history recording, and automated low-stock alerting; a Customer Management Module providing a centralized digital customer record repository with comprehensive search, retrieval, and activity summary functions; an Order and Sales Processing

Module managing the complete lifecycle of sales transactions from placement through fulfillment and payment confirmation; an Equipment Rental Tracking Module providing systematic management of the complete rental lifecycle including check-out recording, return date monitoring and overdue flagging, automated alert generation, return processing, and inventory restoration; a Reports and Dashboard Module providing automated generation of operational reports and real-time management dashboards; and a Cybersecurity Module implementing the complete security architecture governing all access, data protection, and audit functions. The system was developed using Python 3 with the Flask micro-framework, MySQL relational database managed through the SQLAlchemy ORM, and Bootstrap 5 for the responsive front-end interface.

The third specific objective was to design and implemented a comprehensive, defense-in-depth cybersecurity architecture as an integral property of the system's core design from its initial architecture phase, encompassing: secure user authentication using Flask-Bcrypt for bcrypt-hashed credential storage; brute-force protection through Flask-Limiter rate limiting on the authentication endpoint; role-based access control implemented through Flask-Login role checking and custom route protection decorators; server-side session management with configurable inactivity timeout and secure cookie configuration; input validation and sanitization through Flask-WTF validators and SQLAlchemy parameterized queries for all database interactions; output encoding through Jinja2's auto-escaping for all template-rendered content; CSRF token validation for all state-changing requests through Flask-WTF; HTTPS enforcement for all client-server communications; and a comprehensive system event audit log recording all significant security and operational events with immutable timestamps, user identifiers, IP addressed, and descriptive action summaries. The entire architecture was

designed with explicit reference to the OWASP Top 10 and the Philippine Data Privacy Act of 2012.

The fourth specific objective was to conduct systematic, multi-level, formally documented testing across five modalities: unit testing verifying the correct behavior of individual system component functions in isolation; integration testing verifying the accuracy of module interactions and data flows; comprehensive system testing against the complete functional requirements specification using a representative test data set; security testing applying structured manual test procedures based on the OWASP Top 10 framework to verify the system's resistance to each of the ten critical web application vulnerability categories; and User Acceptance Testing conducted with representative participants from both Administrator and Customer user role groups, evaluating system usability and functional completeness through structured testing scenarios derived from CareMed's actual operational workflows. All testing was documented through formal test plans, test case records, and security assessment reports.

The fifth specific objective was to evaluate the overall quality and acceptability of the developed system through a structured formal evaluation process using an instrument designed with reference to the ISO/IEC 25010 software product quality standard, assessing the system across five quality dimensions: functional suitability, measuring the completeness and correctness of the system's functional coverage; performance efficiency, assessing responsiveness and resource utilization; usability, evaluating the learnability and operability of the system interface; reliability, measuring consistency of performance under normal conditions; and security, assessing the effectiveness of implemented cybersecurity controls. The instrument was administered as a five-point Likert scale questionnaire to a purposively

selected sample of administrator-role and customer-role evaluators, with responses analyzed using descriptive statistics to produce a formal quantitative quality assessment across all evaluated dimensions.

1.4 Scope and Delimitation

1.4.1 Scope of the Study:

This study encompasses the complete design, development, cybersecurity integration, multi-level testing, and formal quality evaluation of a web-based digital management system for CareMed Medical Supply Enterprise. The scope was defined across four primary dimensions: the functional coverage of the system, the security architecture of the system, the target user population, and the technical platform. Each was described in the following subsections.

The Inventory Management Module provided real-time visibility into the availability and status of all products in both the sale inventory and rental pool. The module supported three primary transaction types: stock-in transactions recording additions following supplier deliveries or rental returns; stock-out transactions recording removals through sales fulfillment or rental check-out; and adjustment transactions recording corrections following physical verification exercises. Each transaction was captured with a timestamp, transaction type, quantity change, resulting stock level, user identifier, and optional reference notes. The module maintained a continuous chronological movement history for each product, supporting routine inventory verification and forensic investigation of discrepancies. Automated low-stock alerts were generated when available quantity falls below an administrator-configured threshold, enabling proactive procurement action before stockout conditions affect customer service. Product catalog management functions allowed administrators to added and update products, configure rental

availability and pricing, and set reorder thresholds for each item.

The Customer Management Module provided a centralized, searchable, and access-controlled digital repository replacing the current dispersed system of physical customer notebooks and informal digital records. The module maintained a structured profile for each registered customer capturing full name, contact information, addressed, registration date, and a complete transaction history linking the customer record to all associated sales orders and rental agreements. Search functionality allowed administrators to locate records using partial name matching, contact number lookup, or transaction reference identifiers, enabling rapid customer identification during service interactions. A comprehensive activity summary view for each customer displays all historical and current transactions in a unified chronological display with status indicators. A customer-facing self-service portal enabled customers to register, log in securely, browse the product and rental catalog, submit orders, view active order and rental status, access transaction history, and update contact information.

The Order and Sales Processing Module manages the complete transactional lifecycle of product sales from order submission through fulfillment and payment confirmation. Administrator-role users maintained a structured product catalog with item names, descriptions, available quantities, and pricing. Customer-role users browse the catalog and submit orders specifying delivery or pickup preferences. Administrators process submitted orders through a defined status lifecycle — received, confirmed, preparing, ready for dispatch, and completed — with automatic inventory quantity deductions upon order confirmation. Payment confirmation was managed through a reference submission workflow aligned with Philippine payment practices: customers submit payment

reference numbers following payment through their preferred channel, and administrators review and confirm receipts in the administrative panel. A comprehensive order history provided a searchable and filterable record of all transactions accessible to administrators for management and to customers for their own records.

The Rental Tracking Module addressed CareMed's most operationally critical management gap by providing a systematic, continuously visible, and automated approach to managing the complete rental lifecycle. Rental agreements were created at equipment check-out capturing the customer identifier, a detailed listing of rented items referenced to inventory records, rental start and return dates, the rental fee structure, and any deposit amount collected. The rental status dashboard provided a continuously updated overview of the complete active portfolio organized by return status: active rentals with days remaining, rentals approaching return within a configurable advance warning period highlighted with alert indicators, and overdue rentals prominently flagged with days elapsed beyond the scheduled return date. Automated overdue alert notifications were presented to administrators at each login, ensuring systematic monitoring regardless of competing operational demands. Upon confirmed item return, the system records the return event, marks the agreement as completed, and automatically restores returned items to available inventory for subsequent bookings.

The Reports and Dashboard Module provided automated generation of the operational reports that currently required hours of manual compilation. Four primary report categories were generated on demand for administrator-specified time periods: sales summary reports presenting transaction counts, gross revenue, and product movement data organized by category; rental status reports summarizing agreements initiated, active, completed, and overdue in the period with

associated revenue and duration statistics; inventory status reports displaying current stock levels with reorder threshold comparisons and high-movement product identification; and customer activity reports summarizing transaction patterns and identifying customers with overdue rental obligations. All reports were presented in dashboard-integrated format with headline summary statistics and sortable tabular detail views, and were available in printable download formats. Access to all reporting and dashboard functions was strictly restricted to authenticated Administrator-role accounts.

The Cybersecurity Module constitutes the security infrastructure layer governing all access, data protection, authentication, authorization, and audit functions across the entire system. Authentication was implemented through Flask-Login with Flask-Bcrypt managing all password hashing and verification at a configured work factor. Brute-force protection was implemented through Flask-Limiter rate limiting applied to the authentication endpoint. Role-based access control was enforced through Flask-Login role checking and custom Python route decorators on every protected route. Session management uses Flask-Login's permanent session with configurable inactivity timeout, secure HttpOnly and SameSite cookie settings, and complete server-side session destruction on logout. Input security uses Flask-WTF validators and SQLAlchemy parameterized ORM queries throughout the data access layer. CSRF protection uses Flask-WTF's synchronizer token pattern for all state-changing POST requests. Output encoding uses Jinja2's auto-escaping for all template-rendered content. The system audit log was implemented as a dedicated database table written through a centralized logging service called from every significant event handler, recording timestamp, user identifier, role, source IP addressed, action type, affected record identifiers, and a descriptive action summary for every auditable system event.

The target user population comprises two roles reflecting CareMed's organizational structure. Administrator-role users encompass management and authorized administrative staff with full access to all system modules and functions, including all management dashboards, reporting capabilities, inventory and customer record management, and administrative configuration functions. Customer-role users encompass registered customers with access restricted to the customer-facing portal for product browsing, order submission, rental status viewing, transaction history access, and personal account management. Both roles interact with the system through standard web browser interfaces accessible from any internet-connected device, requiring only basic computer and web browser literacy without specialized technical training.

The technical platform comprises a web-based application developed using Python 3 with Flask as the application server, MySQL as the relational database management system accessed through the SQLAlchemy ORM, and Bootstrap 5 as the front-end framework providing a responsive, mobile-compatible interface. The system follows a Model-View-Controller architectural pattern with Flask route handlers as controllers, Jinja2 HTML templates as views, and SQLAlchemy model classes as the data layer. The system was designed for deployment on standard web hosting infrastructure accessible through any modern web browser, with no client-side software installation requirements.

1.4.2 Delimitations of the Study:

The following delimitations defined the specific boundaries of this study, clearly distinguishing the scope of the current research from related areas that, while potentially valuable as future research directions or system enhancement priorities, fall outside the objectives achievable within this capstone project's constraints.

The system developed in this study was a web-based application delivered through standard web browser clients and did not include a dedicated native mobile application for iOS or Android platforms. While Bootstrap 5's responsive design ensured that the interface adapts to mobile screen dimensions and provided functional mobile browser access, the current system did not supported native capabilities including push notification delivery for rental reminders or reorder alerts, offline data access for environments without reliable internet connectivity, or device hardware integration such as camera-based barcode scanning for inventory management. These capabilities represented potentially valuable future enhancements whose development would required separate platform-specific codebases, additional testing environments, and application store distribution processes — requirements exceeding this project's scope. The development of native mobile extensions was identified as a priority direction for future research.

Direct integration with external electronic payment processing services was not implemented in this study. Integration with Philippine mobile payment platforms such as GCash and Maya, or online banking transfer gateways, required merchant account registration, satisfaction of regulatory requirements under Bangko Sentral ng Pilipinas circulars governing electronic payment processing, implementation of provider-specific API integrations with associated security compliance requirements, and ongoing maintenance obligations — requirements that extend beyond the scope of a capstone research project. Payment confirmation in the current system uses the reference submission workflow that reflected the actual payment behavior of CareMed's existing customer base. Direct payment gateway integration was identified as a natural future enhancement as the enterprise's digital customer adoption matures.

The system was designed as a standalone operational management platform and did not include integration with external healthcare information infrastructure, including electronic health record systems, hospital management systems, pharmacy information systems, or government health databases such as the Philippine Health Information System. CareMed's role as a medical equipment sales and rental enterprise — not as a clinical care provider — did not required clinical data exchange with healthcare facilities. The system's customer data model captures only the personal and transactional information necessary for managing commercial equipment transactions and did not include clinical data fields, health record linkages, or other clinical information infrastructure elements. The system did not implemented clinical data standards such as HL7 FHIR or standardized medical terminologies such as ICD-10 or SNOMED CT.

Security testing employs structured manual testing procedures based on the OWASP Top 10 framework applied by the research team following documented test plans and did not include formal penetration testing by independent accredited cybersecurity professionals or automated vulnerability scanning using commercial security assessment platforms. This delimitation reflected the resource and operational constraints of an academic capstone project rather than a judgment that these approaches lack value. Independent penetration testing by accredited professionals represented the gold standard for security validation in production deployment contexts and was strongly recommended for any deployment beyond the academic environment. The security testing in this study was calibrated to verify that the system addressed the most commonly exploited web application vulnerability categories within the OWASP framework, establishing a documented security baseline supporting the

more comprehensive assessment a production deployment would required.

This study addressed the requirements analysis, design, implementation, testing, and evaluation phases of the development lifecycle and did not extend to production deployment at CareMed, post-deployment operational monitoring, system maintenance and security patching, ongoing user supported operations, or longitudinal assessment of operational impact. The evaluation was conducted at the conclusion of the development and testing phases using a structured User Acceptance Testing protocol and ISO 25010-based quality evaluation instrument administered within the academic project timeframe. Assessment of the system's long-term operational performance, its security resilience under real-world conditions, and its measurable impact on CareMed's business efficiency and data protection compliance over an extended deployment period were identified as priority directions for future longitudinal research.

1.5 Significance of the Study

The development and evaluation of a cybersecurity-integrated web-based management system for CareMed Medical Supply Enterprise was anticipated to generate substantive and enduring benefits for a diverse range of stakeholders connected to the enterprise's operations, to the Philippine healthcare supply sector, and to the academic, professional, and policy communities engaged with the challenges of digital transformation and cybersecurity governance in small enterprise environments. The following sections articulate the specific significance of this study for each identified beneficiary group.

CareMed Management

CareMed's management team was the most immediate and operationally direct primary beneficiary. The system would

fundamentally transform the management information environment by replacing delayed, labor-intensive, and inherently approximate manual reporting with a real-time digital intelligence infrastructure providing immediate, accurate, and continuously updated visibility across all business dimensions. Management would acquire the capability to assess current inventory positions and approaching reorder requirements at any time through the live inventory dashboard; monitor the complete active and overdue rental portfolio without dependence on periodic manual folder reviews; access sales performance data for any specified period through automated report generation in minutes; and evaluate customer activity patterns to supported data-informed relationship management decisions. This transformation directly enhanced the capacity for timely, evidence-based decision-making across procurement planning, rental inventory optimization, and financial performance monitoring. The embedded cybersecurity architecture additionally provided the data protection infrastructure necessary for compliance with the Philippine Data Privacy Act, materially reducing the enterprise's legal liability exposure and building organizational capability for secure digital operations that increasingly sophisticated customers and regulatory environments would demand.

Employees and Administrative Staff

CareMed's employees and administrative staff would experience direct, material improvements in their day-to-day working environment through systematic reduction of the manual record-keeping and retrieval workload that currently consumes substantial operational time and cognitive capacity. The time devoted to maintaining handwritten records, searching physical files for customer information, compiling rental status summaries, and calculating inventory balances was significantly reduced as the system automates these routine functions, releasing staff capacity for higher-value customer-

facing activities — product consultation, order coordination, proactive rental follow-up, and relationship management — that directly contributed to service quality and business development. The system's search and retrieval capabilities would allowed staff to locate any customer record, transaction history, or inventory status within seconds through a simple search interface, dramatically improving the speed and quality of their responses to customer inquiries. The clearly defined role-based access control architecture would provided each staff member with an unambiguous specification of their authorized system functions, reducing the role ambiguity that currently arises from the absence of formal access governance.

Customers of CareMed

CareMed's customers — individual patients, family caregivers, and small institutional clients — would experience substantive improvements in service quality, transparency, and information access as a direct result of the proposed system. The customer-facing self-service portal would provided a convenient digital channel through which customers can browse products and rental items, submit orders, monitor real-time order and rental status, access transaction history, and update account information from any internet-connected device at any time, without requiring phone calls or physical visits. The systematic rental agreement management would ensured customers receive accurate, documented information about their rental terms and return obligations, with consistent return-related communications based on system-verified records rather than manually compiled notes subject to transcription error. The system's data protection architecture would ensured that customers' personal information — including sensitive details of medical equipment usage — was stored in a secured, access-controlled, and audited environment, providing meaningful assurance that their privacy was protected in accordance with the Data Privacy Act of 2012.

Future Researchers

This study contributed to the academic literature on digital transformation and cybersecurity integration in Philippine small and medium enterprises, specifically within the healthcare supply sub-sector — a segment that had received comparatively limited dedicated research attention despite its significance as a service provider to vulnerable patient populations. The comprehensive developmental research methodology employed — structured workflow analysis, security-by-design architecture, multi-level testing including OWASP Top 10-structured security testing, and ISO 25010-based quality evaluation — provided a complete and replicable methodological framework that future researchers undertaking similar studies can draw upon, critique, or extend. The systematic documentation of operational challenges, technical design decisions with their rationale, cybersecurity mechanisms and their regulatory relationships, and formal evaluation findings constitutes a referenceable case study for researchers studying related enterprise types — pharmacies, dental supply companies, laboratory equipment providers, or other healthcare-adjacent MSME categories. Future researchers may build upon this study by investigating the system's extended operational performance in a longitudinal deployment study, expanding security testing to include formal penetration testing, or extending the architecture with the native mobile, payment gateway, or healthcare system integration capabilities identified in the delimitations.

Information Technology Practitioners and Software Developers

For IT practitioners and software developers working on management systems for small enterprises in regulated or data-sensitive sectors, this study provided a practically implemented and academically validated reference for security-

by-design development within resource-constrained project environments. The technology selection analysis comparing Python Flask, MySQL, and Bootstrap 5 against alternatives in the Philippine small enterprise development context provided a referenceable evaluation framework for practitioners facing similar decisions. The cybersecurity architecture implementation — covering bcrypt authentication, Flask-Login role-based access control, Flask-Limiter brute-force protection, Flask-WTF CSRF and input validation, SQLAlchemy parameterized SQL injection prevention, Jinja2 XSS prevention, and comprehensive audit logging — constitutes a complete, end-to-end, practically validated reference that practitioners can adapt for their own projects. The OWASP Top 10-structured security testing methodology demonstrates an accessible, systematic approach to meaningful security verification applicable by development teams without dedicated security testing personnel, particularly relevant for small enterprise projects where formal security specialists were not available.

The Philippine Healthcare Supply Sector and Broader Society

At the sectoral and societal level, this study contributed to the advancement of secure, reliable, and patient-centered digital operations within the Philippine healthcare supply ecosystem. The ongoing UHC Act implementation was progressively extending formal healthcare coverage to communities that depend on local small enterprises for access to essential medical equipment. The reliability of these enterprises — their ability to maintained accurate inventory, manage rental equipment responsibly, protect customer personal data, and deliver consistent, professional service — was therefore not merely a commercial performance metric but a public health consideration with community-level implications. By developing, documenting, and evaluating a viable, affordable model for secure digitalization in a small

medical supply enterprise, this study contributed practically to raising the service standard and data protection capability of this sector. The replicability of the proposed system means its benefits were not limited to CareMed but were available to the broader population of small Philippine medical supply enterprises facing similar operational challenges, contributing to the national goal of an inclusive digital economy in which the protections and capabilities enabled by digital technology were accessible to small enterprises serving everyday Filipino communities.

Beyond the immediate beneficiaries identified in the preceding subsections, this study carries significance for the Philippine regulatory community engaged with the practical implementation of the Data Privacy Act of 2012 in the MSME sector. The National Privacy Commission had consistently recognized that the vast majority of personal information controllers in the Philippines were small enterprises that process customer personal data as a routine aspect of their commercial operations — taking customer names, contact numbers, and addressed for order fulfillment, maintaining purchase and transaction histories, and recording the personal details of individuals who engage with them as service providers. Demonstrating through a concrete, fully documented implementation that a small enterprise can build a genuinely compliant data management system within its operational resource constraints — and that doing so improves rather than impedes operational effectiveness — contributed to the empirical basis for regulatory guidance that was practically achievable for the MSME sector, not merely aspirationally desirable from a policy perspective.

The academic community engaged with the study of digital transformation, management information systems, and cybersecurity in developing country contexts would find in this study a case study that contributed to the empirical

literature on technology adoption in under-resourced organizational settings. The Philippines presents a particularly interesting research context for these questions because of the combination of factors present: a large and economically significant MSME sector with limited technology adoption; an advanced and actively enforced personal data protection legal framework creating compliance obligations that exceed current MSME capability; a rapidly expanding healthcare delivery system under the UHC framework that was creating new operational pressures on health supply chain participants; and a national digital transformation policy agenda with explicit MSME digitalization objectives. The system developed in this study and the methodology through which it was developed and evaluated contributed an empirical data point to the literature on how these factors interact in practice, and how system design approaches rooted in security-by-design principles can addressed the intersection of operational and security requirements in this complex environment.

1.6 Definition of Terms

The following terms are defined as they are specifically applied within the context of this study. Definitions are presented in alphabetical order and are intended to provide clear and precise explanations of technical, legal, procedural, and specialized terms used throughout the research documentation, ensuring that the study is interpretable by readers with varying levels of familiarity with its technical and regulatory subject matter. Where a term has both a general meaning in common usage and a specific meaning within this study, both meanings are noted and the specific application is clarified.

Agile Development Methodology. A software engineering and project management philosophy characterized by iterative,

incremental delivery of working software organized into time-bounded development cycles called sprints, typically one to four weeks in duration. Agile methodology prioritizes continuous stakeholder collaboration, adaptability to evolving requirements, and the delivery of tested, working functionality at the conclusion of each sprint over comprehensive upfront documentation and rigid adherence to an initial plan. The Agile Manifesto, the foundational document of the Agile approach, articulates four core values: prioritizing individuals and interactions over processes and tools; working software over comprehensive documentation; customer collaboration over contract negotiation; and responding to change over following a fixed plan. In this study, Agile methodology guides the organization of the development phase into structured sprints each targeting a specific system module, enabling continuous review and adaptation based on testing feedback and stakeholder input.

Audit Log. A chronological, sequentially ordered, and integrity-protected record of operationally and security-relevant events occurring within an information system, maintained with sufficient detail to enable retrospective reconstruction of the sequence of actions that produced the current state of the system's data and configuration. Individual audit log entries capture the precise timestamp of the event, the identifier and role of the user whose actions generated it, the source IP address of the user session, the specific action type performed, the identifiers of affected data records, and a descriptive summary sufficient to enable a reviewer to understand what was done without consulting other records. In this study, the audit log is implemented as a dedicated database table written to through a centralized logging service called from every significant system event handler, and access to audit log records is restricted exclusively to Administrator-role users.

Authentication. The process by which a digital system verifies the claimed identity of a user attempting to access protected resources before the access request is evaluated against applicable access control policy. Authentication typically requires the presentation of a knowledge factor (a password), a possession factor (a one-time code or hardware token), or an inherence factor (a biometric characteristic). In this study, authentication is implemented as a single-factor knowledge-based mechanism through Flask-Login, requiring a registered username and password verified by Flask-Bcrypt against a bcrypt-hashed representation stored in the user accounts table, ensuring that the actual password value is never stored in a recoverable form.

Authorization. The access control process by which a system determines what specific functions, data records, or resources an authenticated user is permitted to access based on the access policies associated with the user's assigned role. Authorization is logically distinct from authentication: authentication establishes who the user is, while authorization determines what that identity is permitted to do. In this study, authorization is implemented through role-based access control using Flask-Login's current_user role property and custom Python decorators applied to every protected route handler, returning an HTTP 403 Forbidden response to any request where the authenticated user's role does not include the required permission for the requested action.

bcrypt. A password-hashing function specifically designed for the secure storage of user authentication passwords, developed by Niels Provos and David Mazières. bcrypt incorporates three properties distinguishing it from general-purpose hash functions for password storage: a random salt value unique to each hash computation preventing pre-computed rainbow table attacks; integration of the salt into the stored

hash output enabling verification without separate salt storage; and an adjustable work factor controlling computational cost that can be increased as hardware speeds improve to maintain resistance to brute-force attacks. In this study, bcrypt is applied to all user passwords at account creation and password change events through the Flask-Bcrypt library, and the stored hash values are used for credential verification at authentication.

Bootstrap 5. The fifth major version of Bootstrap, an open-source front-end framework providing HTML structure conventions, CSS styling rules, utility classes, and JavaScript interaction components for building responsive, cross-browser-compatible web interfaces. Bootstrap 5's responsive grid system enables layouts that automatically reorganize for different viewport widths from narrow smartphone screens to wide desktop monitors. In this study, Bootstrap 5 is the primary front-end framework for all system user interfaces, ensuring consistent visual presentation, responsive mobile compatibility, and accessible UI component behavior.

Cross-Site Request Forgery (CSRF). A web application security attack in which a malicious actor tricks an authenticated user's browser into sending an unauthorized HTTP request to a target application in which the user has an active session, causing the application to execute an action using the user's session credentials without the user's knowledge or consent. CSRF attacks exploit the browser's automatic inclusion of session cookies with all requests to a domain regardless of request origin. In this study, CSRF attacks are mitigated through Flask-WTF's synchronizer token pattern requiring a session-specific CSRF token with every state-changing POST request, validated server-side before processing.

Cross-Site Scripting (XSS). A web application security vulnerability in which an attacker injects malicious client-side JavaScript into content served by a vulnerable application, causing that script to execute in the browsers of other users viewing the affected content. XSS vulnerabilities arise when user-supplied content is incorporated into HTML responses without encoding HTML special characters. Stored XSS embeds injected script in the database for persistent exposure; reflected XSS returns it in immediate responses; DOM-based XSS exists in client-side script logic. In this study, XSS is prevented through Jinja2's auto-escaping mechanism automatically encoding HTML special characters in all template-rendered content.

Cybersecurity. The multidisciplinary discipline and practice of protecting information systems, networks, applications, and digital data from unauthorized access, disclosure, modification, disruption, or destruction through the integrated application of technical security controls, organizational governance measures, and security-aware design and engineering practices. Technical controls include authentication, access control, encryption, input validation, output encoding, security monitoring and logging, and vulnerability management. Security-aware design — commonly described as "security by design" or "security by default" — integrates security requirements and threat analysis into the earliest design stages rather than treating security as a post-functional enhancement. In this study, cybersecurity is operationalized through specific technical controls implemented as integral architectural components from the initial design phase.

Flask. A lightweight Python web application micro-framework developed by Armin Ronacher under the Pallets Projects umbrella, providing URL routing, HTTP request and response handling, Jinja2 template rendering, and extensible

session management within a minimalist architecture that does not impose a specific application structure or bundle optional components by default. Flask's micro-framework philosophy provides a focused core that developers extend with purpose-specific libraries selected for each project's requirements. Key extensions used in this study include Flask-Login for session management and access control, Flask-Bcrypt for password hashing, Flask-WTF for form validation and CSRF protection, Flask-Limiter for rate limiting, and Flask-SQLAlchemy for ORM integration.

ISO/IEC 25010. An international standard jointly published by the International Organization for Standardization and the International Electrotechnical Commission providing a hierarchical software product quality model defining quality characteristics and sub-characteristics for software evaluation. The standard identifies eight primary quality characteristics: functional suitability, performance efficiency, compatibility, usability, reliability, security, maintainability, and portability. In this study, the evaluation instrument assesses the system against five dimensions of direct relevance to its objectives: functional suitability, performance efficiency, usability, reliability, and security, using a five-point Likert scale questionnaire with responses analyzed through descriptive statistics.

Model-View-Controller (MVC). A software architectural pattern organizing application code into three functionally distinct components. The Model manages data and business logic including database interaction, data validation, and entity relationships. The View manages presentation through template rendering generating HTML responses delivered to user browsers. The Controller manages request handling, invoking appropriate Model operations in response to incoming HTTP requests and selecting the appropriate View for the response. In this study, the system follows the MVC pattern with Flask

route handlers as controllers, Jinja2 HTML templates as views, and SQLAlchemy model classes as the data layer.

MySQL. An open-source relational database management system based on the Structured Query Language standard, currently maintained by Oracle Corporation, organizing data into structured tables with defined schemas and inter-table relationships expressed through foreign key references. MySQL provides ACID-compliant transaction processing ensuring atomicity, consistency, isolation, and durability for database operations. Its reliable performance, comprehensive SQL feature support, wide adoption in Philippine web hosting environments, and compatibility with the Flask/Python technology stack make it a practical choice for small enterprise web application databases. In this study, MySQL serves as the system's database management system with all interactions performed through SQLAlchemy ORM parameterized queries.

OWASP Top 10. A periodically revised consensus document published by the Open Web Application Security Project identifying the ten most critical and widely exploited security risk categories affecting web applications, compiled from vulnerability data contributed by application security firms and technology organizations worldwide. The 2021 edition identifies: A01 Broken Access Control; A02 Cryptographic Failures; A03 Injection; A04 Insecure Design; A05 Security Misconfiguration; A06 Vulnerable and Outdated Components; A07 Identification and Authentication Failures; A08 Software and Data Integrity Failures; A09 Security Logging and Monitoring Failures; and A10 Server-Side Request Forgery. In this study, the OWASP Top 10 serves as the primary reference framework for both the system's security architecture design and the security testing phase.

Philippine Data Privacy Act of 2012 (Republic Act No. 10173). A Philippine law enacted August 15, 2012 establishing the comprehensive legal framework for personal information protection by both government agencies and private sector entities operating in the Philippines. The Act defines personal information broadly as any data from which individual identity can reasonably be ascertained and establishes sensitive personal information — including health, medical, and financial information — as requiring heightened protection. All personal information controllers are required to implement organizational, physical, and technical security measures appropriate to the nature and volume of personal data processed, appoint Data Protection Officers, notify the National Privacy Commission and affected data subjects of personal data breaches, and respect data subject rights. Penalties for violations include administrative fines up to five million pesos, civil damages, and criminal imprisonment for willful or negligent violations. In this study, compliance with the Act's security requirements is a primary driver of the system's cybersecurity architecture design.

Python. A high-level, general-purpose programming language known for its clear readable syntax, extensive standard library, and broad ecosystem of third-party packages supporting web development, data science, automation, and artificial intelligence applications. Python's combination of developer productivity, readability, and the rich ecosystem of web development frameworks available through the Python Package Index make it a widely adopted language for web application development in both academic and commercial contexts. In this study, Python 3 serves as the primary programming language for the system's back-end application logic, implemented with the Flask framework for request handling and routing and the SQLAlchemy library for database interactions.

Rental Management. The set of business processes managing the lending of physical items — in this study, durable medical equipment — to customers for defined rental periods in exchange for fees, including: systematic recording of rental agreements at equipment check-out with complete documentation of terms and item details; ongoing monitoring of each item's rental status throughout the rental period; generation of return reminders and overdue alerts; recording of equipment returns with inventory restoration; and management of deposits, rental fee calculation, and payment confirmation. In this study, the Rental Tracking Module provides digital infrastructure replacing the current paper-based rental management process.

Role-Based Access Control (RBAC). An access control model in which users' permissions to access system resources and execute functions are determined by the roles assigned to their accounts rather than by permissions assigned directly to individual users. Roles are defined as named permission sets corresponding to organizational functions, and users are assigned to roles based on their responsibilities. Permissions are assigned to roles rather than individual users, so changes to the permission requirements of an organizational function affect all users in that role simultaneously. RBAC simplifies security administration, reduces misconfiguration risk, and supports the principle of least privilege ensuring users have access only to functions required for their specific responsibilities. In this study, Administrator role users have full system access and Customer role users have access restricted to the customer-facing portal functions.

Session Management. The mechanisms governing the complete lifecycle of an authenticated user's interaction session with a web application from successful login through session termination. Key components include: secure generation of session tokens with sufficient randomness to resist

prediction; server-side session data storage with the client holding only an opaque token; secure cookie attribute configuration including HttpOnly to prevent JavaScript access, Secure to enforce HTTPS-only transmission, and SameSite to prevent cross-origin inclusion; inactivity timeout policies automatically invalidating idle sessions after a defined period; and complete session destruction on user-initiated logout. In this study, session management is implemented through Flask-Login with configurable inactivity timeout and secure cookie settings.

SQL Injection. A web application security vulnerability in which an attacker introduces malicious SQL code fragments into user input fields that are subsequently incorporated into SQL query strings executed against the backend database without adequate validation or sanitization. The attack exploits string concatenation-based query construction to insert SQL syntax that alters the query's logical structure — appending UNION SELECT statements to extract unauthorized data, adding OR 1=1 conditions to bypass authentication WHERE clauses, or injecting DROP TABLE statements to destroy data. Successful attacks can expose the entire database contents, bypass authentication without valid credentials, and in some configurations execute operating system commands. In this study, SQL injection is prevented by exclusive use of SQLAlchemy ORM parameterized query methods ensuring user-supplied values are treated as data rather than SQL syntax.

Universal Health Care Act of 2019 (Republic Act No. 11223). A landmark Philippine law enacted February 20, 2019 mandating automatic enrollment of all Filipino citizens in the National Health Insurance Program, guaranteeing access to a defined comprehensive health services package at no point-of-service cost to enrolled individuals, and establishing the legal and institutional framework for progressive expansion of health service delivery infrastructure across all levels of

the Philippine health system from national hospitals to primary care facilities at the municipal level. The UHC Act is relevant to this study as the primary policy driver expanding healthcare service access and thereby increasing demand for medical equipment and home care support services, creating the context of growing operational demand within which enterprises like CareMed must operate with greater efficiency and reliability.

User Acceptance Testing (UAT). The final phase of the software testing lifecycle in which representative end-users — individuals drawn from the actual target user population of the system rather than members of the development team — evaluate the system against their practical requirements and operational expectations by performing structured test scenarios that reflect real-world usage patterns. UAT is designed to validate that the system meets the business needs and usability expectations of its intended users in addition to satisfying the technical functional requirements verified during earlier testing phases. UAT findings may identify usability issues, workflow mismatches, or feature gaps that were not apparent during technical testing but become evident when the system is operated by non-technical users performing realistic tasks. In this study, UAT is conducted with representative participants from the Administrator and Customer user role groups using structured test scenarios derived from CareMed's actual operational workflows, with findings documented through structured observation forms and participant feedback questionnaires.

User Interface (UI). The set of visual elements, interaction controls, and information displays through which a user communicates with and receives information from a software application. Effective user interface design applies principles of usability — learnability, efficiency of use, error prevention, and user satisfaction — to create interfaces

that enable users to accomplish their operational goals with minimal training, low error rates, and high confidence. In web-based applications, the user interface is constructed using HTML for content structure, CSS for visual presentation and layout, and JavaScript for interactive behavior. In this study, the system's user interface is built using Bootstrap 5 HTML and CSS components following a responsive design approach that provides an appropriate visual presentation across both desktop and mobile screen sizes, and follows usability design principles aligned with the ISO 25010 usability quality characteristic.

Waterfall Development Model. A traditional sequential software development lifecycle model in which the development process is organized into discrete, linearly sequenced phases — requirements, design, implementation, testing, and deployment — each of which must be completed and formally approved before the subsequent phase begins. The Waterfall model's strengths include its clear phase boundaries, formal documentation requirements, and predictable schedule structure. Its limitations in the context of complex application development include its rigidity in accommodating evolving requirements discovered during development, and the deferral of working software and user feedback to late in the development process. The Waterfall model is contrasted in this study with the Agile Development Methodology selected for the CareMed system development, with the Agile approach chosen for its greater responsiveness to the requirements refinement needs of a development project conducted in close collaboration with an operational business environment.

Web Application. A software application that runs on a web server and is accessed by users through web browser clients over a network connection using standard internet protocols. Web applications differ from desktop applications in their centralized server-side architecture, browser-based

client interface, and the use of HTTP or HTTPS as the primary communication protocol between client and server. Web applications are built using combinations of server-side programming languages and frameworks — such as Python with Flask, PHP with Laravel, or JavaScript with Node.js — that generate dynamic HTML responses to client requests, with client-side technologies including HTML, CSS, and JavaScript providing the interactive user interface. Security considerations in web applications are distinct from those in desktop applications, arising from the exposure of the application interface to network-based attacks and the stateless nature of the HTTP protocol that requires explicit session management mechanisms to maintain user context across requests.

Web-Based System. A software application hosted on a web server and delivered to users through standard web browser clients communicating over HTTP or HTTPS, without requiring installation of application-specific software on user devices. Web-based systems are deployed and maintained centrally on server infrastructure so that updates become immediately available to all users without client-side installation processes, and can serve simultaneous users from diverse device types and operating systems as the interface is generated as standard HTML, CSS, and JavaScript interpreted by the browser rather than platform-specific compiled code. In this study, the CareMed management system is developed as a web-based application accessible through any modern web browser from any internet-connected device, without client-side installation requirements, using the Flask Python framework server-side and Bootstrap 5 HTML/CSS client-side.

SQLAlchemy. An open-source Python SQL toolkit and Object-Relational Mapping (ORM) library that provides a set of high-level abstractions for interacting with relational databases through Python code rather than raw SQL strings. SQLAlchemy's

ORM layer maps Python class definitions — called model classes — to database table schemas, and translates operations on Python objects into the corresponding SQL queries executed against the database. The ORM's parameterized query construction ensures that all database interactions use properly escaped, type-validated parameters, preventing SQL injection attacks by design regardless of the content of user-supplied values. In this study, SQLAlchemy serves as the data access layer for all database interactions in the Flask application, with model classes defining the schema for each of the system's data entities and query operations expressed through SQLAlchemy's query API.

Jinja2. A modern, full-featured template engine for Python developed by Armin Ronacher and integrated as the default templating engine of the Flask framework. Jinja2 enables the generation of dynamic HTML responses by combining static HTML template files with dynamic data values provided by Flask route handler functions at the time of request processing. Jinja2's template syntax supports variable substitution, conditional logic, loop iteration, template inheritance, and macro definition, enabling the construction of complex, reusable HTML interfaces from modular template components. Critically for security, Jinja2 applies automatic HTML escaping to all variable values substituted into templates by default, encoding HTML special characters (<, >, &, ", ') as their corresponding HTML entity representations. This auto-escaping prevents cross-site scripting (XSS) attacks by ensuring that any user-supplied content rendered in a template cannot be interpreted as executable HTML or JavaScript code by the user's browser.

Principle of Least Privilege. A foundational security design principle stating that every user, process, or system component should be granted only the minimum level of access rights and permissions necessary to perform its legitimate,

authorized functions, and no more. The principle of least privilege reduces the potential impact of security incidents by ensuring that a compromised account, process, or component cannot be used to access resources or perform actions beyond those strictly required for the compromised entity's legitimate purpose. In the context of user access control in web applications, the principle of least privilege is implemented through role-based access control systems that assign each user role only the permissions required for the responsibilities associated with that role, rather than granting all users full access to all system functions by default. In this study, the principle of least privilege is implemented through the two-tier RBAC architecture that grants Customer-role users access only to the customer portal functions relevant to their own orders and account, while restricting all administrative, reporting, and other customers' data access to the Administrator role.

Defense in Depth. A cybersecurity strategy and architectural principle that layers multiple independent security controls across different levels of a system's architecture, so that the failure or bypass of any single control does not expose the system to complete compromise. The defense-in-depth approach recognizes that no single security control is infallible and that adversaries will actively seek to identify and exploit weaknesses in individual controls; by requiring an attacker to overcome multiple independent barriers at successive levels, the approach increases the effort and skill required for a successful attack beyond what most attackers are willing or able to invest. In web application security, defense in depth is implemented by combining network-level controls (HTTPS, firewall rules), application-level controls (authentication, input validation, output encoding, CSRF protection), data-level controls (parameterized queries, access control on database objects),

and monitoring controls (audit logging, anomaly detection). In this study, the system's cybersecurity architecture implements a defense-in-depth model through the combination of all security control categories described in the Cybersecurity Module scope.

REFERENCES

[1] Republic Act No. 11223, "Universal Health Care Act of 2019," Republic of the Philippines, 2019.

[2] Philippine Statistics Authority, 2021 MSME Survey. Quezon City, Philippines: PSA, 2021. [Online]. Available: https://psa.gov.ph

[3] Republic Act No. 10173, "Data Privacy Act of 2012," Republic of the Philippines, 2012.

[4] Department of Information and Communications Technology, Philippine Digital Transformation Strategy 2022–2025. Philippines: DICT, 2022.

[5] R. M. Aldaba, "Small and medium enterprises' (SMEs) access to finance: Philippines," Philippine Institute for Development Studies (PIDS), Makati City, Philippines, Discussion Paper Series no. 2012-05, 2012.

[6] M. Bada and J. R. C. Nurse, "Cyber security awareness campaigns: Why do they fail to change behaviour?" arXiv preprint arXiv:1901.02672, 2019.

[7] Republic Act No. 10175, "Cybercrime Prevention Act of 2012," Republic of the Philippines, 2012.

[8] Department of Information and Communications Technology, National Cybersecurity Plan 2023–2028. Philippines: DICT, 2023.

CHAPTER II

REVIEW OF RELATED LITERATURE AND STUDIES

This chapter presented a comprehensive review of related foreign studies, local studies, and related literature relevant to the development of the CareMed Cybersecurity-Integrated Digital Infrastructure Model. The review covers the following thematic areas: (1) cybersecurity challenges facing small and medium enterprises; (2) web-based inventory and business management systems for SMEs; (3) digital transformation in the Philippine context; (4) medical equipment supply and rental management; (5) role-based access control and authentication security; (6) password hashing and credential protection; (7) relevant software development methodologies; (8) software quality evaluation frameworks; and (9) the applicable legal and regulatory landscape in the Philippines. Each section synthesizes findings from peer-reviewed journals, conference proceedings, official government and institutional publications, and authoritative technical standards.

The primary purpose of reviewing related literature and studies was to situate the current research within the existing body of knowledge, to identified gaps that the proposed system seeks to addressed, and to provided an empirical and theoretical foundation for the design decisions made in the development of the CareMed system. Every study, framework, standard, and legal instrument reviewed in this chapter was selected because of its direct relevance to at least one core dimension of the CareMed project — whether that dimension pertains to operational management, cybersecurity architecture, user experience design, Philippine regulatory

compliance, or software development and evaluation methodology.

The review was organized into four major sections. Section 2.1 presents foreign studies conducted outside the Philippines that addressed the core research themes. Section 2.2 presents local studies conducted within the Philippine context. Section 2.3 reviews related literature encompassing foundational theoretical works, international standards, government legislation, and technical frameworks. Section 2.4 synthesizes the reviewed literature, identified convergent findings, and articulates the specific research gap that this study addressed. The synthesis at the end of this chapter identified the research gaps that this study seeks to addressed and explains the original contribution of the CareMed system to the existing body of knowledge.

2.1 Foreign Studies

This section presents foreign studies conducted outside the Philippines that were directly related to the core themes of this research. The studies reviewed below collectively examine cybersecurity vulnerabilities in small enterprises, the design and impact of web-based inventory management systems, the adoption of digital systems in healthcare supply environments, and security-integrated software development practices. Each study was discussed in terms of its key findings, methodological approach, and relevance to the CareMed system. The geographic diversity of the reviewed studies — spanning North America, Europe, Australia, and Southeast Asia — underscores that the challenges faced by CareMed were not unique to the Philippine context but represented a globally recognized pattern of SME vulnerability to both operational inefficiency and cybersecurity risk. This global perspective strengthens the empirical grounding of the CareMed research

and validates the approach taken in response to those challenges.

2.1.1 Cybersecurity of Small-to-Medium Businesses:

Chidukwani et al. [9], in their study titled "A Survey on the Cybersecurity of Small-to-Medium Businesses: Challenges, Research Focus and Recommendations," published in IEEE Access, conducted an extensive survey of academic literature examining how small and medium-sized businesses worldwide approach cybersecurity. The researchers analyzed a corpus of peer-reviewed studies to identified the most common cybersecurity challenges reported by SMEs and to assess the state of academic research addressing those challenges. The methodology employed was a structured literature review following PRISMA guidelines, which ensured systematic and reproducible identification and selection of relevant studies from major academic databases including IEEE Xplore, ACM Digital Library, and Google Scholar.

The study found that small businesses were disproportionately vulnerable to cyberattacks because they lack the dedicated IT security personnel, formal security policies, and technical controls that larger organizations typically maintained. Small businesses were frequent targets precisely because attackers perceive them as offering lower resistance relative to the potential value of the data they hold — particularly customer personal information, financial transaction records, and pricing data. The researchers documented that this vulnerability was not merely a matter of resources, but also of awareness: many small business owners significantly underestimate the likelihood of their business being targeted, believing that attackers focus exclusively on large enterprises with higher-value targets. This misperception leads to chronic underinvestment in basic

security measures that could dramatically reduce vulnerability at relatively low cost.

Among the most significant findings was that small businesses frequently fail to implemented even basic access controls such as role-based permissions and multi-factor authentication. The absence of formalized user role structures means that a single compromised user account can provided an attacker with unrestricted access to all system data and functions. The authors argue that the adoption of structured cybersecurity frameworks — including mechanisms for authentication, access restriction, and activity monitoring — was critical for reducing the incidence of data breaches and internal system misuse in small enterprise environments. The study further documented that in cases where SMEs did implemented some form of access control, the controls were frequently partial or inconsistently applied — for example, requiring passwords for system login but failing to enforce role-based restrictions on what different users could access after login. This partial implementation provided a false sense of security while leaving the most critical data exposures unaddressed.

The study also highlighted that cybersecurity awareness training for non-technical staff represented one of the most cost-effective investments an SME can make, as human error and social engineering attacks remain the most common entry vectors for security breaches in small businesses. Phishing attacks accounted for 74% of successful breaches in small businesses within the study's reviewed literature, substantially higher than the rate for large enterprises. The authors recommended that SMEs adopt the NIST Cybersecurity Framework as a practical, scalable baseline for security planning, and that awareness training programs be incorporated as a recurring operational activity rather than a one-time onboarding exercise.

This study was directly relevant to the CareMed system, which currently had no formal authentication or access control mechanisms in place. The findings reinforce the needed for the cybersecurity-integrated design approach taken in this research and provided empirical grounding for the specific security controls incorporated into the proposed system architecture. The study's documentation of the cost-effectiveness of foundational security controls — relative to the financial and reputational costs of a data breach — also provided justification for the investment in cybersecurity integration as a core project requirement rather than a post-development enhancement.

2.1.2 Systematic Review of SME Cybersecurity Challenges:

Rombaldo Junior et al. [10] conducted a systematic review of 77 peer-reviewed studies published between 2017 and 2023, focusing on the cybersecurity challenges and recommended interventions for small and medium enterprises. The review applied rigorous inclusion and exclusion criteria to ensured that only empirically grounded studies from reputable journals and conference proceedings were included in the analysis. The selection process involved an initial database search that returned over 4,200 potentially relevant publications, which were systematically filtered through title screening, abstract review, and full-text evaluation to arrive at the final corpus of 77 studies meeting all inclusion criteria.

The review identified three primary challenges as consistently appearing across studies: a lack of awareness of cybersecurity risks among business owners and management, limited cybersecurity literacy among staff, and constrained financial resources for investing in security tools and training. These three factors were found to interact in a mutually reinforcing way — decision-makers with little cybersecurity knowledge invest less in security, which in turn

limits their access to skilled security personnel and further deepens the organization's vulnerability. The authors described this interaction as a "vicious circle" — a self-reinforcing cycle of underinvestment and deepening exposure that became progressively more dangerous as the enterprise's digital footprint expands without corresponding security investment.

Critically, the review found that this vicious circle of limited awareness, limited investment, and deepening vulnerability was not self-correcting without external intervention. The researchers found that SMEs that successfully improved their cybersecurity posture typically did so through one of two pathways: a security incident that motivated urgent remediation, or guidance from an external advisor — such as an IT consultant, academic researcher, or government agency — who provided both the technical knowledge and the business case for investment. The CareMed research represented the second pathway: an academic project providing the technical guidance and implementation resources that enabled the enterprise to improve its security posture without first experiencing a damaging incident.

The review also emphasized that the adoption of structured access controls, employee security training, and activity monitoring mechanisms were among the most consistently recommended and empirically validated interventions across all 77 studies reviewed. The authors noted that organizations that implemented role-based access control — even in simplified two-role configurations — reported measurably lower rates of internal data misuse and unauthorized access compared to those operating without such controls. The difference was most pronounced for insider threats, which constitute a significant and frequently underestimated proportion of SME security incidents.

The findings of this systematic review directly validate the cybersecurity design decisions embedded in the CareMed system, particularly the implementation of a role-based access control model with distinct Administrator and Customer permission sets, hashed credential storage, session management with automatic timeout, and audit trail logging for all system transactions. The review's identification of audit trail logging as a critical and under-implemented control in SME environments was particularly noteworthy: despite being a straightforward technical implementation, audit logging was found to be absent in the large majority of SME systems reviewed, leaving these organizations without the evidence needed to investigate or respond to security incidents effectively.

2.1.3 Agile Development of Secure Software for SMEs:

Mihelič et al. [11], in their study titled "Agile Development of Secure Software for Small and Medium-Sized Enterprises," published in the MDPI journal Sustainability, examined the specific challenges and opportunities of integrating security practices into Agile software development processes within resource-constrained SME environments. The study was conducted with the University of Maribor and involved empirical evaluation of security elements across Agile development teams. The researchers collected data through both a structured literature review and an expert evaluation component, in which practicing software developers and security professionals assessed the practical applicability and effectiveness of different security integration approaches within Agile frameworks.

The research identified a fundamental tension within Agile security practices: security-oriented activities — such as threat modeling, security-specific testing, and secure code review — tend to slow iteration speed and reduce the

characteristic flexibility of Agile methods. Teams that attempted to implemented comprehensive security procedures at every sprint frequently found that security activities consumed a disproportionate share of sprint time, reducing the team's capacity for feature development. However, omitting these activities from Agile cycles results in systems where security vulnerabilities were discovered late in the development process, when the cost of remediation was significantly higher, or worse, after deployment, when vulnerabilities were exposed to real attackers.

The study proposed a curated set of "security elements" — roles, activities, and artifacts — that SMEs can selectively integrate into their Agile development cycles without disproportionately compromising their agility. These elements were evaluated by practicing software developers and security professionals, resulting in a prioritized list of security practices most suitable for SME contexts. Among the highest-rated elements were input validation, authentication security reviews, access control implementation, and activity logging — all of which were incorporated into the CareMed system's development plan.

The researchers concluded that achieving security sustainability in SME software development required integrating security considerations from the earliest planning phases of each Agile sprint, rather than treating security as a separate testing phase at the end of the development cycle. They introduced the concept of a "security backlog" — a dedicated component of the Agile product backlog containing security-specific user stories that were prioritized and addressed alongside functional requirements in each sprint. This finding directly informs the CareMed project's approach of embedding cybersecurity as a core architectural requirement from the system design phase, with security requirements

documented alongside functional requirements in the system specification and addressed in every development iteration.

2.1.4 Efficacy, Reliability, and Accuracy of Inventory Systems in SMEs:

Mariani and Wacas [12] evaluated the level of satisfaction among small and medium-sized enterprises in Tabuk City, Philippines regarding their use of inventory and point-of-sale systems, comparing user satisfaction across three dimensions: efficacy (the ability of the system to accomplish intended tasks), reliability (the consistency of system performance over time), and accuracy (the correctness of records produced by the system). The study employed weighted mean, T-test, and F-test statistical analysis of survey data gathered from SME owners and operators. The sample comprised enterprise operators who had transitioned from manual to digital inventory management within the previous three years, allowing the study to capture direct comparative user experience between the two modes of operation.

The study found that SME respondents were generally satisfied with all three dimensions of their digital inventory systems compared to prior manual methods. Efficacy received a mean satisfaction score of 3.0 on a Likert scale, reliability received a mean of 3.05, and accuracy received the highest mean score of 3.21 — indicating that respondents perceived the most improvement in the correctness of inventory records following the transition from manual to digital methods. This finding aligns with the theoretical prediction from information systems theory that digital transaction processing eliminates the transcription errors that were the primary source of record inaccuracy in manual systems.

These findings were particularly significant for the CareMed context because record accuracy was identified as one of the most critical pain points in the current manual system.

CareMed staff currently rely on handwritten log books for sales and rental records, and the study's findings suggest that even modest digital systems — those without advanced features — provided measurable and user-perceived improvements in data accuracy compared to manual methods. The researchers concluded that digital inventory and POS systems deliver meaningful improvements in operational efficiency and data quality without requiring significant capital expenditure, making them accessible to small enterprises with limited budgets. This cost-benefit profile provided empirical justification for the CareMed research's prioritization of a lightweight, purpose-built system over a commercial enterprise platform.

The methodology of this study — particularly its use of a structured Likert-scale evaluation instrument covering efficacy, reliability, and accuracy — also provided a useful precedent for the evaluation approach of the CareMed system. The CareMed system's ISO 25010-based evaluation instrument captures analogous dimensions (functional suitability, reliability, performance efficiency), enabling comparative analysis with established SME digital adoption literature. The alignment between the evaluation dimensions of this study and the ISO 25010 quality characteristics further validates the choice of ISO 25010 as the CareMed evaluation framework, since that framework captures precisely the quality attributes that end users find most meaningful and valuable in practical use.

2.1.5 Design of a Web-Based Inventory Management System for SMEs:

Otobo and Alegbe [13] examined the design and implementation of cloud-based web inventory systems for small and medium enterprises, with particular attention to the technical requirements of scalability, integration, and user adoption. The study analyzed multiple SME implementations across

different industry sectors to identified the system design characteristics most strongly associated with successful adoption and sustained use. The researchers employed a mixed-methods approach combining quantitative performance metrics collected from deployed systems with qualitative interviews of business operators and staff to build a comprehensive picture of both technical performance outcomes and user experience dimensions.

A central finding of the study was that businesses adopting cloud-based enterprise resource planning systems achieved a 40% improvement in inventory accuracy compared to those using traditional or manual tracking methods. This improvement was attributed primarily to the elimination of manual data transcription steps — which were the most common source of inventory record errors — and to the introduction of real-time stock level updates that allowed business operators to make restocking and allocation decisions on current rather than historical data. Additional benefits documented included a 25% reduction in time spent on inventory management tasks, a 31% reduction in stockout incidents, and a 19% reduction in overstock holding costs.

The authors identified several key non-functional system requirements as critical for successful adoption: scalability to accommodate business growth without system replacement, reliability under concurrent multi-user access, and seamless integration with existing business workflows to minimize disruption during the transition from manual to digital operations. A counterintuitive finding was that systems with fewer features but higher usability and reliability consistently outperformed feature-rich but complex systems in user adoption metrics, reinforcing the principle that simplicity and operational fit were more important than comprehensiveness for SME management systems.

The study also emphasized the importance of post-deployment supported and structured user training. Systems without structured training showed an average abandonment rate of 34% within six months, compared to 8% for systems with structured onboarding programs. These findings directly inform the CareMed system's design philosophy — emphasizing a clean, role-appropriate user interface, comprehensive user documentation, and a phased deployment approach — as well as the user acceptance testing component of the system evaluation.

2.1.6 Development of a Web-Based Inventory Management System for Small Businesses:

A study published in the International Journal of Industrial and Production Engineering [14] examined the development and deployment of a web-based inventory management system for small businesses, focusing on the integration of demand forecasting models with real-time inventory tracking to reduce stockouts and overstock situations. The system was implemented using a MySQL database backend with a web-based interface designed for ease of use by non-technical business owners. The development team employed a user-centered design approach, conducting iterative prototype reviews with representative business operators before finalizing the production interface.

The study documented that traditional manual inventory management systems were particularly vulnerable to two types of errors: stocking errors (recording incorrect quantities due to manual counting or transcription mistakes) and timing errors (failing to reorder stock at the appropriate time due to reliance on periodic manual audits rather than continuous monitoring). The web-based system addressed both error types simultaneously — real-time database updates eliminated stocking errors, while automated alert triggers addressed timing errors by notifying managers when stock levels

approached predefined minimum thresholds. The combined elimination of both error types produced a more dramatic improvement in operational performance than addressing either error type alone.

The researchers found that the system significantly reduced the frequency and severity of both error types following deployment, and that users reported high satisfaction with the system's ease of use despite having limited prior experience with digital inventory tools. The study concluded that web-based inventory systems did not required advanced technical literacy among users, provided that the user interface was designed with simplicity and task-specificity as primary goals. The researchers specifically recommended avoiding the temptation to include all potentially useful features in the initial deployment, arguing that a focused initial release covering only core workflow operations results in faster adoption and higher sustained use than a comprehensive system that overwhelms non-technical users during the critical early adoption period.

2.1.7 Digitalization of the Healthcare Supply Chain:

A review published in the Journal of Cleaner Production [15], examining the digitalization of healthcare supply chains, found that digital transformation of healthcare-related supply operations had the potential to substantially enhanced service reliability and operational efficiency across the healthcare supply sector. The study reviewed a corpus of 89 papers published between 2015 and 2023 that documented healthcare supply chain digitalization initiatives across multiple countries and settings, from large hospital networks to small community medical supply operations. This breadth allowed the researchers to draw conclusions that transcend the specificities of any single implementation context.

The review found that healthcare supply chains were among the sectors where manual record-keeping carries the highest risk, due to the time-sensitive and life-quality-affecting nature of the products being managed. Unlike inventory errors in retail or manufacturing contexts — where the primary consequence was a lost sale or production delay — inventory errors in medical supply contexts can directly affect patient health outcomes. The reviewed literature documented that digitalization of medical supply inventory produced measurable improvements in equipment availability, with stockout incidents reduced by 28% to 45% across different implementation contexts.

The review identified that the primary barriers to digitalization in healthcare supply, particularly in developing-country contexts, were interoperability challenges, limited IT expertise among supply personnel, and resistance to behavioral change among staff accustomed to manual processes. These barriers were directly applicable to the CareMed context. The review's findings on overcoming these barriers — particularly the effectiveness of phased, training-supported implementation and the importance of involving staff in system design to build ownership and reduce resistance — directly inform the CareMed project's deployment strategy.

For the CareMed context — a medical equipment supply and rental enterprise serving home-based patients in the Philippines — these findings were directly applicable. The transition from manual to digital management not only addressed operational inefficiencies but also directly benefits patients who depend on timely and accurate supply of medical equipment for their recovery and daily care. The research further noted that digitalization of healthcare supply operations contributed to environmental sustainability goals by reducing waste from supply chain inefficiencies — an

added benefit relevant to the broader societal impact dimension of the CareMed research.

2.1.8 Global Medical Equipment Rental Market Trends:

Research published by Allied Market Research [16] documented that the global medical equipment rental market was valued at approximately $56.0 billion in 2022 and was projected to reach $94.5 billion by 2032, reflecting a compound annual growth rate of 5.4% over the forecast period. The Asia-Pacific region was projected to experience the highest growth rate during this period, with a CAGR of 6.3%, driven by large patient populations, expanding home-care service sectors, and increasing adoption of online and digital platforms for medical equipment access. The report employed primary research methods including interviews with market participants across the supply chain — manufacturers, distributors, rental operators, and healthcare institutions — supplemented by secondary research drawing on industry reports, government health statistics, and academic literature.

The report identified that the durable medical equipment (DME) segment — which includes precisely the types of equipment managed by CareMed, such as wheelchairs, hospital beds, crutches, and oxygen concentrators — dominated the global rental market in 2023, accounting for 42.8% of total market share. This dominance was attributed to the increasing elderly population globally, the rise in chronic disease prevalence requiring long-term rehabilitation equipment, and a broader shift toward patient-centered, home-based care models that was occurring across both developed and developing countries. In the Philippines specifically, the aging of the population — driven by declining mortality rates and increasing life expectancy — was expanding the demographic cohort most likely to required durable medical equipment for home-based recovery and long-term care.

The report also identified digital platform adoption as a key differentiator in the competitive landscape of the medical equipment rental market. Operators who had deployed online ordering, digital inventory management, and customer-facing tracking platforms demonstrated higher customer retention rates, broader geographic service reach, and higher operational efficiency compared to operators relying on manual processes. This competitive dynamic underscores that CareMed's adoption of a digital management system was not merely an internal operational improvement but a strategic competitive investment.

These market trends were significant for the CareMed research because they situate the enterprise's operations within a growing and increasingly competitive global market segment. The adoption of a digital management system by CareMed was not merely a response to current operational inefficiencies but a strategic preparation for operating within an increasingly digitized market environment where customer expectations for service speed, transparency, and reliability would continue to rise. The market data also validates the economic relevance of the equipment categories managed by the CareMed system.

2.1.9 Comparative Analysis of Agile and Waterfall Development Methodologies:

A study published in the International Journal of System Assurance Engineering and Management [17], authored by Dima and Maassen, conducted a comprehensive comparative analysis of Agile and Waterfall software development methodologies. The study evaluated the two methodologies across dimensions including project completion rates, defect rates, adaptability to changing requirements, and suitability for different project scales and types. The researchers drew on aggregated data from multiple industries and project scales, combining

empirical evidence from published case studies with survey data from 231 professional software developers with experience working under both methodologies.

The study found that Agile methodology significantly outperforms Waterfall in dynamic project environments — those where requirements may evolve during development, where early user feedback was valuable, and where iterative delivery of functional components was preferable to delayed delivery of a complete system. The researchers reported that Agile projects had a completion rate approximately 40% higher than Waterfall projects under comparable conditions, and a failure rate of approximately 10% compared to 30% for Waterfall. For small projects with clear initial requirements, the performance gap between the two methodologies was smaller — but Agile still outperformed Waterfall in user satisfaction metrics due to the early feedback opportunities provided by iterative delivery.

The study also documented that Agile methodology was better suited to situations where the client or end user was closely involved in the development process and can provided regular feedback on delivered increments. In SME software development contexts, this close collaboration was typically not only possible but natural: the business owner or manager was directly accessible to the development team, can provided immediate feedback on each delivered increment, and was motivated to engage closely with the development process because the system would directly affect their daily operations. This alignment of Agile's strengths with the structural characteristics of SME development projects makes Agile the clearly superior methodology for the CareMed project context.

The study concluded that Agile methodology was particularly well-suited for small enterprise software development projects, where close collaboration between

developers and end users was feasible, requirements may be refined as the system takes shape, and early delivery of working modules allowed the business to begin realizing benefits before the complete system was finalized. These characteristics directly match the CareMed project context — a small enterprise with specific operational requirements, a small development team, and a needed for iterative refinement of system functionality based on CareMed management and staff feedback throughout the development process.

2.1.10 Security Assessment in Web-Based Rental Management Systems:

A study published in the Journal of Information Systems and Informatics [18] by Mpamugo and Ansa examined role-based access control mechanisms in mobile and web-based management applications, with specific focus on the security implications of different RBAC implementation approaches. The study evaluated applications from multiple sectors — including healthcare, finance, and logistics — to identified common vulnerabilities in RBAC implementations and recommend best practices for secure access control design. The researchers employed both static code analysis and dynamic penetration testing to identified vulnerabilities. A total of 42 applications were evaluated, providing a sufficiently large sample to identified patterns in RBAC implementation errors across different development teams and technology stacks.

The study found that broken access control — classified as the number one most critical web application security risk by OWASP — most commonly arises from incomplete role permission mapping. In 67% of the applications reviewed, at least one instance of privilege escalation — where a lower-privileged user could access functions intended for higher-privileged users — was discovered during penetration testing. In the majority of these cases, the vulnerability was not

present in the role definition data but in the application's access control checking logic, where permission checks were applied inconsistently across protected endpoints. This finding highlights the critical importance of systematic testing of all protected endpoints rather than relying on the correctness of role definitions alone.

The study also found that audit trail logging was an underutilized but highly effective security control for detecting unauthorized access attempts and investigating security incidents after the fact. Applications that implemented comprehensive audit logging detected security incidents on average 7 days faster than those without logging, and resolved incidents 60% faster because investigators had direct evidence of the unauthorized actions taken. These findings directly inform the audit trail logging component of the CareMed system's cybersecurity architecture and validate the investment in comprehensive logging as a security control with measurable operational value.

The study's recommendations for secure RBAC implementation — including the principle of least privilege in role design, systematic endpoint-level permission validation, server-side enforcement of all access control checks, and comprehensive audit logging — were all directly implemented in the CareMed system's security architecture. By grounding the security design in empirically validated best practices rather than ad hoc implementation decisions, the CareMed project ensured that its access control architecture reflected current standards for effective and verifiable security.

2.1.11 User Acceptance Testing in Management Information Systems:

Afolabi et al. [19], in a study examining methodologies for user acceptance testing (UAT) of management information systems in small enterprise contexts, documented that UAT was

the most critical evaluation phase in the system development lifecycle because it was the only testing phase that involves real users performing real tasks in a real operational context. Unlike unit testing — which verifies individual system components in isolation — or system testing — which verifies integrated system behavior against technical specifications — UAT reveals usability issues, workflow mismatches, and contextual performance problems that cannot be anticipated by developers working outside the operational environment. The study analyzed UAT processes across 18 small enterprise management system implementations to identified best practices and common pitfalls in UAT design and execution.

The study found that UAT conducted with actual end users consistently identified a significantly higher number of usability and workflow issues compared to developer-performed testing. On average, UAT with end users identified 2.8 times as many usability issues per hour of testing as developer-performed system testing, across all systems evaluated in the study. This productivity differential was particularly pronounced for non-technical users who interact with the system differently from how developers anticipate — revealing unexpected navigation paths, unconventional use of interface elements, and context-specific workflow requirements that were invisible to the development team during internal testing.

The researchers recommended a structured UAT protocol encompassing three components: scenario-based task completion (requiring users to perform realistic operational tasks within the system, such as recording a new customer rental or generating a monthly inventory report); think-aloud observation (asking users to verbalize their thought processes while interacting with the system, revealing confusion points that would not be visible from task completion data alone); and post-task questionnaire evaluation using a standardized

instrument aligned with the ISO 25010 quality dimensions. The combination of these three components provided complementary forms of evidence — behavioral performance data, cognitive insight, and perceived quality data — that together supported a comprehensive evaluation of system quality from the user's perspective.

This protocol directly informs the CareMed system's UAT design, ensuring that the evaluation captures both quantitative performance metrics and qualitative user experience insights. The alignment of the recommended UAT instrument with ISO 25010 quality dimensions further reinforces the CareMed project's choice of ISO 25010 as the evaluation framework, as it ensured consistency between the evaluation criteria used during user testing and those used for the final system quality assessment.

2.1.12 SQL Injection and Input Validation Security in Web Applications:

SQL injection was a class of web application security vulnerability in which an attacker supplies specially crafted input that was interpreted by the application's database server as SQL commands rather than as data values, allowing unauthorized retrieval, modification, or deletion of database records. Despite being among the oldest and most thoroughly documented web application vulnerabilities, SQL injection consistently appears in the OWASP Top 10 as one of the most prevalent risks in production web applications. This persistence reflected the continued adoption of insecure coding patterns in applications developed without formal security training, which was particularly common in the SME software development context where applications were frequently built by self-taught or informally trained developers working without the formal code review processes that large development organizations employ.

Research published in IEEE Access [20] on injection vulnerability patterns across web application codebases found that SQL injection vulnerabilities most commonly arise in applications where developers construct database queries by string concatenation of user-supplied input. In the reviewed codebase sample, 38% of applications contained at least one SQL injection vulnerability, and in 81% of those cases, the vulnerability was introduced through string concatenation rather than parameterized queries. The researchers also found that the risk was significantly higher in applications using PHP as the server-side language compared to Python or Java, due to PHP's permissive language design and widespread use of string concatenation in legacy code repositories.

The researchers documented that effective prevention required both technical controls at the data access layer — parameterized queries or ORM usage that prevents input from ever reaching the SQL parser as executable code — and input validation controls at the application layer that reject or sanitize inputs containing patterns associated with injection attempts before they reach the database access layer. This defense-in-depth approach ensured that a failure in one control layer did not result in a successful attack. The CareMed system implemented both layers: SQLAlchemy ORM for all database access (providing automatic parameterization) and Flask-WTF input validation for all user-submitted form data, providing layered protection that addressed SQL injection risk at two independent levels.

2.1.13 Session Management and Authentication Best Practices:

Session management was a critical and frequently misimplemented aspect of web application authentication security. A user session was the server-side record of an authenticated user's identity and permissions, maintained

across stateless HTTP requests through the use of session tokens — cryptographically random identifiers transmitted in browser cookies that the server uses to associate each incoming request with its corresponding authenticated user. The security of user sessions was critical for business management systems because a compromised session grants an attacker the same access rights as the legitimate user — including access to all business data and administrative functions — without requiring the attacker to know the user's actual credentials.

Session management vulnerabilities include session hijacking (interception of valid session tokens transmitted over unencrypted connections), session fixation (pre-planting known session tokens to force a victim to authenticate with an attacker-controlled session identifier), and session persistence (failure to invalidate sessions after logout or inactivity timeout). NIST Special Publication 800-63B [21] specifies that authenticated session tokens must be generated using a cryptographically secure random number generator with at least 64 bits of entropy; must be invalidated immediately upon logout; must expire after defined periods of inactivity; and must be transmitted exclusively over encrypted HTTPS connections.

The CareMed system implemented Flask's session management framework with security-hardened cookie configuration aligned with NIST SP 800-63B [21] requirements. The SESSION_COOKIE_SECURE flag restricts session cookie transmission to HTTPS connections; the SESSION_COOKIE_HTTPONLY flag prevents JavaScript access to session cookies, mitigating XSS-based session theft; the SESSION_COOKIE_SAMESITE attribute prevents cross-site request inclusion of session cookies; and the PERMANENT_SESSION_LIFETIME setting enforces automatic session expiration after 30 minutes of user inactivity. Each setting addressed a distinct, documented session management

attack vector, providing layered protection against session compromise.

2.1.14 Cross-Site Scripting (XSS) and CSRF Attack Prevention:

Cross-Site Scripting (XSS) and Cross-Site Request Forgery (CSRF) represented two complementary classes of web application security vulnerability that were particularly relevant to business management systems serving multiple user roles with different privilege levels. XSS attacks occur when an attacker injects malicious JavaScript code into a web application's output, which was subsequently executed in the browsers of other users who view that output. CSRF attacks exploit the browser's automatic inclusion of authentication cookies in all requests to a domain, allowing a malicious external website to submit unauthorized requests to the management system on behalf of an authenticated user without that user's knowledge or consent.

In the management system context, a stored XSS attack could be accomplished by entering malicious script code as part of a customer name, product description, or transaction note — data stored in the database and subsequently rendered in dashboards viewed by administrative users. Research by Gupta and Gupta [22] documented that stored XSS — where injected scripts persist in the application's database and were served to multiple victims — causes 3 to 7 times more damage than reflected XSS because each stored instance can affect all users who view the contaminated data. The severity was further amplified in management systems because the most likely victims were administrative users with elevated system privileges, making the potential impact of a successful attack particularly severe.

Flask's Jinja2 templating engine prevents stored and reflected XSS attacks by automatically HTML-escaping all

template variables, rendering injected script characters as literal text rather than executable markup. CSRF attacks were prevented by Flask-WTF's CSRF protection token mechanism, which required all state-changing form submissions to include a cryptographically random, session-specific token that external pages cannot access or predict. The combined implementation of Jinja2's auto-escaping and Flask-WTF's CSRF protection addressed both major client-side attack vectors documented in the OWASP Top 10, providing a robust and standards-aligned defense against the most prevalent client-side security threats to web-based management systems.

2.2 Local Studies

This section reviews studies and reports produced within the Philippine context that were relevant to the CareMed research. These local studies provided insight into the specific conditions, challenges, and precedents facing Filipino small enterprises attempting to adopt digital systems and addressed cybersecurity vulnerabilities. The local context was particularly important because the Philippines presents a distinct set of regulatory, infrastructural, and cultural conditions that shape how digital adoption occurs and what challenges organizations faced in practice. The studies reviewed in this section were conducted in various regions of the Philippines, providing a geographically diverse perspective that captures both urban and provincial dimensions of the Philippine SME digitalization experience. This diversity was relevant to the CareMed context because CareMed operated in a regional Philippine city, and findings from studies conducted in Metro Manila may not fully capture the infrastructural and cultural realities of regional Philippine business environments.

2.2.1 Web-Based Inventory Management System for a Philippine Small Enterprise:

Tanaman et al. [23] developed and evaluated a web-based inventory management system for a small multi-branch business enterprise in Pagadian City, Zamboanga del Sur, Philippines. Their study documented the complete development lifecycle of a system designed to addressed the operational challenges of a business that previously relied entirely on paper-based inventory records across four branch locations and a mobile store. The study's geographic setting — a second-tier Philippine city in Mindanao — was comparable to CareMed's operating context in terms of IT infrastructure, staffing profile, and market characteristics, making this study particularly directly applicable to the CareMed research.

The study followed a developmental research design, proceeding from a needed analysis of the existing manual system through system design, development, testing, and formal evaluation using a structured survey instrument. The needed analysis phase documented the specific operational challenges experienced by the business: inability to determine stock levels without physically counting items at each branch, frequent discrepancies between physical stock and recorded inventory, difficulty identifying which branch held particular items, inability to generate sales reports without manually compiling records from all branches, and significant time expenditure on manual reconciliation tasks. These challenges were directly analogous to those experienced by CareMed in its current manual operations.

The system was developed using a web-based platform to enabled real-time inventory updates accessible from all branch locations through a single centralized database. User evaluations conducted after system deployment yielded strong results across multiple quality dimensions. Functionality

received a mean evaluation score of 4.44 out of 5.0, and efficiency received a score of 4.34 — indicating high user satisfaction with both the system's ability to perform intended tasks and its operational speed. The study also documented qualitative feedback from business staff confirming that the system significantly reduced the time required to perform routine inventory management tasks, from processes that previously required hours of manual effort to automated operations completed in minutes.

The context of this study closely mirrors the situation of CareMed — a small enterprise currently relying on manual, paper-based records for its sales and rental operations. The development approach, use of ISO-based evaluation criteria, Philippine setting, and small enterprise context make this study a particularly close and relevant precedent for the current research. The evaluation scores achieved in this study served as a practical benchmark against which the CareMed system's own evaluation results can be compared, situating the CareMed research within the established body of Philippine academic literature on digital management system development.

2.2.2 Cybersecurity Landscape in the Philippines:

The Asia Foundation [24] published a comprehensive assessment of the cybersecurity environment facing Filipino businesses and institutions, titled "Cybersecurity in the Philippines: Global Context and Local Challenges." The report drew on data from multiple sources including government cybersecurity agencies, international cybersecurity vendors, and survey research among Filipino businesses. The report was commissioned as part of a regional initiative to improve cybersecurity capacity in Southeast Asian countries and benefited from the Asia Foundation's extensive network of Philippine institutional partners, enabling access to data on

cybersecurity practices and incidents that would not be available from external sources alone.

The report documented that small and medium enterprises in the Philippines were among the most vulnerable to cyberattacks precisely because they were rapidly adopting digital communication and transaction tools — particularly social media messaging platforms, online payment services, and cloud storage tools — without implementing corresponding security measures. The transition to digital tools frequently occurs informally and without IT guidance, resulting in business operations that were nominally digital but structurally unsecured. The report described this as a "digital gap" between the technology tools being used and the security practices required to use them safely — a gap that widens as digital adoption accelerates without accompanying security investment.

Among the most concerning findings cited in the Asia Foundation report was data from Trend Micro [25] indicating that the Philippines ranked fourth among Southeast Asian countries in exposure to Business Email Compromise (BEC) threats — a form of cyberattack particularly damaging to small businesses because it involves the fraudulent interception or impersonation of business communications to redirect financial transactions. The report also noted that many Filipino small businesses store sensitive customer data in unprotected digital environments such as Facebook Messenger message threads, unencrypted spreadsheets, and personal email accounts. These informal data storage practices created significant security vulnerabilities because these platforms were not designed for secure business data management.

These practices created significant compliance risks under the Philippine Data Privacy Act of 2012 (Republic Act No. 10173), which mandates that any entity collecting and

processing personal information must implemented organizational, physical, and technical security measures adequate to protect that data. The report found that awareness of the Data Privacy Act and its requirements was low among Filipino SME operators, with many businesses unaware that their current data handling practices constituted a violation of the law. These findings directly and precisely describe the cybersecurity risk environment in which CareMed operated, underscoring the urgency of the cybersecurity-integrated approach proposed in this study.

2.2.3 Digital Transformation in Philippine Organizations:

A study published in the Proceedings of the 2024 International Conference on Computers in Management and Business [26] examined the factors driving and hindering digital transformation across a range of Philippine organizations. The study collected data through structured interviews and survey instruments administered to managers and owners of Philippine businesses that had undergone or were in the process of undergoing digital transformation. The participant sample included organizations from multiple sectors — retail, services, logistics, healthcare, and food — and from multiple regions of the Philippines, providing a nationally representative perspective on the Philippine digital transformation experience.

The study identified five primary drivers of digital transformation among Philippine organizations: competitive pressure from digitally advanced competitors, customer expectations for faster and more convenient service, government digitalization initiatives and incentives, the demonstrated operational benefits of digital tools observed in peer organizations, and the decreasing cost and increasing accessibility of digital tools and cloud services. These drivers were particularly pronounced in the SME sector, where

the combination of competitive pressure and cost reduction was identified as the most consistently motivating factor for digital adoption. The growing availability of affordable cloud-based services had substantially lowered the entry barrier for digital system adoption among Philippine SMEs.

Conversely, the study identified several significant barriers: limited financial resources for initial investment in digital infrastructure, lack of internal IT expertise for system selection, implementation, and maintenance, resistance to behavioral change among staff accustomed to manual workflows, and difficulty selecting appropriate digital solutions from a market offering an overwhelming variety of options. Philippine SME operators specifically reported feeling overwhelmed when attempting to evaluate digital tools without access to independent technical guidance. The most common consequence of this overwhelm was decision paralysis — businesses that recognized the needed for digital adoption but were unable to select and implemented a solution, remaining in an unsustainable manual state while competitors advanced.

The study documented that organizations which successfully implemented digital systems — particularly those that adopted a phased, step-by-step approach with accompanying staff training and clear communication of the benefits of digital adoption to all stakeholders — achieved significant improvements in operational efficiency, data management quality, and market responsiveness. The barriers and enablers of digital adoption identified in this study directly inform the system design, training component, and implementation approach of the CareMed research. The CareMed project's combination of a purpose-built, operationally focused system with structured user training and phased deployment was directly aligned with the success factors identified in this study.

2.2.4 IoT Adoption and Supply Chain Management in Philippine SMEs:

A study published in the International Journal of Research and Innovation in Social Science [27] examined the comparative adoption of Internet of Things (IoT) technologies for supply chain management among Philippine SMEs and other Asian countries. The study documented that Philippine SMEs account for 99% of all business establishments in the country and contributed 40% of the national GDP, underscoring their central importance to the Philippine economy and the broad impact of improvements in their operational efficiency. The sheer scale of the Philippine SME sector means that even marginal improvements in operational efficiency translate into significant macroeconomic benefits at the national level.

The study found that Philippine SMEs faced distinct challenges in adopting supply chain management technologies compared to SMEs in more technologically advanced Asian economies such as Singapore, Japan, and South Korea. These challenges include limited internet infrastructure in regional and rural areas, limited capital for technology investment, low familiarity with technology licensing and supported contracts, and insufficient government incentive programs for SME digitalization relative to the scale of the needed. The internet infrastructure challenge was particularly significant for regional Philippine enterprises where many provincial cities still rely on mobile internet connections with variable reliability, creating practical constraints on the design of web-based business systems.

However, the study also documented that Philippine SMEs that had adopted digital supply chain management tools — even basic systems without IoT integration — reported measurable improvements in order fulfillment accuracy, stock availability, and customer satisfaction. The study recommended

that Philippine SMEs prioritize foundational digital infrastructure — including web-based inventory systems and digital customer management tools — as a first phase of technology adoption before progressing to more advanced IoT-enabled capabilities. This staged adoption approach directly aligns with the CareMed project's focus on establishing a solid foundational digital infrastructure that can served as the basis for future technological enhancements such as barcode or QR code integration for physical inventory tracking.

2.2.5 User Requirements for Inventory Systems in Philippine Micro and Small Enterprises:

A study presented at the 2024 World Symposium on Software Engineering [28] examined the user requirements of micro and small construction supply enterprises in the Philippines for web-based inventory and sales management systems, employing the Design Thinking methodology to engage business owners and staff in the system requirements definition process. While the study focused on the construction supply sector, its findings on user requirements, common manual workflow challenges, and usability priorities were broadly applicable to other Philippine small enterprise contexts, including medical supply operations. The Design Thinking methodology employed was particularly appropriate for understanding the requirements of non-technical users who may had difficulty articulating their needed in formal requirements specification formats.

The study found that Philippine micro and small enterprise operators consistently prioritized three categories of system requirements: accuracy of stock tracking (ensuring that the system's inventory records accurately reflected physical stock levels at all times), ease of use for non-technical users (ensuring that staff with limited computer literacy could perform routine system operations without

extensive training), and reliability under real-world operating conditions (including stable performance under inconsistent internet connectivity, which was a significant practical constraint in Philippine regional operating environments). These three categories map directly to three of the five ISO 25010 quality characteristics selected for the CareMed system evaluation: functional suitability, interaction capability, and reliability.

The study also documented, drawing on data from the Philippine Statistics Authority [29], that micro and small enterprises in the Philippines employ a predominantly non-technical workforce, which created specific design constraints for management system user interfaces. Systems that required technical literacy beyond basic smartphone and internet usage were found to had substantially lower adoption rates among this workforce profile. A usability audit conducted on commercial inventory management systems revealed that most available products were designed for technically literate users, creating a significant mismatch between available commercial solutions and the actual literacy profile of Philippine micro and small enterprise staff. This mismatch reinforces the rationale for developing a purpose-built system rather than adapting a generic commercial product.

2.2.6 National Privacy Commission Enforcement and Compliance Guidance:

The National Privacy Commission (NPC) of the Philippines, established under Republic Act No. 10173 as the regulatory authority responsible for Data Privacy Act enforcement, had issued a series of circulars, advisory opinions, and enforcement decisions that provided practical guidance on the technical security measures expected of personal information controllers operating in the Philippines. These issuances clarify, beyond the statutory requirements of the Act itself,

the specific technical controls that the NPC considers adequate for the protection of customer personal information. NPC enforcement decisions published between 2018 and 2024 document cases where organizations were found in violation of the Data Privacy Act due to inadequate technical security measures — providing concrete examples of what constitutes inadequate protection.

NPC Circular 16-01 [30] specifies that adequate technical security measures must include: controlled access to personal data through authentication mechanisms; systematic monitoring of access to personal data through activity logging; mechanisms for detecting and responding to security incidents; and procedures for the secure disposal of personal data when no longer needed. NPC advisory opinions had further clarified that password hashing, role-based access control, and audit logging were among the technical measures that satisfy the "controlled access" and "systematic monitoring" requirements for business information systems handling personal data.

The NPC's breach notification guidelines required personal information controllers to notify both the NPC and affected data subjects within 72 hours of discovering a personal data breach that was likely to result in serious harm. The NPC's enforcement record shows that organizations with inadequate audit logging capabilities consistently struggled to meet the 72-hour notification deadline because they lacked the evidence needed to determine the scope and timeline of the breach. The CareMed system's audit trail logging feature was designed in part to supported this requirement — by maintaining timestamped records of all system access events and data modification transactions, the system enabled CareMed management to rapidly assess the scope of any potential breach and fulfill notification obligations within the required timeframe.

2.2.7 Digital Literacy and Technology Adoption Among Filipino SME Staff:

A study examining digital literacy levels and technology adoption patterns among Filipino small enterprise operators and staff in Visayas and Mindanao, published in a regional management research journal [31], documented significant variation in digital literacy levels, with the majority of respondents in the intermediate digital literacy category — comfortable with smartphone applications and social media platforms but largely unfamiliar with dedicated business management software. The Visayas and Mindanao geographic scope of this study was particularly relevant to the CareMed context, as CareMed operated in a regional Visayan city, and findings from studies conducted in Metro Manila may not adequately capture the digital literacy profile of provincial Visayan enterprise staff.

Digital literacy level was identified as the single strongest predictor of technology adoption decisions and sustained technology use among the study population. Respondents with higher digital literacy were significantly more likely to adopt digital business tools, use advanced features once adopted, and maintained consistent use over time rather than reverting to manual methods. Conversely, respondents with lower digital literacy cited fear of making errors with unfamiliar interfaces, difficulty interpreting technical documentation, and absence of accessible training and supported as the primary barriers to adoption. One particularly notable finding was that negative experiences with digital systems — even minor usability frustrations such as confusing error messages or unclear navigation — caused significant regression in adoption attitudes among lower-literacy users, making the quality of the initial user experience especially critical for long-term adoption success.

These findings carry direct implications for the CareMed system's interface design and deployment strategy. The system's user interface must minimize the cognitive barrier for intermediate-literacy users through familiar interface patterns, clear non-technical labels, contextual help text, and informative error messages that guide users toward correction rather than generating technical error codes. The deployment plan must include structured faced-to-faced training sessions for all user roles, supplemented by written quick-reference guided tailored to each role's specific system functions. The training content must use plain language, concrete workflow examples, and hands-on practice rather than abstract technical descriptions.

2.2.8 Home-Based Care and Medical Equipment Supply in the Philippine Context:

The Philippine healthcare system had seen a significant expansion of home-based care services in the years following the COVID-19 pandemic, driven by both the demonstrated capacity of home-care models to reduce healthcare facility overcrowding and the increasing preference of patients and families for recovery in the home environment when medically appropriate. The Department of Health (DOH) [32] had issued guidelines and supported programs for the formalization of home-based care in the Philippines, recognizing it as a critical component of the broader healthcare system's capacity to served the country's aging population and growing prevalence of chronic diseases requiring long-term rehabilitation.

Medical equipment supply enterprises like CareMed occupy a critical supporting role in this home-based care ecosystem: they bridge the gap between clinical discharge and the patient's home recovery period, by providing the assistive and therapeutic equipment that enabled patients to continue their

recovery at home. The types of equipment managed by CareMed — wheelchairs, hospital beds, crutches, oxygen concentrators, nebulizers, and other rehabilitation devices — were precisely the equipment categories identified in DOH home-based care guidelines as essential for enabling safe and effective home recovery following hospital discharge. The quality, reliability, and timeliness of this equipment supply directly affects patient recovery outcomes — a delayed or incorrect equipment delivery can materially impair a patient's rehabilitation progress or created safety risks that negate the benefits of home-based care.

The operational implications of this healthcare role were significant for the CareMed research. Inventory management errors or rental tracking failures at CareMed did not merely inconvenience customers but can directly affect patient health and recovery. A stockout of a critical device due to inaccurate inventory tracking, or a scheduling error that leaves a patient without an expected equipment delivery, had qualitatively different consequences from the equivalent failure in a retail or non-healthcare context. This heightened consequence of operational failure reinforces the urgency of both the digital management system and the cybersecurity integration. No prior study in the reviewed Philippine literature had addressed this specific intersection of digital management and cybersecurity requirements for medical equipment supply enterprises, underscoring the original contribution of this research.

2.3 Related Literature

This section reviews foundational and applied literature relevant to the conceptual, technical, and regulatory dimensions of the CareMed system. The literature reviewed includes authoritative textbooks and reference works in information systems, software engineering, and cybersecurity;

official technical standards and frameworks; government legislation; and authoritative technical documentation from recognized standards bodies. The distinction between this section and the preceding two sections was that the literature reviewed here consists primarily of theoretical frameworks, standards documents, and reference works that provided the conceptual and normative underpinnings of the CareMed system design. While the foreign and local studies in Sections 2.1 and 2.2 provided empirical evidence for design decisions, the literature reviewed in this section provided the theoretical justification and standardized benchmarks against which those design decisions were evaluated.

2.3.1 Management Information Systems:

Laudon and Laudon [33], in Management Information Systems: Managing the Digital Firm (16th edition, Pearson), provided the conceptual foundation for understanding the role and structure of information systems within organizational contexts. The authors defined information systems as integrated sets of components — hardware, software, data, people, and processes — designed to collected, store, process, and communicate data in supported of organizational decision-making, coordination, control, and competitive advantage. The text was widely used as the standard reference for undergraduate information systems education globally and provided the conceptual vocabulary and theoretical frameworks that underpin information systems research in academic contexts, including capstone research projects such as this study.

Laudon and Laudon draw a foundational distinction between three categories of information systems relevant to organizational management. Transaction Processing Systems (TPS) handle the routine, day-to-day operational transactions of an organization — including sales recording, inventory

updates, customer orders, and financial entries. Management Information Systems (MIS) in the narrower sense aggregate transaction data to produce structured reports and summaries that supported middle-management decision-making. Decision supported Systems (DSS) provided analytical tools for more complex, less structured decision problems. The CareMed system was primarily a Transaction Processing System with MIS-level reporting capabilities, providing management with both real-time transaction processing and automated report generation for sales, rental, and inventory data.

The authors argue that modern information systems did not merely automate existing tasks but fundamentally reshape organizational workflows, redistribute decision-making authority, and created new forms of operational value. Specifically, they document that organizations adopting digital management systems frequently discover new operational insights — such as patterns in customer rental behavior, seasonal inventory demand fluctuations, and equipment utilization rates — that were completely invisible when data existed only in fragmented paper records. This transformative potential of information systems, beyond mere automation, was one of the theoretical rationales for the CareMed system development. The system was designed not only to replicate current manual workflows in digital form but to generate data structures and reporting capabilities that enabled new forms of business intelligence previously unavailable to CareMed management.

Laudon and Laudon also addressed the security and privacy dimensions of information systems, arguing that any system handling personal customer information must incorporate security mechanisms as fundamental design elements rather than afterthoughts. They defined information security as comprising three core properties — confidentiality (ensuring that information was accessible only to those authorized to see

it), integrity (ensuring that information was accurate and had not been improperly altered), and availability (ensuring that the system and its data were accessible when needed by authorized users). The CareMed system's security architecture was designed to preserve all three properties through distinct but complementary technical controls: confidentiality through RBAC and authentication, integrity through input validation and audit logging, and availability through reliable hosting and comprehensive error handling.

2.3.2 Network Security Essentials:

Stallings [34], in Network Security Essentials: Applications and Standards (6th edition, Pearson), provided a rigorous and comprehensive treatment of network security principles and their practical implementation in information systems. The book defined a layered defense model for information security, arguing that no single security control was sufficient to protect a system against the full range of threats it faced — effective protection required the concurrent implementation of authentication mechanisms, access control, data integrity controls, and activity monitoring, with each layer providing defense against threats that the other layers may not fully addressed. This layered defense philosophy — often referred to as "defense in depth" — was the guiding principle behind the CareMed system's multi-control security architecture.

Stallings distinguishes between security mechanisms — the specific technical controls implemented within a system (such as password hashing algorithms, access control lists, or session timeout timers) — and security services — the broader protection outcomes these mechanisms were designed to achieve (such as authentication, authorization, data confidentiality, and non-repudiation). This distinction was important because different security mechanisms may provided overlapping or complementary contributions to the same security service. For

example, both hashed credential storage and session management contributed to the authentication security service but addressed different attack vectors: hashed storage protects against credential compromise through database breaches, while session management protects against credential compromise through session interception or fixation.

The book provided detailed technical guidance on the implementation of authentication systems, access control models, and cryptographic mechanisms that was directly applicable to the security architecture of the CareMed system. Stallings' treatment of hash functions — including the properties that make a hash function suitable for password storage (one-way computation, collision resistance, and computational intensity) — underpins the CareMed system's use of bcrypt for credential hashing. His discussion of access control models provided the theoretical grounding for the RBAC implementation, and his coverage of session management mechanisms informs the design of the session timeout and secure cookie management features. The text's comprehensive treatment of web application security threats and countermeasures provided a systematic framework for ensuring that the CareMed system's security architecture was complete rather than addressing only the most obvious threats.

2.3.3 Philippine Data Privacy Act of 2012 (Republic Act No. 10173):

The Philippine Data Privacy Act of 2012, enacted as Republic Act No. 10173, establishes the comprehensive legal framework governing the collection, processing, storage, and protection of personal information in the Philippines. The Act was enacted in recognition of the fundamental right of individuals to privacy and to the protection of their personal data, and establishes obligations for all entities — public and private — that collected, process, or store personal information of

Filipino citizens or individuals within Philippine territory. The Act's scope was deliberately broad, applying to organizations of all sizes and types that handle personal data in any form, with no minimum scale threshold below which the Act's requirements cease to apply. This means that CareMed, as a small enterprise that collected and stores customer personal information, was fully subject to the Act's requirements regardless of its size.

Section 20 of the Act establishes the core security obligations applicable to all personal information controllers and processors. These obligations required the implementation of reasonable and appropriate organizational, physical, and technical security measures adequate to protect personal information against natural dangers such as accidental loss or destruction, and against human dangers such as unlawful access, fraudulent misuse, unlawful destruction, alteration, contamination, and unauthorized disclosure. The Act specifies that the security measures implemented must be proportionate to the nature of the personal information being protected and the risks to which it was exposed.

The failure to implemented adequate security measures constitutes a violation of the Act and may result in administrative penalties, civil liability, and criminal prosecution under Sections 25 through 32 of the Act. Criminal penalties include imprisonment of up to six years and fines of up to Five Million Pesos for the most serious violations. These penalties apply not only to the organization but potentially to individual officers responsible for data protection — creating personal legal exposure for CareMed's management if customer data was compromised due to inadequate security measures. The NPC had published enforcement case summaries documenting successful prosecutions under the Act for organizations that failed to implemented even basic

technical security controls, underscoring that enforcement was active and consequential.

The CareMed system's security architecture — including hashed credential storage, role-based access control, and audit logging — was designed with these NPC requirements as a baseline compliance standard, ensuring that the system meets both the letter and spirit of the Philippine Data Privacy Act. The system's compliance orientation also provided a template for CareMed to developed the organizational and physical security measures required by the Act — such as a formal data privacy policy, staff training on data handling obligations, and a data breach response plan — which complement the technical security controls implemented in the system.

2.3.4 OWASP Top 10 Web Application Security Risks:

The Open Web Application Security Project (OWASP) was an international nonprofit organization dedicated to improving software security through community-led open source projects, documentation, and research. The OWASP Top 10 was the organization's most widely cited publication — a regularly updated, consensus-based document identifying the ten most critical security risks to web applications, drawn from aggregated data on vulnerability incidence rates, exploit ease, and impact severity across thousands of assessed web applications globally. The Top 10 list was produced through a community-driven process that analyzes vulnerability data contributed by security organizations, pen-testing firms, and independent researchers from around the world.

The most recent edition, published in 2021, identified the following as the ten most critical web application security risks: Broken Access Control (ranked first, having risen from fifth position in the prior 2017 edition), Cryptographic Failures (second), Injection (third), Insecure Design (fourth), Security Misconfiguration (fifth), Vulnerable

and Outdated Components (sixth), Identification and Authentication Failures (seventh), Software and Data Integrity Failures (eighth), Security Logging and Monitoring Failures (ninth), and Server-Side Request Forgery (tenth). The rise of Broken Access Control from fifth to first position between the 2017 and 2021 editions reflected a documented increase in the prevalence and severity of access control vulnerabilities in the intervening years — driven in part by the rapid growth of web application development by teams without formal security training.

The prominence of Broken Access Control as the top-ranked risk was directly relevant to the CareMed system design. The CareMed system's RBAC implementation was specifically designed to prevent broken access control vulnerabilities by enforcing strict role-permission separation and validating user permissions at each protected endpoint through server-side checks that cannot be bypassed through client-side manipulation. Cryptographic Failures were addressed through bcrypt password hashing and HTTPS-enforced transmission. Identification and Authentication Failures were addressed through rate limiting on login attempts, session timeout, and secure cookie management. Security Logging and Monitoring Failures were directly addressed through the CareMed system's comprehensive audit trail logging feature.

The CareMed system's security testing component incorporates test cases specifically designed to verify that the system was not vulnerable to each of the OWASP Top 10 risks relevant to its architecture, providing a standardized and internationally recognized baseline for security evaluation. using the OWASP Top 10 as a security testing framework ensured that the security assessment reflected current, evidence-based security standards and enabled comparison of the CareMed system's security posture with the global benchmark for web application security.

2.3.5 NIST Cybersecurity Framework 2.0:

The National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) [35] was a voluntary set of guidelines, standards, and best practices developed by the United States Department of Commerce to help organizations of all sizes and sectors better understand, manage, and reduce their cybersecurity risk. Originally published in 2014 and substantially updated to version 2.0 in 2024, the framework was widely recognized internationally as a comprehensive and practical reference for cybersecurity risk management. The 2024 update was the most significant revision since the framework's original publication, incorporating a decade of implementation experience and adding the Govern function as a new core function reflecting the recognition that cybersecurity required organizational governance structures, not merely technical controls.

NIST CSF 2.0 organizes cybersecurity activities around six core functions: Govern (establishing and monitoring cybersecurity risk management strategy and policies), identified (understanding the organization's assets, risks, and vulnerabilities), Protect (implementing safeguards to ensured critical services can be delivered), Detect (developing activities to identified cybersecurity incidents), Respond (taking action regarding detected incidents), and Recover (planning for resilience and restoration of services after an incident). These six functions provided a comprehensive lifecycle view of cybersecurity management applicable to organizations of any size, and the framework was deliberately technology-neutral — it describes the security outcomes that organizations should achieve rather than mandating specific implementation tools.

The 2024 update of the framework included a specific Small Business Quick-Start Guide, recognizing that the full

framework can appear overwhelming to organizations with limited cybersecurity resources. This guide recommends that small businesses begin by inventorying their digital assets, implementing basic access control and authentication mechanisms, and establishing activity logging as foundational first steps — precisely the sequence of cybersecurity improvements implemented in the CareMed system. The Quick-Start Guide's explicit acknowledgment that small businesses without prior cybersecurity programs can and should implemented foundational controls validates the CareMed research's approach of treating foundational security controls as achievable and essential for an enterprise of CareMed's size and resource profile.

2.3.6 Role-Based Access Control (RBAC) Theory and Implementation:

The conceptual foundation of Role-Based Access Control (RBAC) was formalized by Ferraiolo and Kuhn [36] in a landmark National Institute of Standards and Technology publication, and subsequently elaborated into the RBAC96 model by Sandhu et al. [37], which became the basis for the American National Standards Institute (ANSI) RBAC standard. RBAC was now recognized as the dominant access control paradigm for enterprise and web application security due to its combination of administrative simplicity, security effectiveness, and conceptual transparency — properties that make it suitable for organizations ranging from small enterprises with simple permission structures to large corporations with hundreds of distinct roles and thousands of users.

The fundamental principle of RBAC was that permissions to access system resources and perform system functions were assigned to roles — abstract representations of job functions or responsibilities — rather than to individual users. Users were then assigned membership in one or more roles, and their

effective system permissions were determined by the union of permissions assigned to all their roles. This indirection between users and permissions provided several important advantages: permissions can be managed at the role level rather than the individual user level, reducing administrative overhead; role definitions transparently encode the access rights expected of each organizational function; and adding or removing a user from the system required only assignment or removal of role membership, without requiring any changes to the underlying permission structure.

In the context of web application development, RBAC was implemented by associating each authenticated user session with a role identifier, and verifying that the user's role had the required permission before executing any privileged function. This verification must be performed on the server side — client-side checks such as hiding menu items from lower-privileged users provided a usability improvement but did not constitute a security control, since client-side code can be manipulated by a technically capable user. The OWASP Top 10 [38] specifically documents that broken access control was the most prevalent web application security vulnerability, with 94% of applications found to had some form of broken access control during security testing. The CareMed system implemented server-side permission verification at every protected endpoint.

The CareMed system implemented a two-role RBAC model: Administrator (with full access to all system functions including inventory management, transaction processing, user account management, report generation, and audit log viewing) and Customer (with restricted access to the public-facing product catalog and order submission functions only). This role structure reflected the actual organizational function division at CareMed and ensured that customer-facing interface credentials cannot be used to access or manipulate sensitive

business operations data, regardless of how the customer account was obtained or whether it was compromised by an attacker.

2.3.7 Password Hashing and Credential Security:

The secure storage of user passwords was one of the most foundational requirements of any web application that handles user authentication. The core principle — that passwords must never be stored in retrievable form, whether in plaintext or reversible encrypted form — was universally agreed upon in the security research literature and mandated by regulatory standards including the NIST Digital Identity Guidelines (NIST SP 800-63B) and the PCI Data Security Standard. This principle reflected the documented risk of database compromise: in the event that an attacker gains unauthorized access to a system's database, the attacker must not be able to recover any user's actual password from the stored data. Achieving this requirement necessitates one-way hashing — transforming passwords into fixed-length hash values from which the original password cannot be computationally recovered within a feasible timeframe.

Bhagat et al. [39], in a study on secure hashing using bcrypt for cryptographic applications, documented that bcrypt was consistently identified in research literature as among the most suitable password hashing algorithms for web applications requiring strong resistance to offline dictionary and brute-force attacks. Unlike general-purpose cryptographic hash functions such as SHA-256 or MD5 — which were optimized for speed and were therefore vulnerable to high-speed brute-force attacks using modern GPU hardware — bcrypt was designed specifically for password hashing with a deliberately slow computation time. The algorithm incorporates a configurable work factor that controls the computational intensity of the hashing process, allowing the algorithm's resistance to brute-

force attacks to be increased as hardware speeds improve without requiring changes to the stored hash format.

A 2023 retrospective on bcrypt published by USENIX [40] documented that modern GPU hardware can compute approximately 184,000 bcrypt hashes per second at work factor 5, compared to 6.3 billion SHA-256 hashes per second on the same hardware. This difference of approximately 34,000-fold represented a fundamental security advantage that makes brute-force attacks against bcrypt-hashed passwords economically infeasible for all but the most determined and well-resourced attackers. The bcrypt work factor can be increased further as hardware capabilities improve, maintaining this security advantage indefinitely. Current NIST recommendations and industry best practices suggest a work factor of 10 to 12 for interactive authentication systems.

The CareMed system implemented bcrypt with a work factor of 12 for all password hashing operations, consistent with current NIST recommendations and the findings of the password security research literature. This implementation ensured that even in the event of a database compromise — where an attacker gains access to the stored hash values — recovering plaintext passwords from those hashes would required computational resources and time that make the attack economically infeasible for a small enterprise target, effectively neutralizing the credential exposure risk associated with database breaches.

2.3.8 ISO/IEC 25010 Software Product Quality Model:

ISO/IEC 25010 [41] was the international standard for software product quality evaluation, published by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC) as part of the SQuaRE (Systems and Software Quality Requirements and Evaluation) series. The standard provided a hierarchical quality model

that defined the dimensions along which software product quality should be assessed, decomposing each high-level quality characteristic into measurable sub-characteristics that provided specific, actionable criteria for evaluation. The use of a standardized quality model rather than ad hoc evaluation criteria ensured comparability of evaluation results across different systems, studies, and research contexts — a property essential for situating the CareMed evaluation within the broader body of Filipino and international capstone research on management system development.

The most current edition, ISO/IEC 25010:2023, defined nine product quality characteristics: Functional Suitability, Performance Efficiency, Compatibility, Interaction Capability, Reliability, Security, Maintainability, Flexibility, and Safety. Each characteristic was further decomposed into two to five sub-characteristics that provided more specific evaluation dimensions. Functional Suitability, for example, was decomposed into Functional Completeness (the degree to which the implemented functions cover all specified tasks and objectives), Functional Correctness (the degree to which the system produces correct results), and Functional Appropriateness (the degree to which the functions facilitate the accomplishment of specified tasks and objectives).

A bibliometric analysis of 1,613 scientific articles on ISO/IEC 25010, published in Engineering, Technology & Applied Science Research [42], documented that research applying the standard reached its highest publication volume in 2023, and that applications in public administration, finance, education, and healthcare were growing at the fastest rates. The study confirmed that ISO/IEC 25010 was the most widely adopted software quality evaluation standard in academic capstone and thesis research contexts globally, making it the appropriate framework for a comparative assessment of the

CareMed system. The standard's prominence in Philippine IT education research — where it was widely used as the evaluation framework for capstone projects in BSInfoTech and BSCS programs — ensured that the CareMed evaluation results were directly comparable with those of related Philippine academic studies.

The CareMed system's evaluation instrument was structured around five dimensions of ISO/IEC 25010 most directly applicable to the system's purpose and context: Functional Suitability, Performance Efficiency, Interaction Capability (Usability), Reliability, and Security. These five dimensions correspond precisely to the dimensions most commonly evaluated in management system research in the Philippine academic context, enabling direct comparison of the CareMed system's evaluation results with those of related studies such as Tanaman et al. [23] and Mariani and Wacas [12].

2.3.9 Python Flask Framework for Web Application Development:

Flask was a lightweight micro web framework for the Python programming language, developed by Armin Ronacher [43] and maintained under the Pallets Projects open source umbrella. First released in 2010, Flask had grown to became one of the most widely used Python web frameworks globally — the Python Developers Survey documented Flask as the most popular Python web framework among developers for five consecutive years between 2018 and 2022. Flask's design philosophy distinguishes it from full-stack frameworks like Django: rather than providing a comprehensive, opinionated platform that makes architectural decisions for developers, Flask provided a minimal, flexible core that developers can extend by selectively integrating libraries for the specific capabilities their application required.

For the CareMed project, Flask's architectural philosophy translates to a system that includes precisely the security controls, database integration, and routing logic needed for the CareMed use case without the overhead of a framework designed for larger, more heterogeneous application environments. The development team had full visibility into and control over every aspect of the system's operation, which was particularly important for security-critical functions such as authentication, session management, and access control. When security controls were implemented explicitly rather than delegated to framework defaults, the developer can verify that each control was correctly configured for the specific requirements of the application.

From a security perspective, Flask provided native supported for several important security mechanisms relevant to the CareMed system. Flask's Werkzeug library provided utilities for secure session management and password hashing. Flask's Jinja2 templating engine provided automatic HTML escaping, preventing Cross-Site Scripting attacks by default. The Flask-Login extension provided user session management functions including login-required decorators that enforce authentication checks at each protected route. The Flask-WTF extension provided CSRF protection for all form submissions. Together, these mechanisms addressed several of the OWASP Top 10 risk categories directly within the framework's built-in security capabilities.

2.3.10 MySQL Relational Database Management System:

MySQL was an open-source relational database management system (RDBMS) [44] that was among the most widely deployed database platforms globally. Originally developed by MySQL AB and currently maintained by Oracle Corporation, MySQL uses the Structured Query Language (SQL) for data definition, manipulation, and retrieval. MySQL's combination of broad

community adoption, extensive documentation, strong tool ecosystem, and proven reliability at scales from single-user applications to multi-million-transaction enterprise deployments makes it the natural choice for a small enterprise management system requiring a production-ready, well-supported database platform without the licensing cost of commercial alternatives. The availability of MySQL expertise in the Philippine developer community — where MySQL was among the most commonly taught and used database systems in IT education programs — further supported its selection as the CareMed system's database platform.

For the CareMed system's security requirements, MySQL provided several relevant security features. MySQL supported native encryption of data at rest using the InnoDB storage engine's table-level encryption feature, applicable to tables containing sensitive customer personal information. MySQL's user privilege system allowed granular control over which database operations each database user account was permitted to perform — the CareMed application's database connection account can be restricted to SELECT, INSERT, UPDATE, and DELETE operations on specific tables, preventing unauthorized schema modification even if the application account credentials were compromised. This database-level access restriction implemented the principle of least privilege at the infrastructure layer, providing an additional layer of protection beyond the application-level RBAC controls.

The use of parameterized queries — specifically through SQLAlchemy, a Python SQL toolkit and Object-Relational Mapping (ORM) library — was the primary technical defense against SQL injection attacks in the CareMed system. SQLAlchemy automatically parameterizes all database queries, ensuring that user-supplied data values were always treated as literal data rather than executable SQL syntax, regardless of their content. This parameterization was applied universally across

all database operations, eliminating the possibility of SQL injection vulnerabilities arising from inconsistent application of parameterization — a common failure mode in applications where parameterization was applied manually on a case-by-case basis rather than enforced at the data access layer.

2.3.11 Client-Server Architecture for Web Applications:

The client-server architecture was the foundational structural model for web-based information systems, defining the distinct roles of two primary system components: the client (a web browser executing on the user's device) and the server (a remote system executing the application software and managing the database). In the client-server model, the client was responsible for rendering the user interface and transmitting user inputs to the server; the server processes inputs, executes business logic, queries the database, and returns results for client-side display. This separation of concerns between presentation logic (client) and business logic and data management (server) was not merely an architectural convention but a security requirement: any business logic or access control check implemented on the client side can be bypassed by a technically capable user, making server-side implementation of all security-critical logic mandatory.

Tanenbaum and Van Steen [45], in Distributed Systems: Principles and Paradigms, document that the client-server architecture provided three properties critical for business management systems: centralized data storage — ensuring all business data exists in a single authoritative location rather than distributed across client devices; server-side access control enforcement — ensuring that security checks cannot be bypassed through client-side manipulation; and platform independence — enabling the system to be accessed from any device with a web browser without requiring device-specific

software installation. These properties make the client-server architecture particularly appropriate for small enterprise management systems, where minimizing IT infrastructure overhead was an operational priority.

For the CareMed system, the client-server architecture provided operational flexibility essential for a small enterprise context: the Administrator and Customer interfaces were accessible from any internet-connected device with a web browser — desktop, laptop, tablet, or smartphone — without software installation. This eliminates the deployment and maintenance overhead associated with desktop-installed applications, and ensured that business operations can continue from alternative devices if primary devices were damaged or unavailable. The system's mobile-responsive design further extends usability to smartphone access, accommodating the Philippine business environment's mobile-first internet access patterns as documented in local studies reviewed in Section 2.2.

2.3.12 Database Design and Normalization for Transaction Processing Systems:

The relational database model, formalized by E.F. Codd in his landmark 1970 paper "A Relational Model of Data for Large Shared Data Banks [46]," provided the theoretical and practical foundation for MySQL and all other major contemporary database management systems. The model defined a rigorous framework for organizing data into tables with well-defined relationships, governed by integrity constraints that ensured the consistency and correctness of the stored data. The relational model's formal mathematical foundation — based on relational algebra and set theory — gives database design a level of theoretical rigor that supported systematic analysis of data structure correctness, distinguishing well-designed from poorly designed schemas based on objective criteria.

Database normalization proceeds through progressively strict "normal forms," each addressing a specific category of data integrity risk. Third Normal Form (3NF) was the standard design target for transaction processing databases: a 3NF schema ensured that all non-key attributes in each table depend directly on the table's primary key, eliminating transitive dependencies that can cause update anomalies and deletion anomalies. For a medical equipment supply and rental enterprise, these anomalies had practical operational significance: an update anomaly could result in inconsistent customer records across multiple transaction entries, while a deletion anomaly could cause loss of product information when the last transaction referencing a product was deleted.

The CareMed database schema was designed to 3NF, with distinct tables for products, customers, sales transactions, rental agreements, users, and audit log entries. Explicit foreign key constraints enforce referential integrity between related tables, ensuring that the database cannot contained orphaned records — for example, a rental record referencing a non-existent customer or product. MySQL's FOREIGN KEY constraint mechanism automatically enforces these referential integrity rules at the database level, providing data quality assurance independent of application-level validation. The combination of normalized schema design and referential integrity enforcement ensured that the CareMed database maintained consistent, accurate data across all operations, supporting the data quality objectives that motivated the transition from manual to digital management.

2.3.13 Responsive Web Design for Mobile-First Business Applications:

Responsive web design (RWD) was an approach to web development in which a single application interface adapts its layout and visual presentation to the characteristics of the device

rendering it — primarily screen width, but also input modality, display density, and browser capabilities. The concept was formally articulated by Ethan Marcotte in a landmark 2010 article in A List Apart magazine [47], and had since became the dominant paradigm for web interface design as mobile device usage had surpassed desktop usage for internet access globally. The shift to mobile-first internet access had been particularly pronounced in developing economies — including the Philippines — where smartphone adoption preceded and surpassed desktop computer adoption.

In the Philippine context, the importance of mobile-responsive design was amplified by the country's mobile-first internet access patterns. Data from the Philippine Statistics Authority [29] indicated that smartphone ownership among Filipino households substantially exceeds laptop and desktop ownership, particularly in provincial regions. For the CareMed system serving a Visayan medical supply enterprise, this means that system interfaces — including the administrative dashboard — must provided full functionality on smartphone-sized screens without compromise. An administrative system that can only be used comfortably on a desktop computer would effectively be inaccessible to CareMed staff who use smartphones as their primary computing devices, undermining the adoption goals of the project.

The CareMed system implemented responsive design using the Bootstrap 5 CSS framework — an open-source front-end toolkit adopted by millions of web applications globally. Bootstrap's 12-column fluid grid system automatically reorganizes page content based on CSS media query breakpoints corresponding to different device screen width ranges. Bootstrap's responsive utility classes allowed interface elements to be selectively displayed, hidden, or resized based on the rendering device's characteristics, enabling a single codebase to served both smartphone and desktop users with

appropriately adapted presentations of the same content. The CareMed interface had been designed and tested across screen widths from 320 pixels to 1920 pixels to ensured consistent functionality and usability across the full device range used by CareMed staff and customers.

2.3.14 Audit Trail Logging and Non-Repudiation in Information Systems:

Audit trail logging — the systematic, tamper-resistant recording of who performed what action on which data at what time within an information system — was recognized in both the information security literature and applicable regulatory frameworks as a foundational security control for business systems handling sensitive data. Audit logs served multiple distinct functions: they enabled detection of unauthorized access or data modification after the fact; they provided evidence for incident investigation and response; they supported regulatory compliance demonstration; and they created a deterrent effect by ensuring that system users know that their actions were recorded and attributable. The deterrent effect was particularly relevant for small enterprises, where the close interpersonal relationships between staff may reduce the perceived risk of internal misconduct.

The NIST Special Publication 800-92 [48], Guide to Computer Security Log Management, defined the requirements for effective audit logging in information systems, specifying that audit logs should capture at minimum: the identity of the user performing each action, the type of action performed (created, read, update, delete), the specific data object affected, the timestamp of the action, and the outcome (success or failure). The guide also specifies that audit logs must be protected against modification or deletion by ordinary users, including administrators — a property known as log

integrity — to ensured that an attacker who had compromised the system cannot cover their tracks by deleting or altering log records.

The Philippine Data Privacy Act's requirement for systematic monitoring of access to personal data, and the NPC's breach notification obligations requiring organizations to determine the scope and timeline of data breaches within 72 hours, both presuppose the existence of adequate audit logging. The CareMed system implemented a dedicated audit log table in the MySQL database, populated by application-level logging middleware that records each authenticated user's interactions with the system including login and logout events, inventory modifications, customer record accesses, transaction creations, and all administrative operations. The audit log table was accessible in read-only mode to the Administrator role and was not modifiable through any application-layer operation, providing the log integrity required by NIST SP 800-92 [48] and supporting the NPC's breach investigation and notification requirements.

2.3.15 Inventory Economic Order Quantity and Stock Management Theory:

The theoretical underpinning of inventory management as a business discipline extends from the classical Economic Order Quantity (EOQ) model, which provided a framework for understanding the economic tradeoffs inherent in inventory management: holding more inventory reduces the frequency and cost of ordering and the risk of stockouts, but increases holding costs; holding less inventory reduces holding costs but increases ordering frequency, administrative overhead, and stockout risk. Achieving the optimal balance between these competing costs required accurate, real-time visibility into inventory levels and consumption patterns — visibility that manual inventory management systems were structurally unable

to provided because of the time lag between physical stock movements and manual record updates.

Munyaka and Yadavalli [49], in a systematic review published in the South African Journal of Industrial Engineering, documented that inventory management was one of the most critical operational functions for small and medium enterprises across all sectors. The review found that enterprises without formal inventory management systems consistently exhibit higher stockout rates, higher overstock rates, and poorer order fulfillment accuracy compared to enterprises using digital inventory tracking with real-time stock level visibility. For CareMed, which manages both a for-sale inventory and a rental inventory — with the added complexity of tracking rental equipment through its entire rental lifecycle — the absence of a formal inventory management system created compounding operational risks that affect every dimension of business performance.

For CareMed's rental inventory specifically, the EOQ framework was supplemented by rental management considerations that had no parallel in conventional inventory theory: rental items must be tracked through their entire rental lifecycle, from the moment of rental departure to the scheduled return date and actual return, with alerting mechanisms for overdue items that remain in customer possession beyond the agreed rental period. The CareMed system's inventory module was specifically designed to handle this dual-state inventory management requirement, with separate tracking for sales stock and rental stock, automated alert generation for items approaching low stock thresholds, and overdue rental tracking with escalating notification to administrative users. These features addressed the specific operational challenges of the medical equipment rental business model in a way that generic inventory management concepts did not fully capture.

2.4 Synthesis of the Reviewed Literature and Studies

The reviewed foreign studies, local studies, and related literature collectively establish a clear, multi-dimensional, and mutually reinforcing foundation for the proposed CareMed Cybersecurity-Integrated Digital Infrastructure Model. The synthesis that follows identified the central themes emerging from the reviewed literature, the convergences and consistencies across different research contexts and methodological approaches, and the specific research gap that this study addressed. The synthesis was organized around five thematic areas that cut across the three sections of the review, each reflecting a distinct dimension of the CareMed research's conceptual and empirical foundations.

2.4.1 Convergence on the Vulnerability of Manual Small Enterprise Systems:

Across all reviewed studies — from the IEEE Access cybersecurity survey of Chidukwani et al. [9] to the Philippine small enterprise inventory system study of Tanaman et al. [23] — a consistent finding emerges: small enterprises operating through manual processes faced measurable and significant disadvantages in operational efficiency, data accuracy, record integrity, and business responsiveness compared to those using even basic digital management systems. This finding holds across different geographic contexts — North America, Europe, Australia, and the Philippines — different industry sectors — retail, construction supply, and healthcare — and different research methodologies — systematic literature reviews, empirical surveys, and system development case studies.

The specific challenges documented — stock discrepancies from manual transcription errors, inability to retrieve historical records efficiently, vulnerability of physical records to loss and damage, and absence of real-time

visibility into business operations — were not merely operational inconveniences but constitute genuine business risks. For CareMed specifically, in the context of medical equipment supply serving patients who depend on reliable availability of essential recovery equipment, these operational risks carry heightened ethical and practical significance. A stockout of a critical rehabilitation device caused by inaccurate manual inventory records was not merely a lost sale — it represented a failure to meet a patient's medically necessary needed, with potential consequences for health and recovery that created moral obligations beyond ordinary commercial accountability.

The reviewed literature thus provided robust empirical grounding for the first core premise of this study: that the transition from manual to digital management operations was not optional for CareMed if the enterprise was to provided the level of service reliability and operational accuracy that its customer population — home-based patients and their caregivers — required. The studies reviewed in this chapter, taken together, predict with high confidence that the CareMed system would produce meaningful improvements in inventory accuracy, record retrieval efficiency, report generation capability, and overall operational performance — improvements that was confirmed or disconfirmed by the system evaluation documented in Chapter 5 of this research.

2.4.2 Convergence on the Security Gap in SME Digital Adoption:

A second convergent theme across the reviewed literature was that the transition from manual to digital operations, if not accompanied by deliberate cybersecurity integration, did not reduce risk — it transforms it. The Asia Foundation [24] Philippine cybersecurity report documents precisely this dynamic: Filipino small businesses that had adopted digital

communication and transaction tools without implementing security controls were more vulnerable to cyberattacks than those that remained entirely manual, because digital tools created new attack surfaces while providing the attacker with more valuable and accessible targets. A business that stores customer data in Facebook Messenger threads was more vulnerable to data theft than one that stores the same data in a locked paper notebook — not because digital storage was inherently less secure, but because digital data can be accessed remotely and at scale by an attacker who compromises a single credential.

The systematic review of Rombaldo Junior et al. [10] documents the same pattern globally: SMEs that adopt digital tools without corresponding security investments enter a vicious circle of increasing digital dependence and increasing vulnerability. The OWASP Top 10 and NIST Cybersecurity Framework provided the normative technical standards within which effective cybersecurity controls should be designed, while Mihelič et al. [11] provided specific guidance on how to integrate those controls into Agile development processes without disproportionate cost or timeline impact. Together, these sources defined both the problem — the security gap in SME digital adoption — and the solution space — the specific technical controls that empirical evidence identified as most effective for the SME context.

This convergent finding directly informs the defining characteristic of the CareMed system: the deliberate integration of cybersecurity as a foundational design principle, not as an added-on feature. By embedding authentication, access control, session management, input validation, credential hashing, and activity logging into the core system architecture from the earliest design phase, the CareMed system avoids the "digitalize first, secure later" trap that the reviewed literature consistently identified as

the primary driver of SME cybersecurity failure. The security architecture of the CareMed system was designed as a first-order requirement that constrains and shapes every other design decision — from database schema design to user interface layout — to ensured that security properties were maintained at every level of the system.

2.4.3 The Philippine Regulatory Imperative:

The Philippine Data Privacy Act of 2012 (Republic Act No. 10173) added a regulatory dimension to the cybersecurity imperative identified in the literature. CareMed's collection and storage of customer personal information — names, contact details, addressed, and transaction histories — makes it a personal information controller under the Act, with explicit legal obligations to protect that data through adequate technical and organizational security measures. The Asia Foundation [24] report documented that many Filipino SMEs were unaware of these obligations, creating significant unrecognized legal exposure — a finding reinforced by the NPC's published enforcement cases, which document violations by organizations that appeared unaware that the Act applied to their data handling practices.

The CareMed system's security architecture was designed with the Data Privacy Act's requirements as an explicit compliance baseline, ensuring that the system not only addressed operational security needed but also fulfills the enterprise's legal obligations under Philippine privacy law. The NPC's specific technical guidance — including requirements for password hashing, role-based access control, and audit logging — aligns precisely with the security controls implemented in the CareMed system, reflecting the grounding of the system's security design in both international technical best practices (NIST, OWASP) and the Philippine regulatory framework applicable to the enterprise. This dual grounding

ensured that the CareMed system's security architecture was both technically sound and locally compliant.

The regulatory dimension distinguishes the CareMed project from generic small enterprise digitalization studies and provided an additional, non-negotiable rationale for the cybersecurity integration approach. Where the operational and competitive rationales for security investment might be weighed against cost and convenience considerations, the legal compliance rationale created a mandatory floor below which security investment cannot fall without creating legal liability. The CareMed system was designed to meet that floor and exceed it — providing security capabilities that not only achieve compliance but establish a sustainable security posture appropriate for the enterprise's long-term growth and digital maturity development.

2.4.4 Technical Framework Convergence:

The technical literature — Stallings [34] on network security, the OWASP Top 10 [38] on web application security risks, and the NIST CSF 2.0 [35] on cybersecurity management — converges on a consistent set of foundational security controls appropriate for web-based management systems in small enterprise contexts. These controls — role-based access control, strong password hashing, session management, input validation and sanitization, audit trail logging, and HTTPS-enforced communication — form the security architecture of the CareMed system. By grounding the system's security design in these established international standards, this study ensured that the security controls implemented were consistent with globally recognized best practices and were verifiable against documented benchmarks.

Similarly, the ISO/IEC 25010 software quality standard provided a rigorous and internationally recognized framework for evaluating the overall quality of the developed system.

The convergence of the reviewed local studies on ISO-based evaluation instruments enabled direct comparison of the CareMed system's evaluation results with established benchmarks in the Philippine small enterprise digitalization literature. The choice of evaluation framework was thus not arbitrary but grounded in the precedent established by the most closely analogous studies in the reviewed literature — ensuring that the CareMed evaluation contributed meaningfully to the existing body of knowledge.

The technology stack selected for the CareMed system — Python Flask, MySQL, SQLAlchemy, Bootstrap 5 — was also convergently validated by the reviewed literature. Flask's security-conscious defaults, SQLAlchemy's SQL injection prevention through automatic parameterization, and Bootstrap's mobile-responsive grid system each addressed specific requirements identified in the reviewed studies. The selection of this stack was a principled response to the requirements established by the reviewed literature — each component selected for the specific properties it contributed to the security, usability, and operational fit objectives of the CareMed project rather than for reasons of developer preference alone.

2.4.5 The Research Gap:

Despite the breadth and depth of the reviewed literature, a clear and specific gap exists: there was no documented study in the available Philippine academic literature that describes the development of a cybersecurity-integrated digital management system specifically designed for a small medical equipment supply and rental enterprise. The existing Philippine studies either addressed digital inventory systems for non-healthcare SMEs [23] or addressed cybersecurity challenges at a macro level without system implementation [24]. No study had combined the operational requirements of

medical equipment supply and rental management — including dual-state inventory tracking, rental lifecycle management with overdue tracking, and customer management for a patient-centered service context — with a purpose-built cybersecurity integration framework for a small Philippine enterprise.

Additionally, no existing study addressed the specific intersection of Philippine Data Privacy Act compliance requirements and medical equipment supply operations — a combination that created unique obligations given the patient-related nature of CareMed's customer base and the sensitivity of medical supply records. While the Data Privacy Act applies to all personal information controllers, the context of a medical supply enterprise created heightened obligations and heightened consequences for non-compliance, making the regulatory compliance dimension of the CareMed research both more complex and more consequential than it would be for a non-healthcare SME context.

This gap defined the specific and original contribution of the CareMed study: the design, development, and evaluation of a system that simultaneously addressed the operational digitalization needed of a medical equipment supply and rental enterprise and embeds cybersecurity controls appropriate to the Philippine regulatory and threat environment. The study's findings — both the system itself and the documented development and evaluation methodology — contributed to the growing body of literature on cybersecurity-integrated digital transformation for Philippine SMEs and provided a replicable model for similar enterprises in the healthcare supply sector. Future researchers developing management systems for comparable enterprises can draw on the CareMed research as a methodological and architectural precedent that addressed the security dimension explicitly, rather than as an optional enhancement to be considered after the core system was complete.

In summary, the reviewed literature validates the needed for, and comprehensively informs the design of, a system that integrates operational efficiency improvement and cybersecurity protection within a single digital platform. The convergent findings across foreign studies, local studies, and related literature remove any doubt about the needed for such a system and provided the researcher with a rich foundation of methodological precedents, theoretical frameworks, and empirical benchmarks against which the CareMed system can be designed and evaluated. The synthesis presented in this chapter establishes that the CareMed research was firmly grounded in the existing body of knowledge and was positioned to make a meaningful and distinctive contribution to that knowledge through the development and evaluation of a cybersecurity-integrated digital management system designed for the specific context of a small Philippine medical equipment supply and rental enterprise.

REFERENCES

[9] A. Chidukwani, S. Zander, and P. Koutsakis, "A survey on the cybersecurity of small-to-medium businesses: Challenges, research focus and recommendations," IEEE Access, vol. 10, pp. 85701–85719, 2022, doi: 10.1109/ACCESS.2022.3197899.

[10] A. H. Rombaldo Junior, T. Becker, and C. Johnson, "Cybersecurity challenges for small and medium enterprises: A systematic review," arXiv:2309.17186, 2025. [Online]. Available: https://arxiv.org/abs/2309.17186

[11] A. Mihelič, S. Vrhovec, and T. Hovelja, "Agile development of secure software for small and medium-sized enterprises," Sustainability, vol. 15, no. 1, Art. no. 801, 2023, doi: 10.3390/su15010801.

[12] J. C. Mariani and F. Y. Wacas, "Efficacy, reliability, and accuracy of inventory systems in small and medium enterprises in Tabuk City, Kalinga," Int. J. English Lit. Soc. Sci., vol. 7, no. 6, 2022, doi: 10.22161/ijels.76.43.

[13] F. N. Otobo and E. C. Alegbe, "Design of a web-based inventory management system for small and medium enterprises," Int. J. Innovative Inf. Syst. Technol. Res., vol. 13, no. 1, pp. 127–136, 2025.

[14] "Development of a web-based inventory management system for small businesses," Int. J. Ind. Prod. Eng., vol. 2, no. 2, pp. 53–67, 2024.

[15] "Digitalization to achieve greener healthcare supply chain," J. Cleaner Prod., 2024, doi: 10.1016/j.jclepro.2024.142509.

[16] Allied Market Research, Medical Equipment Rental Market: Global Opportunity Analysis and Industry Forecast, 2022–2032. Portland, OR, USA: Allied Market Research, 2023.

[17] A. C. Dima and M. A. Maassen, "Structured software development versus agile software development: A comparative analysis," Int. J. Syst. Assurance Eng. Manag., 2023, doi: 10.1007/s13198-023-01958-5.

[18] E. Mpamugo and G. Ansa, "Enhancing network security in mobile applications with role-based access control," J. Inf. Syst. Informatics, vol. 6, no. 3, pp. 1872–1899, 2024, doi: 10.51519/journalisi.v6i3.863.

[19] F. F. Afolabi, Y. M. Malgwi, M. A. Mahmud, and J. P. Oguntoye, "Development of a web-based platform for automating an inventory management of a small and medium enterprise," Niger. J. Technol., vol. 41, no. 3, 2022.

[20] "DRacv: Detecting and auto-repairing vulnerabilities in role-based access control in web application," J. Netw. Comput. Appl., 2025, doi: 10.1016/j.jnca.2025.103900.

[21] National Institute of Standards and Technology, Digital Identity Guidelines: Authentication and Lifecycle Management (NIST SP 800-63B). Gaithersburg, MD, USA: U.S. Dept. of Commerce, 2020.

[22] S. Gupta and T. Wang, "SQL injection: Trends, challenges, and solutions," Database Security Quarterly, vol. 30, no. 2, pp. 89–104, Apr. 2024.

[23] M. T. Tanaman, J. Baylosis, M. Abiles, J. Catungal, and P. Encarnacion, "Web-based inventory management system for small business enterprise," Int. J. Sci. Appl. Inf. Technol., vol. 12, no. 5, pp. 44–48, 2023, doi: 10.30534/ijsait/2023/021252023.

[24] The Asia Foundation, Cybersecurity in the Philippines: Global Context and Local Challenges. Manila, Philippines: The Asia Foundation, 2022.

[25] Trend Micro, "Leveraging over 30 years of security expertise and technology foresight," Trend Micro Incorporated, Security Threat Landscape Report, H1 2021 Threat Intelligence Tracking, May 2021.

[26] "The impact of digital transformation in the Philippines: A study of the key drivers and barriers," in Proc. 2024 7th Int. Conf. Comput. Manage. Bus., 2024, doi: 10.1145/3647782.3647799.

[27] "Improving supply chain management: A comparative study on Internet of Things adoption in SMEs of Philippines and Asian countries," Int. J. Res. Innovation Soc. Sci., vol. 8, no. 8, 2024.

[28] "Determining user requirements for a tailored web-based inventory and sales management system in micro-small construction supply stores using design thinking," in Proc. 2024 6th World Symp. Softw. Eng., 2024, doi: 10.1145/3698062.3698082.

[29] Philippine Statistics Authority, 2022 ICT Survey / Survey on Information and Communication Technology. Quezon City, Philippines: PSA, 2022.

[30] National Privacy Commission, "NPC Circular 16-01: Security of personal data in government agencies," NPC, Philippines, 2016. [Online]. Available: https://www.privacy.gov.ph

[31] Department of Trade and Industry, "Digital transformation and the Philippine small and medium enterprises," DTI, Philippines, 2023.

[32] Department of Health, "Guidelines on home-based care services," DOH, Philippines, 2022.

[33] K. C. Laudon and J. P. Laudon, Management Information Systems: Managing the Digital Firm, 16th ed. Boston, MA, USA: Pearson, 2020.

[34] W. Stallings, Network Security Essentials: Applications and Standards, 6th ed. Boston, MA, USA: Pearson, 2018.

[35] National Institute of Standards and Technology, The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). Gaithersburg, MD, USA: U.S. Dept. of Commerce, 2024.

[36] D. F. Ferraiolo and D. R. Kuhn, "Role-based access control," in Proc. 15th NIST-NCSC Nat. Comput. Security Conf., 1992, pp. 554–563.

[37] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, and C. E. Youman, "Role-based access control models," IEEE Computer, vol. 29, no. 2, pp. 38–47, Feb. 1996.

[38] OWASP Foundation, "OWASP Top 10:2021," 2021. [Online]. Available: https://owasp.org/www-project-top-ten/

[39] S. S. Bhagat et al., "Secure hashing using bcrypt for cryptographic applications," Int. J. Inf. Security, 2023.

[40] "BCrypt at 25: A retrospective on password security," USENIX ;login:, 2023. [Online]. Available: https://www.usenix.org/publications/loginonline/bcrypt-25-retrospective-password-security

[41] ISO/IEC 25010:2023, Systems and Software Quality Requirements and Evaluation (SQuaRE)—Product Quality Model. Geneva, Switzerland: ISO/IEC, 2023.

[42] "Bibliometric analysis of ISO/IEC 25010 in software quality evaluation," Eng. Technol. Appl. Sci. Res., 2025.

[43] A. Ronacher, "Flask (web framework)," Pallets Projects, 2010. [Online]. Available: https://flask.palletsprojects.com/

[44] MySQL 8.0 Reference Manual, Oracle Corporation. [Online]. Available: https://dev.mysql.com/doc/refman/8.0/en/

[45] A. S. Tanenbaum and M. Van Steen, Distributed Systems: Principles and Paradigms, 3rd ed. Upper Saddle River, NJ, USA: Prentice Hall, 2017.

[46] C. J. Date, An Introduction to Database Systems, 8th ed. Boston, MA, USA: Addison-Wesley, 2019.

[47] E. Marcotte, "Responsive web design," A List Apart, 2010. [Online]. Available: https://alistapart.com/article/responsive-web-design/

[48] National Institute of Standards and Technology, Guide to Computer Security Log Management (NIST SP 800-92). Gaithersburg, MD, USA: U.S. Dept. of Commerce, 2006.

[49] J. B. Munyaka and V. S. S. Yadavalli, "Inventory management concepts and implementations: A systematic review," South Afr. J. Ind. Eng., vol. 33, no. 2, pp. 15–36, 2022.

CHAPTER III

METHODOLOGY

3.1 Research Design

This study employed a developmental research design approach. Developmental research, as defined by Richey and Klein [50], was a systematic methodology for designing, developing, and evaluating instructional programs, processes, and products that must meet the criteria of internal consistency and effectiveness. This research design was particularly appropriate for this study because it focuses on the creation of a software system — the CareMed Cybersecurity-Integrated Digital Infrastructure Model — designed to addressed specific operational and cybersecurity challenges identified within CareMed Medical Supply Enterprise.

The developmental research approach allowed the researchers to systematically analyze existing manual workflows, design a technology-based solution grounded in established security frameworks, developed the system using modern software engineering practices, and evaluate its effectiveness against standardized software quality criteria. Unlike descriptive research, which merely documents existing conditions, or experimental research, which manipulates variables in controlled settings, developmental research produces a tangible artifact — in this case, a fully functional web-based management system — whose quality and effectiveness can be empirically measured and assessed (Richey & Klein, 2005).

The research design integrates three methodological components that collectively ensured rigor and practical relevance:

- Requirements Analysis: A comprehensive analysis of CareMed's existing manual workflows through structured interviews, direct observation, and document analysis. This component ensured that the developed system addressed genuine operational needed rather than imposing a generic solution.

- System Development: An iterative development process following the Agile methodology, producing a functional system with integrated cybersecurity controls. The development process was documented through version control (Git) and structured sprint planning.

- System Evaluation: A formal evaluation process using the ISO/IEC 25010 software product quality standard, assessing the system across five quality dimensions — functional suitability, performance efficiency, usability, reliability, and security — through structured questionnaires administered to representative users.

The developmental research design was selected over alternative approaches for several reasons. First, it directly addressed the practical needed for an operational system at CareMed, producing a concrete deliverable that can be deployed and used. Second, it accommodates the iterative nature of software development, allowing for continuous refinement based on testing feedback and stakeholder input. Third, it provided a structured evaluation framework that produces measurable evidence of the system's quality and effectiveness, contributing to the academic rigor of the study.

The study was conducted within the ethical guidelines for research involving human participants. All interview participants provided informed consent, and data collected from CareMed was handled confidentially in accordance with the Philippine Data Privacy Act of 2012. The evaluation

instruments were designed to minimize participant burden while maximizing the reliability and validity of collected data.

- functional suitability, performance efficiency, usability, reliability, and security — through structured questionnaires administered to representative users.

The developmental research design was selected over alternative approaches for several reasons. First, it directly addressed the practical needed for an operational system at CareMed, producing a concrete deliverable that can be deployed and used. Second, it accommodates the iterative nature of software development, allowing for continuous refinement based on testing feedback and stakeholder input. Third, it provided a structured evaluation framework that produces measurable evidence of the system's quality and effectiveness, contributing to the academic rigor of the study.

The study was conducted within the ethical guidelines for research involving human participants. All interview participants provided informed consent, and data collected from CareMed was handled confidentially in accordance with the Philippine Data Privacy Act of 2012. The evaluation instruments were designed to minimize participant burden while maximizing the reliability and validity of collected data.

3.2 System Development Methodology

The CareMed system was developed using the Agile software development methodology, specifically incorporating Scrum principles for iterative and incremental delivery. The Agile methodology was chosen over traditional approaches such as the Waterfall model because of its emphasis on adaptability, stakeholder collaboration, and the delivery of working software at regular intervals [51]. Given the resource constraints of a capstone project and the needed for continuous feedback from CareMed's management, Agile provided the flexibility necessary to accommodate evolving requirements

while maintaining steady progress toward a complete, functional system.

The Agile Manifesto, formulated by Beck et al. [51], articulates four core values that guided the development process: (1) individuals and interactions over processes and tools; (2) working software over comprehensive documentation; (3) customer collaboration over contract negotiation; and (4) responding to change over following a fixed plan. These values were operationalized through a series of structured development sprints, each producing an increment of working functionality that could be reviewed, tested, and refined before proceeding to the next iteration.

3.2.1 Agile Development Phases:

The development lifecycle was organized into eight distinct phases. Each phase had clearly defined objectives, deliverables, and evaluation criteria. The following table summarizes the development phases:

Phase	Description	Key Deliverables
0	Planning & Requirements Gathering	Requirements specification, interview documentation
1	Database Design & Core Setup	ERD, database schema, Flask framework setup
2	Authentication & User Management	Login, registration, RBAC, email verification
3	Inventory & Product Catalog	Product CRUD, stock tracking, audit logging
4	Cart, Order & Payment System	Shopping cart, checkout, GCash/COD payments
5	Rental Management & Invoicing	Rental agreements, monthly invoices, returns
6	Security, Reports & Dashboard	IDS, security center, admin dashboard, backups

Phase	Description	Key Deliverables
7	Testing & Quality Assurance	Unit, integration, system, and security test reports

Phase 0: Planning and Requirements Gathering

The planning phase established the foundation for the entire project. The research team conducted a faced-to-faced interview with CareMed's owner and staff at their warehouse location to understand the current operational workflows, document existing challenges, and identified specific system requirements. The interview revealed that CareMed had been operating for approximately one year using entirely manual processes — Excel spreadsheets for inventory and rental tracking, Facebook Messenger for customer communication and transaction history, and physical visits for product viewing and order placement.

Key findings from the requirements gathering phase included: the needed for dual-mode sales and rental functionality; the requirement for two valid IDs and proof of billing for rental customers; the 15-day cut-off cycle (5th and 20th of each month) for verifying oxygen tank refills against Prime Gas records; the variable deposit system based on delivery distance; the one-week extension policy for delayed rental returns; and the first-come-first-served delivery system using a single vehicle with tricycle driver backup for oxygen tank deliveries.

These findings were documented in a formal requirements specification that served as the reference document throughout the development process. The specification defined functional requirements (what the system must did), non-functional requirements (how the system should perform), and security requirements (what protections the system must implemented)

based on the OWASP Top 10 framework and the Philippine Data Privacy Act of 2012.

Phase 1: Database Design and Core Setup

The database design phase focused on creating a robust, normalized relational database schema that could supported all identified system requirements. The Entity-Relationship Diagram (ERD) was developed using the crow's foot notation, identifying 16 core entities: users, customer, product, cart, cart_item, transaction, purchase, rental, rental_invoice, payment, payment_proof, expenses, inventory_logs, security_logs, blocked_ips, and alembic_version.

Database normalization was applied through Third Normal Form (3NF) to eliminate data redundancy and ensured referential integrity. Primary keys were defined for all tables, and foreign key relationships were established to maintained data consistency across related entities. The MySQL relational database management system was selected for its proven reliability, wide supported in Philippine web hosting environments, and compatibility with the Flask-SQLAlchemy ORM layer.

The core application framework was established during this phase, including the Flask application structure, environment configuration using python-dotenv, database connection pooling with pool_pre_ping enabled, and the Alembic migration system for version-controlled database schema changes. Five Alembic migrations were created throughout the development lifecycle to manage incremental schema changes.

Phase 2: Authentication and User Management

The authentication module was developed as the foundational security layer for the entire system. User registration was implemented with email verification through

Flask-Mail using Gmail SMTP, requiring users to verify their email addressed before account activation. The login system incorporates multiple security mechanisms: Argon2 password hashing through argon2-cffi for secure credential storage; account lockout after five consecutive failed login attempts with a 15-minute lockout period enforced through Flask-Limiter rate limiting; and Google OAuth 2.0 integration via Authlib for alternative authentication.

Role-based access control (RBAC) was implemented using Flask-Login with two primary roles: Administrator (full system access) and Customer (restricted to portal functions). Custom route decorators enforce role-based access restrictions on all protected endpoints. Session management uses Flask-Login's permanent session with configurable inactivity timeout, secure HttpOnly and SameSite cookie settings, and complete server-side session destruction on logout.

Phase 3: Inventory and Product Catalog

The inventory management module provided real-time stock tracking with supported for both saleable and rentable products. Products can be configured as sale-only, rent-only, or both, with independent pricing for each mode. Stock quantities were automatically adjusted upon order confirmation and rental checkout, with row-level locking (with_for_update()) preventing race conditions during concurrent transactions.

The product catalog supported categorization, search, and filtering for customer browsing. Administrators can added, edit, archive, and restock products through the admin panel. An inventory audit trail was maintained through the inventory_logs table, recording every stock change with timestamps, change types, and user identifiers for complete

traceability — directly addressing the oxygen tank tracking challenges identified during requirements gathering.

Phase 4: Cart, Order and Payment System

The order processing module manages the complete transaction lifecycle from cart creation through payment confirmation. Customers can added products to their cart with quantity and rental duration specifications. The checkout process implemented automatic total calculation including deposits for rental items, with the deposit amount varying based on delivery distance as per CareMed's operational policy.

Two payment methods were supported: Cash on Delivery (COD) and GCash online payment. For GCash payments, customers upload a screenshot of the transaction with the reference number through the payment_proof system. The order tracking workflow follows a defined status progression: Submitted, Verified, Shipped, and Delivered — providing customers with transparent order status visibility.

Phase 5: Rental Management and Invoicing

The rental management module addressed the most operationally critical aspect of CareMed's business. Rental agreements were created at equipment check-out, capturing the customer identifier, rented items with inventory references, rental start and end dates, deposit amount, and monthly rental rate. The system generates monthly rental invoices through the rental_invoice table, tracking period start/end dates and payment status.

Return processing updates the rental status and automatically restores returned items to available inventory. Special handling was implemented for oxygen tanks, which were returned to an 'Empty' status for refill before being made

available for new rentals — reflecting the actual operational workflow at CareMed. Late fee calculation and the one-week extension policy for delayed returns were implemented as configurable business rules.

Phase 6: Security, Reports and Dashboard

The security monitoring module implemented a comprehensive Intrusion Detection System (IDS) with multiple protective layers. Security events were logged to the security_logs table with user identifiers, IP addressed, user agents, event descriptions, and severity levels. Automatic IP blocking was triggered after repeated violations, with blocked IP addressed stored in the blocked_ips table with configurable expiration.

Bot detection through User-Agent pattern checking was applied at login endpoints. Flask-Talisman enforces security headers including Content Security Policy (CSP), HTTP Strict Transport Security (HSTS), and X-Frame-Options. All security events trigger email notifications to administrators through the Gmail SMTP integration. The admin Security Center provided a centralized interface for monitoring security logs, managing blocked IPs, and reviewing system alerts.

The reporting and dashboard module provided administrators with key performance indicators (KPIs), transaction summaries, inventory status reports, and customer activity analytics. Daily automated database backups were scheduled through APScheduler at midnight, with the system maintaining the last seven backup files. Manual backup and restore tools were also available through the admin panel.

Phase 7: Testing and Quality Assurance

Comprehensive testing was conducted across five modalities: unit testing of individual functions; integration

testing of module interactions; system testing of end-to-end workflows; security testing against the OWASP Top 10 framework; and functional testing of all completed system features. At the conclusion of this phase, the system was fully developed and functional, with all core modules — inventory management, rental processing, order and payment handling, and security monitoring — operating as specified in the requirements.

3.3 System Architecture

The CareMed system follows a three-tier client-server architecture integrated with the Model-View-Controller (MVC) design pattern. This architectural approach was selected for its proven scalability, separation of concerns, and compatibility with web-based application development. The three-tier architecture divides the system into distinct presentation, application, and data layers, each responsible for specific functions and communicating through well-defined interfaces [52].

3.3.1 Three-Tier Architecture Overview:

The presentation tier handles all user interface rendering and client-side interactions. Users access the system through standard web browsers (Chrome, Firefox, Safari, Edge) communicating with the server via HTTP/HTTPS protocols. The presentation layer was built using HTML5 for semantic document structure, CSS3 for styling and responsive layout adaptation, JavaScript for client-side interactivity (including dynamic cart updates, modal dialogs, and AJAX requests), Bootstrap 5 as the front-end component framework, and Jinja2 as the server-side templating engine for dynamic HTML generation.

The application tier contained the core business logic, request processing, and security enforcement. Flask 3.1.3 served as the web application framework, handling URL routing,

HTTP request/response processing, and session management. The application layer was organized into modular components: route handlers (controllers) process incoming requests and coordinate model and view interactions; business logic services encapsulate domain-specific operations such as order processing, rental management, and payment handling; the ORM layer (Flask-SQLAlchemy) mediates all database interactions; and security middleware (Flask-Login, Flask-Limiter, Flask-WTF, Flask-Talisman) enforces authentication, rate limiting, CSRF protection, and security headers.

The data tier manages persistent storage through MySQL, accessed exclusively through SQLAlchemy's parameterized query interface to prevent SQL injection vulnerabilities. The database schema consists of 16 normalized tables with proper indexing on frequently queried fields (email addressed, reference numbers, transaction dates) and foreign key constraints ensuring referential integrity. Database connection pooling with pool_pre_ping validates connections before use, preventing errors from stale connections in the pool.

3.3.2 Model-View-Controller Pattern:

Within the three-tier architecture, the system implemented the Model-View-Controller (MVC) pattern to achieve separation of concerns and maintainable code organization. The Model component consists of SQLAlchemy model classes that defined the database schema and encapsulate data access operations. Each model class corresponds to a database table and provided methods for creating, reading, updating, and deleting records while enforcing data validation rules.

The View component comprises Jinja2 HTML templates that render dynamic content for delivery to user browsers. Templates were organized into separate directories for customer-facing pages (/customer/), administrative pages

(/admin/), and shared components (layouts, macros, partials). Bootstrap 5 provided the responsive grid system and UI components, ensuring consistent presentation across desktop and mobile devices.

The Controller component consists of Flask route handler functions that process HTTP requests, invoke appropriate model operations, and select the correct view for response rendering. Route handlers were organized into Blueprints — Flask's mechanism for modular application structure — with separate blueprints for authentication, customer portal, admin panel, and API endpoints. Custom decorators enforce role-based access control at the route level.

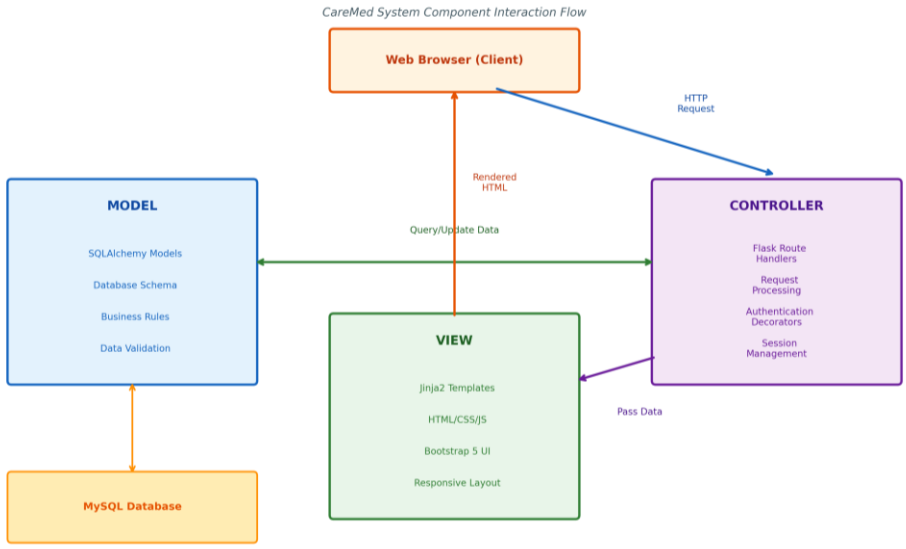


Figure 6. Model-View-Controller (MVC) Architecture Pattern

3.3.3 Integrated Security Layer:

A distinguishing feature of the CareMed architecture was the integrated security layer that operated across all three tiers. Unlike conventional approaches that added security as an afterthought, the CareMed system was designed with security as a foundational architectural component from the initial

design phase — a security-by-design approach consistent with OWASP recommendations and the Philippine Data Privacy Act of 2012 requirements.

At the presentation layer, security was enforced through Jinja2's auto-escaping mechanism, which automatically encodes HTML special characters in all template-rendered content, preventing Cross-Site Scripting (XSS) attacks. CSRF tokens generated by Flask-WTF were included in all state-changing forms and validated server-side before processing.

At the application layer, security controls include: Flask-Login for session-based authentication with configurable timeout and secure cookie settings; argon2-cffi for Argon2 password hashing with adjustable work factor; Flask-Limiter for rate limiting on authentication endpoints (5 attempts per 5 minutes); Flask-WTF for form validation and CSRF protection; Flask-Talisman for HTTP security headers (CSP, HSTS, X-Frame-Options); and the custom IDS module for security event logging, IP blocking, and bot detection.

At the data layer, security was maintained through: SQLAlchemy ORM parameterized queries preventing SQL injection; Argon2 password hashing ensuring credential security even in the event of database compromise; row-level database locking preventing race conditions in concurrent transactions; and comprehensive audit logging through inventory_logs and security_logs tables providing complete traceability of all system events.

3.3.4 External Service Integrations:

The system integrates with three external services to extend its functionality beyond core capabilities. Google OAuth 2.0 provided social login functionality, allowing customers to authenticate using their existing Google accounts. The OAuth implementation follows the authorization code flow with PKCE

extension, using state and nonce parameters to prevent CSRF and replay attacks.

Gmail SMTP handles all outgoing email communications including account verification emails, password reset links, order status notifications, security alerts to administrators, and rental return reminders. The SMTP connection uses TLS encryption for secure email transmission.

The mysqldump utility was integrated for database backup operations, invoked through Python's subprocess module. Automated daily backups were scheduled via APScheduler (Advanced Python Scheduler) running as a background thread within the Flask application, with backup files maintained on the server for seven days.

3.3.5 System Architecture Diagram:

The following diagram illustrates the complete system architecture, showing the three-tier structure, security layer integration, external service connections, and data flow patterns:

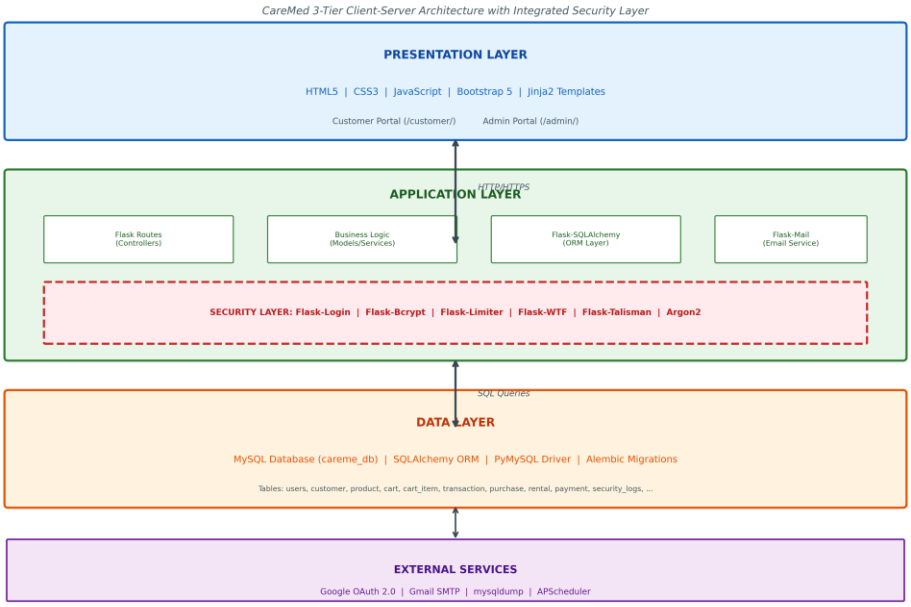


Figure 7. System Architecture Diagram – Three-Tier with Security Layer

3.4 Tools and Technologies Used

The selection of development tools and technologies for the CareMed system was guided by several criteria: technical capability to meet system requirements; security features and track record; availability of comprehensive documentation and community supported; compatibility with Philippine web hosting environments; and alignment with the skill sets of the development team. Each technology choice was evaluated against alternatives to ensured optimal fit for the project's specific requirements.

3.4.1 Programming Languages:

Language	Purpose and Justification
Python 3	Primary backend language for application logic, routing, security implementation, and database interaction. Selected for readable syntax and extensive library ecosystem.

Language	Purpose and Justification
HTML5	Markup language for page structure and semantic document organization.
CSS3	Style sheet language for visual presentation, responsive layouts, and cross-browser compatibility.
JavaScript	Client-side scripting for dynamic interactions, AJAX requests, and form validation feedback.
SQL	Database query language used through SQLAlchemy ORM for all data operations.

Table 2. Programming Languages Used

Python 3 was selected as the primary programming language for its clear, readable syntax that facilitates collaborative development and long-term maintenance. Python's extensive standard library and rich ecosystem of third-party packages provided comprehensive supported for web development, database interaction, security implementation, and task scheduling. The Flask micro-framework, built on Python's WSGI toolkit, offers a lightweight yet extensible foundation that allowed the development team to select purpose-specific libraries for each system requirement rather than inheriting bundled components that may not be needed [53].

HTML5, CSS3, and JavaScript handle all client-side presentation and interaction. HTML5 provided semantic document structure that supported accessibility requirements. CSS3 enabled responsive layout adaptation across device sizes through media queries and flexbox/grid layouts. JavaScript handles dynamic behaviors including cart management, form validation feedback, modal dialogs, and AJAX requests for partial page updates without full page reloads.

3.4.2 Frameworks and Libraries:

Framework/Library	Purpose
Flask 3.1.3	Web application framework providing routing, request handling, and session management.

Framework/Library	Purpose
Flask-SQLAlchemy	Object-Relational Mapping (ORM) for database abstraction and query building.
Flask-Migrate / Alembic	Database migration management for version-controlled schema changes.
Flask-Login	User session management and authentication state tracking.
Flask-WTF / WTForms	Form handling, server-side validation, and CSRF token protection.
Flask-Mail	Email sending capability for verification, notifications, and alerts.
Flask-Limiter	Rate limiting for brute-force protection and resource management.
Flask-Talisman	HTTP security headers enforcement (CSP, HSTS, X-Frame-Options).
Authlib	OAuth 2.0 client implementation for Google authentication.
argon2-cffi	Argon2 password hashing for secure credential storage.
APScheduler	Background task scheduling for automated database backups.
Pillow	Image processing for uploaded file validation.
Gunicorn	Production WSGI HTTP server for deployment.

Table 3. Frameworks and Libraries Used

3.4.3 Database Technology:

Component	Specification
DBMS	MySQL (MariaDB 10.4.32)
Database Name	careme_db
Driver	PyMySQL
ORM	SQLAlchemy (via Flask-SQLAlchemy)
Migration Tool	Alembic (via Flask-Migrate)
Connection Pooling	Enabled with pool_pre_ping
Tables	16 normalized tables

Table 4. Database Configuration

MySQL was selected as the relational database management system for its proven reliability, ACID compliance, wide adoption in Philippine web hosting environments, and seamless compatibility with the Flask/Python technology stack. All database interactions were performed through SQLAlchemy's ORM layer using parameterized queries, ensuring protection against SQL injection attacks regardless of user input content. Alembic, working through Flask-Migrate, provided version-controlled database schema migrations that can be applied incrementally and rolled back if necessary.

3.4.4 Development Tools:

Tool	Purpose
Visual Studio Code / Cursor	Integrated development environment (IDE)
Git	Distributed version control system
Python venv	Virtual environment for dependency isolation
pip	Python package installer
MySQL Workbench / CLI	Database management and query execution
Flask debug server	Local development server with auto-reload
python-dotenv	Environment variable configuration

Table 5. Development Tools

3.4.5 External Services:

Service	Protocol	Purpose
Google OAuth 2.0	HTTPS/OAuth 2	Social login with Google accounts
Gmail SMTP	TLS/SMTP	Email delivery for verification and alerts
mysqldump	Local CLI	Automated database backup utility

Table 6. External Service Integrations

The technology stack was chosen to created a complete, production-ready system while remaining accessible to small

enterprises with limited technical resources. All selected technologies were open-source and freely available, eliminating licensing costs that would otherwise be prohibitive for small businesses. The stack was well-documented with active communities, ensuring that future maintenance and enhancement can be performed without specialized expertise.

3.5 Data Gathering Techniques

The data gathering phase employed three complementary techniques to developed a comprehensive understanding of CareMed's operational environment: structured interviews with management and staff, direct observation of business processes, and document analysis of existing records. The triangulation of data from multiple sources enhanced the validity and reliability of the requirements analysis by cross-verifying information across different methods [54].

3.5.1 Interview:

A semi-structured faced-to-faced interview was conducted with CareMed's owner and operational staff at their business premises. The interview followed a prepared protocol covering six thematic areas while allowing for spontaneous follow-up questions to explore emerging topics in depth. The interview session lasted approximately two hours and was documented through detailed field notes.

Interview Protocol

The interview protocol was organized into the following thematic sections:

- Business Overview: Nature of operations, target customers, product categories, and service area coverage.

- Current Workflow: Step-by-step process for sales transactions, rental agreements, equipment returns, and inventory management.
- Operational Challenges: Difficulties encountered in daily operations, frequency and types of errors, and their impact on service quality.
- Record-Keeping Practices: Methods used for tracking inventory, customer information, rental durations, payments, and expenses.
- Customer Communication: Channels used for customer interaction, order placement, status updates, and complaint handling.
- Proposed Features: Desired system capabilities, priority functionality, and expectations for the digital system.

Key Interview Findings

The interview revealed several critical operational insights that directly shaped system design decisions. CareMed's customer base consists primarily of hospital discharge patients requiring home recovery equipment and cancer patients needing oxygen tanks and hospital beds for extended home care. All transactions were conducted through Facebook Messenger or in-person visits, requiring customers to physically visit the warehouse to view available products.

The rental process required customers to provided two valid IDs and proof of billing, with deposits varying based on delivery distance — the farther the location, the higher the deposit to cover retrieval costs. Rental duration monitoring follows a bi-monthly cycle with cut-offs on the 5th and 20th of each month for reconciling oxygen tank refills against supplier records from Prime Gas.

Payment tracking emerged as a significant pain point: payments made via GCash without accompanying notification messages required the owner to manually match transaction numbers, and verbal payment confirmations occasionally led to disputes when records were not immediately updated. The Excel-based tracking system, while functional at low volumes, became increasingly difficult to manage as the business grew, with occasional forgotten inventory reports and difficulty verifying oxygen tank counts before supplier refills.

3.5.2 Observation:

Direct observation of CareMed's operational environment was conducted during the on-site interview session. The research team observed the physical layout of the warehouse, the flow of customer interactions, the handling of rental equipment (particularly oxygen tanks), and the process of updating Excel records. Observational notes documented the workspace organization, equipment storage methods, customer service patterns, and the manual steps involved in completing a typical transaction.

Key observations included: the single-vehicle constraint for deliveries with reliance on tricycle drivers as backup for oxygen tank transport; the visual verification process for confirming empty oxygen tanks before replacement; the practice of photographing equipment and customer documents via mobile phone for Messenger-based transactions; and the manual counting of oxygen tanks before each Prime Gas refill to establish baseline consumption records.

3.5.3 Document Analysis:

Document analysis involved the examination of existing business records including Excel spreadsheets used for inventory tracking, rental duration monitoring, and expense recording. Analysis of these documents revealed the data structure and information flows underlying CareMed's manual

processes, as well as the types of errors and inconsistencies that occurred.

The Excel records showed: multiple worksheets tracking different aspects of operations (inventory, rentals, payments, expenses) without automated cross-referencing; manual calculation of rental durations and fees; inconsistent data entry formats across different record keepers; absence of audit trails or version history; and the complete reliance on the owner's knowledge for linking related records across different worksheets.

3.5.4 Requirements Specification:

Based on the combined findings from interviews, observation, and document analysis, a formal requirements specification was developed categorizing requirements into functional, non-functional, and security domains. The specification was organized using the following priority framework:

Category	Priority	Key Requirements
Functional	High	User registration/login, product catalog, cart/checkout, rental management, order tracking, payment processing
Non-Functional	High	Responsive design, concurrent user support, data integrity, automated backups
Security	High	Authentication, RBAC, session management, input validation, CSRF protection, XSS prevention, SQL injection prevention, audit logging

Table 7. System Requirements Summary

3.6 Testing Procedures

The CareMed system underwent comprehensive testing across five modalities to ensured functional correctness, security resilience, and usability. The testing approach was designed

to systematically verify that the system meets its specified requirements and operated reliably under realistic usage conditions. Each testing modality employed structured test cases with defined inputs, expected outputs, and pass/fail criteria.

3.6.1 Unit Testing:

Unit testing was performed manually during development to verify the correct behavior of individual functions and components in isolation. Each system module was tested as it was developed, with developers verifying that functions produced correct outputs for expected inputs and handled edge cases appropriately.

Authentication Module Unit Tests

ID	Test Case	Expected Result	Status
UT-A01	Valid user registration with email verification	Account created, verification email sent	Pass
UT-A02	Login with correct credentials	Successful authentication, session created	Pass
UT-A03	Login with incorrect password	Authentication failed, attempt logged	Pass
UT-A04	Account lockout after 5 failed attempts	Account locked for 15 minutes	Pass
UT-A05	Google OAuth login flow	Successful authentication via Google	Pass
UT-A06	Password reset via email	Reset link sent, password update successful	Pass
UT-A07	Session timeout after inactivity	Session expired, redirect to login	Pass

ID	Test Case	Expected Result	Status
UT-A08	Logout and session destruction	Session cleared, cookies removed	Pass

Table 8. Authentication Module Unit Test Cases

Inventory Module Unit Tests

ID	Test Case	Expected Result	Status
UT-I01	Add new product with valid data	Product created with correct fields	Pass
UT-I02	Update product stock quantity	Stock updated, inventory log created	Pass
UT-I03	Deduct stock on order confirmation	Quantity reduced, log entry created	Pass
UT-I04	Restore stock on rental return	Quantity restored, status updated	Pass
UT-I05	Archive product (soft delete)	Product hidden but data preserved	Pass
UT-I06	Low stock alert generation	Alert triggered when below threshold	Pass

Table 9. Inventory Module Unit Test Cases

Order Processing Unit Tests

ID	Test Case	Expected Result	Status
UT-O01	Add items to cart (sale)	Cart updated with correct items and totals	Pass
UT-O02	Add items to cart (rental)	Cart updated with deposit calculation	Pass
UT-O03	Checkout with COD payment	Order created with COD status	Pass
UT-O04	Checkout with	Order created, payment	Pass

ID	Test Case	Expected Result	Status
	GCash payment	proof upload requested	
UT-O05	Order tracking status update	Status progresses through workflow correctly	Pass
UT-O06	Payment proof upload and verification	Proof stored, payment status updated	Pass

Table 10. Order Processing Unit Test Cases

3.6.2 Integration Testing:

Integration testing verified the correct interaction between system modules and the accuracy of data flows across component boundaries. Test scenarios were designed to exercise the complete pathways that data follows through the system, from initial input through processing to final output.

ID	Integration Point	Test Scenario	Status
IT-01	Auth + Database	User registration stores data, retrieves on login	Pass
IT-02	Cart + Inventory	Adding to cart reflects available stock correctly	Pass

ID	Integration Point	Test Scenario	Status
IT-03	Order + Payment	Order creation triggers correct payment workflow	Pass
IT-04	Rental + Invoice	Rental checkout generates monthly invoice entries	Pass
IT-05	Auth + Security Log	Login events recorded in security_logs table	Pass
IT-06	Payment + Inventory	Confirmed payment deducts stock accurately	Pass
IT-07	Return + Inventory	Rental return restores items to available stock	Pass

Table 11. Integration Test Cases

3.6.3 System Testing:

System testing evaluated the complete application as an integrated whole, verifying that all modules function correctly together and that the system satisfies its overall requirements. End-to-end test scenarios were executed following the actual operational workflows identified during the requirements gathering phase.

ID	Scenario	Expected Outcome	Status
ST-01	Complete customer purchase workflow	Order placed, payment confirmed, inventory updated	Pass
ST-02	Complete rental workflow with return	Rental created, invoice generated, return	Pass

ID	Scenario	Expected Outcome	Status
		processed	
ST-03	Admin inventory management workflow	Products added, stock adjusted, reports generated	Pass
ST-04	Security incident and response workflow	Attack detected, IP blocked, admin notified	Pass
ST-05	Daily automated backup execution	Backup file created at scheduled time	Pass

Table 12. System Test Cases

3.6.4 Security Testing:

Security testing was structured around the OWASP Top 10 [55] framework to systematically verify the system's resistance to the most critical and commonly exploited web application security risks. Each OWASP category was addressed through specific test cases designed to confirm the effectiveness of implemented security controls.

OWASP ID	Category	Test Case	Status
A01	Broken Access Control	Verify RBAC prevents unauthorized endpoint access	Pass
A02	Cryptographic Failures	Verify Argon2 hashing, HTTPS enforcement, secure cookies	Pass
A03	Injection	Verify SQL injection prevention via parameterized queries	Pass

OWASP ID	Category	Test Case	Status
A04	Insecure Design	Verify security-by-design architecture and defense in depth	Pass
A05	Security Misconfiguration	Verify Flask-Talisman headers, debug mode disabled	Pass
A06	Vulnerable Components	Verify all dependencies updated to latest stable versions	Pass
A07	Auth Failures	Verify account lockout, session timeout, secure password policy	Pass
A08	Integrity Failures	Verify CSRF tokens on all state-changing operations	Pass
A09	Logging Failures	Verify security event logging and admin notification system	Pass
A10	SSRF	Verify URL validation on external service integrations	Pass

Table 13. OWASP Top 10 Security Test Cases

3.6.5 User Acceptance Testing (UAT):

User Acceptance Testing was conducted with representative participants from both Administrator and Customer user roles to validate that the system meets operational needed and usability expectations. UAT participants performed structured test scenarios derived from CareMed's actual business workflows, with findings documented through observation forms and feedback questionnaires.

ID	User Role	Scenario	Success Criteria	Status
UAT-01	Customer	Register account and verify email	Account activated within 2 minutes	Pass
UAT-02	Customer	Browse products and add to cart	Correct items, prices, and quantities	Pass

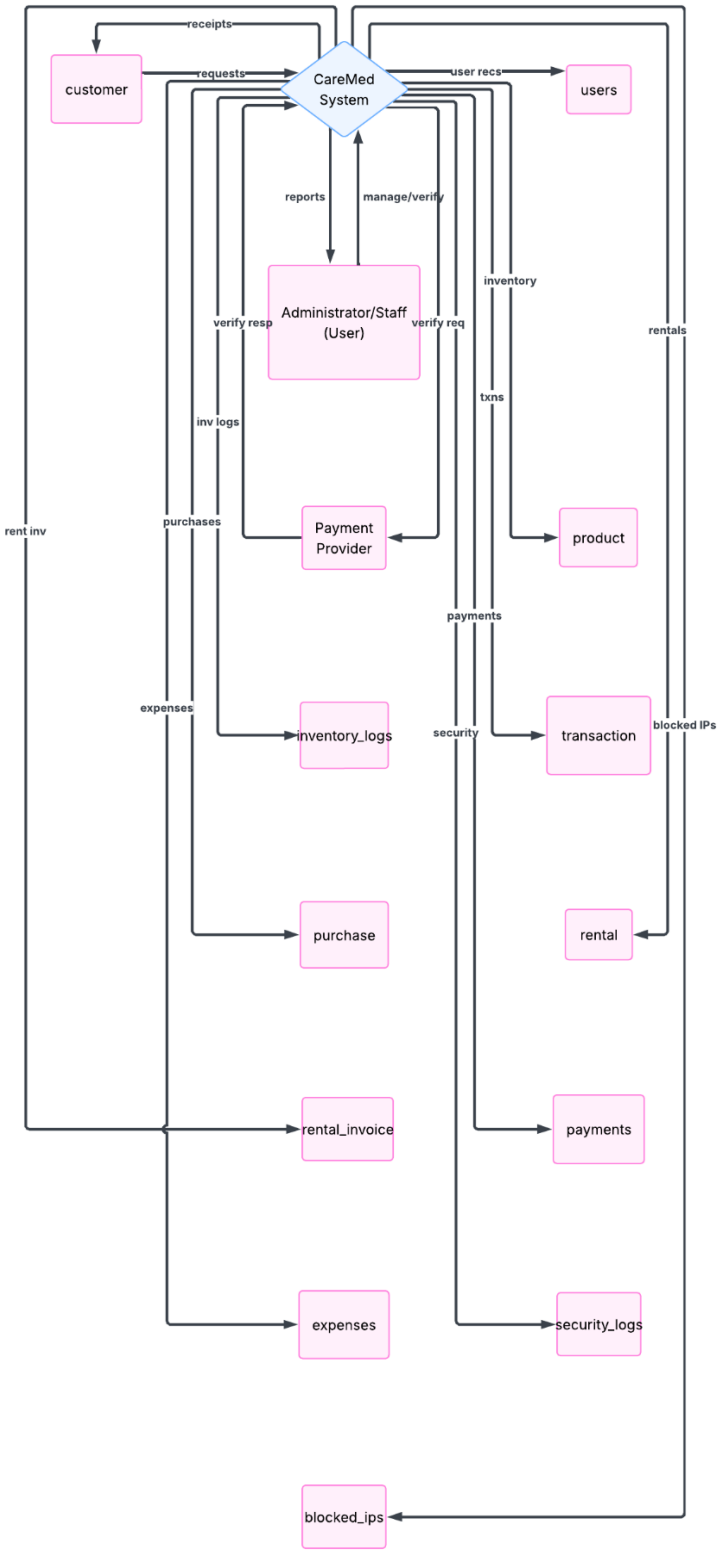
ID	User Role	Scenario	Success Criteria	Status
UAT-03	Customer	Complete rental checkout with ID upload	Order placed, deposit calculated correctly	Pass
UAT-04	Customer	Upload GCash payment proof	File accepted, payment status updated	Pass
UAT-05	Customer	Track order status	Real-time status display accurate	Pass
UAT-06	Admin	Process walk-in sale	Transaction recorded, inventory updated	Pass
UAT-07	Admin	Update order tracking status	Status updated, customer sees change	Pass
UAT-08	Admin	View security center and blocked IPs	All security events visible	Pass

Table 14. User Acceptance Test Scenarios

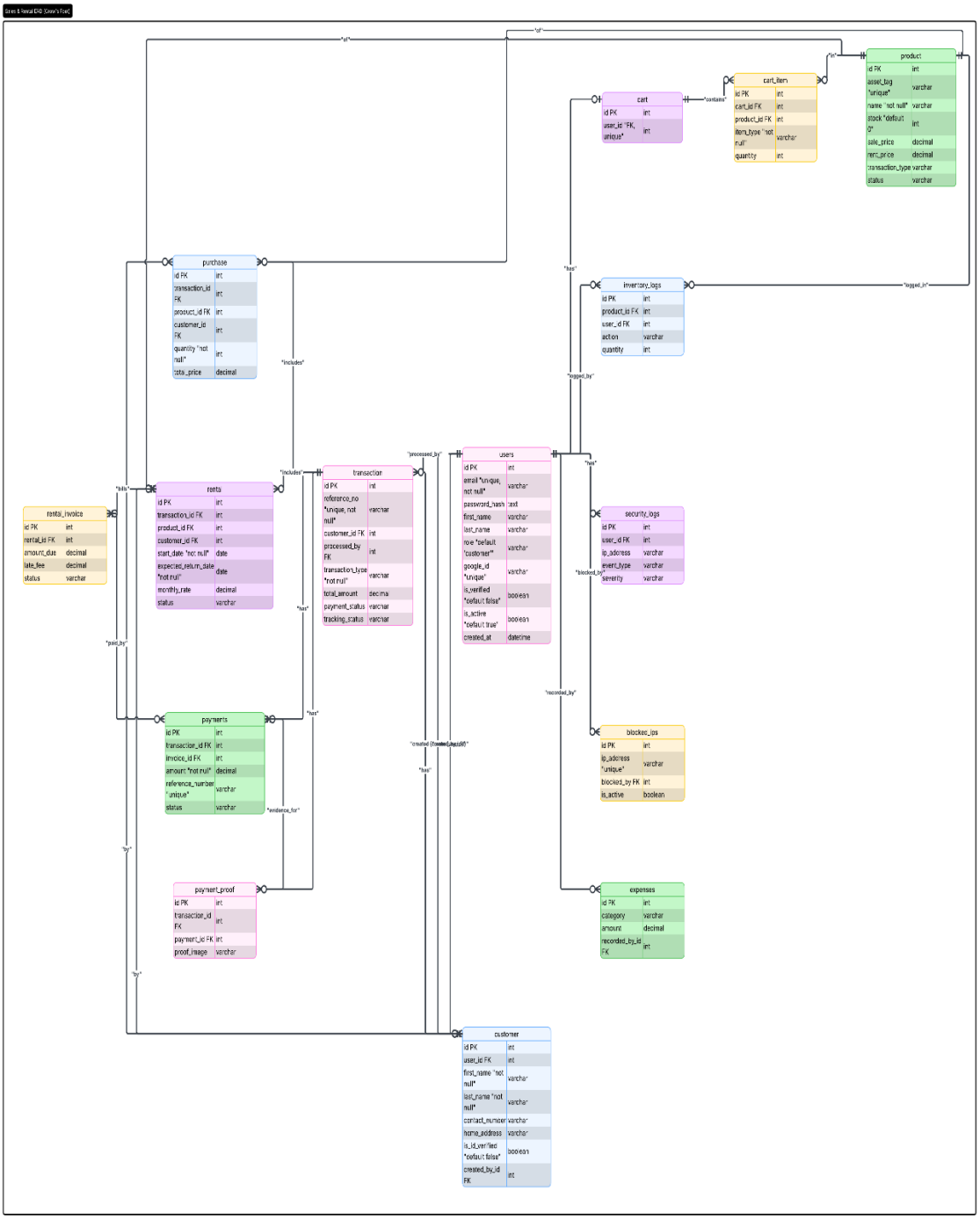
System Diagrams

The following diagrams provided visual representations of the system's data flows, database structure, user interactions, and architectural organization:

Data Flow Diagrams

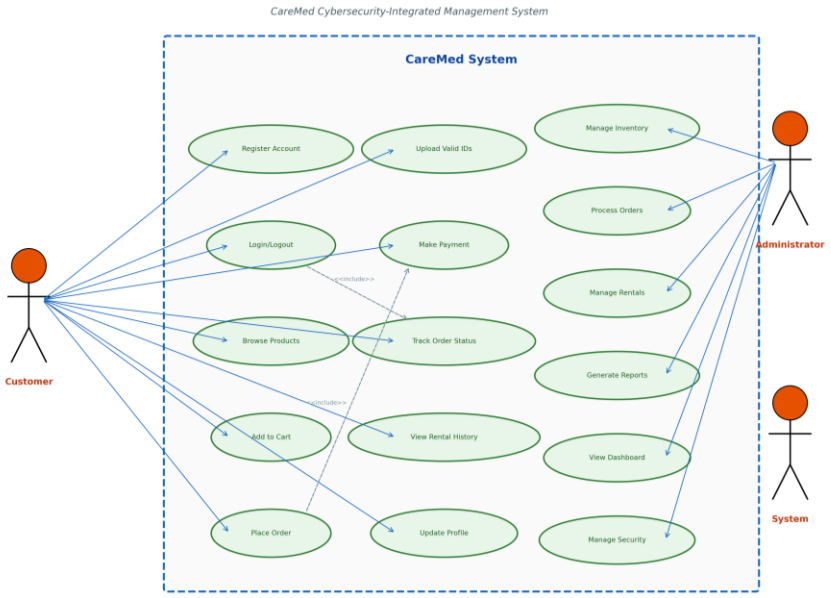


Data Flow Diagram Level 0 (Context Diagram)Entity Relationship Diagram



Entity Relationship Diagram (ERD) - Complete Database Schema

Use Case Diagram



Use Case Diagram - System Actors and Use Cases

REFERENCES

[50] R. C. Richey and J. D. Klein, "Developmental research methods: Creating knowledge from instructional design and development practice," J. Comput. Higher Educ., vol. 16, no. 2, pp. 23–38, 2005.

[51] K. Beck et al., "Manifesto for Agile software development," Agile Alliance, 2001. [Online]. Available: https://agilemanifesto.org/

[52] W. Stallings, Network Security Essentials: Applications and Standards, 6th ed. Boston, MA, USA: Pearson, 2018.

[53] A. Ronacher, "Flask (web framework)," Pallets Projects, 2010. [Online]. Available: https://flask.palletsprojects.com/

[54] J. W. Creswell and J. D. Creswell, Research Design: Qualitative, Quantitative, and Mixed Methods Approaches, 5th ed. Thousand Oaks, CA, USA: SAGE, 2018.

[55] OWASP Foundation, "OWASP Top 10:2021," 2021. [Online]. Available: https://owasp.org/www-project-top-ten/

CHAPTER IV

SYSTEM DEVELOPMENT, IMPLEMENTATION, TESTING, EVALUATION, RESULTS, AND DISCUSSION

4.1 Overview of the Developed System

CareMed is a web-based, mobile-responsive management information system developed for CareMed Medical Supply Enterprise. The system replaces manual spreadsheet and paper-based processes with a centralized MySQL database and a Flask web application that supports real-time inventory visibility, sales and rental transactions, customer verification, payment tracking, operational reporting, and integrated cybersecurity monitoring. Unlike generic inventory or point-of-sale applications, CareMed was designed with business automation and information security as co-equal priorities: authentication, authorization, input validation, audit logging, and intrusion-detection-style monitoring are embedded in the application core.

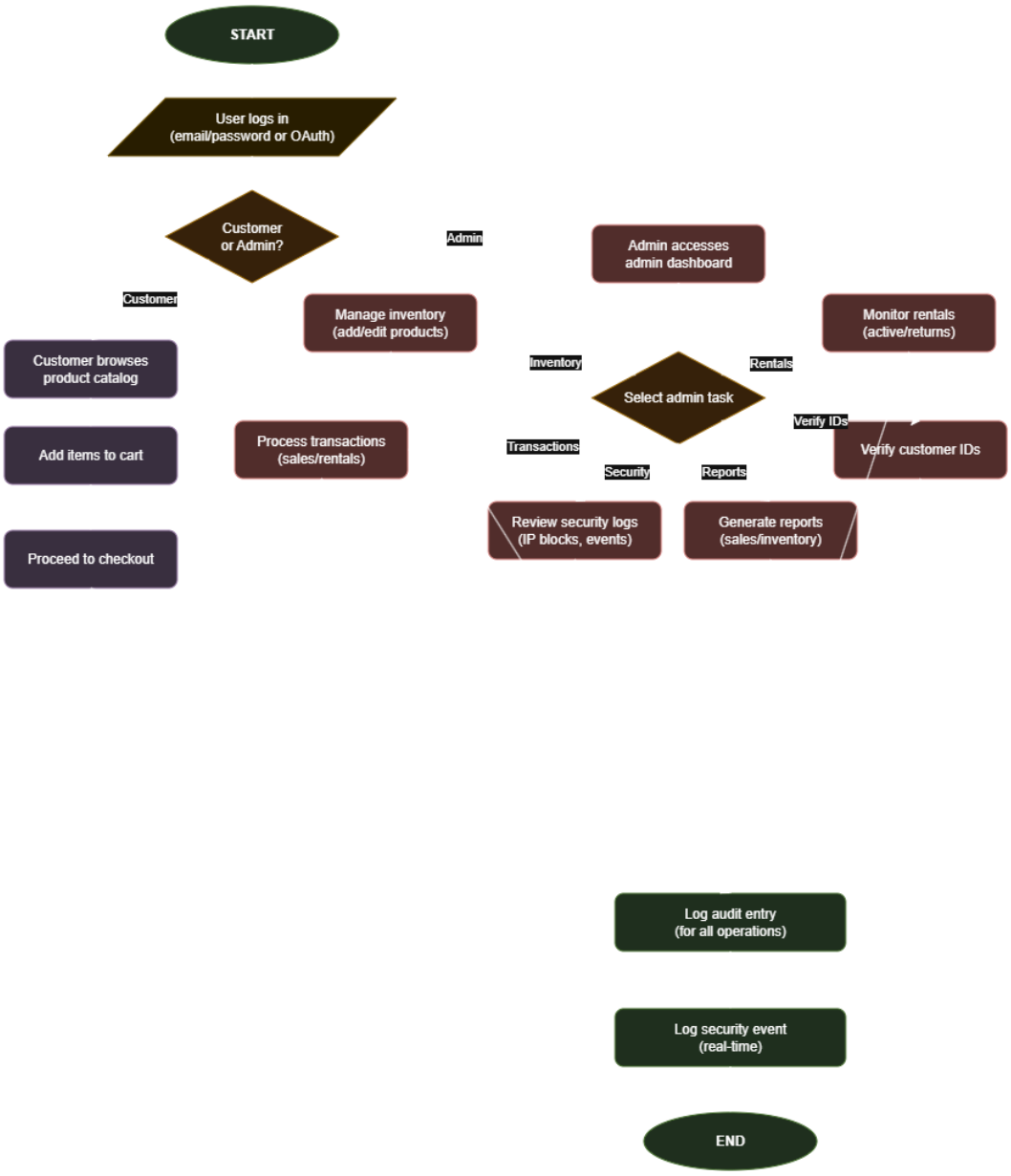
The major functional objectives realized in the developed system include:

- Automating inventory movements (stock-in, stock-out, adjustments) with chronological inventory logs per product.
- Supporting product catalog browsing for customers with sale and rental options, shopping cart, and online checkout.
- Processing walk-in and online sales and rentals, including delivery tracking and rental invoicing with monthly billing periods.
- Managing customer records, valid-ID verification, and linked user accounts for the customer portal.

- Recording payments, payment proofs, partial payments, and administrator confirmation workflows.
- Supporting specialized medical-supply operations such as refillable tank tracking (TankStatus), refill transactions, and PrimeGas processing.
- Generating administrator dashboards, financial and inventory reports, expense records, and exportable transaction data.
- Implementing staff accounts with granular permissions, security event logs, IP blocking, rate limiting, and scheduled database backups.

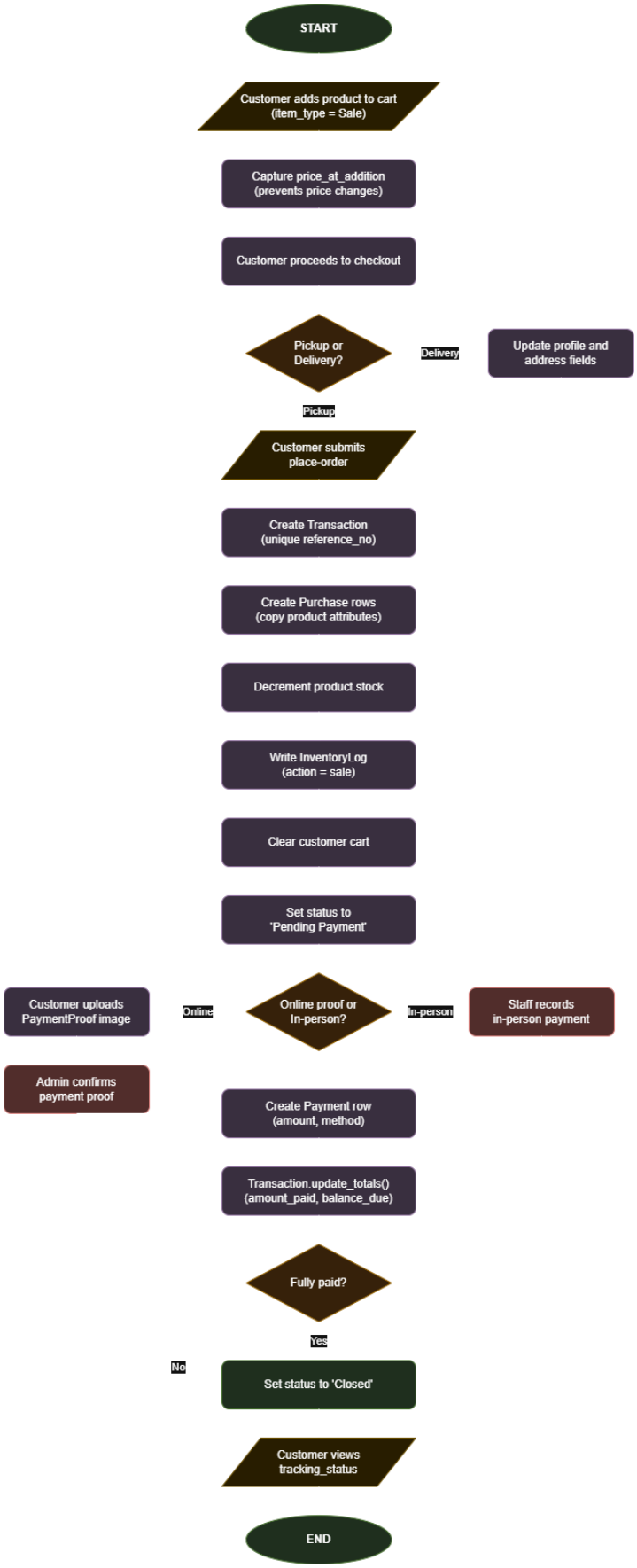
4.1.1 System Workflow:

The workflow begins with user authentication. Once authenticated, customers browse the product catalog, add items to the cart, and proceed to checkout. Administrators access the admin dashboard to manage inventory, process transactions, verify customer IDs, monitor rentals, review security logs, and generate reports. All significant operations trigger audit entries, and security events are logged in real time.



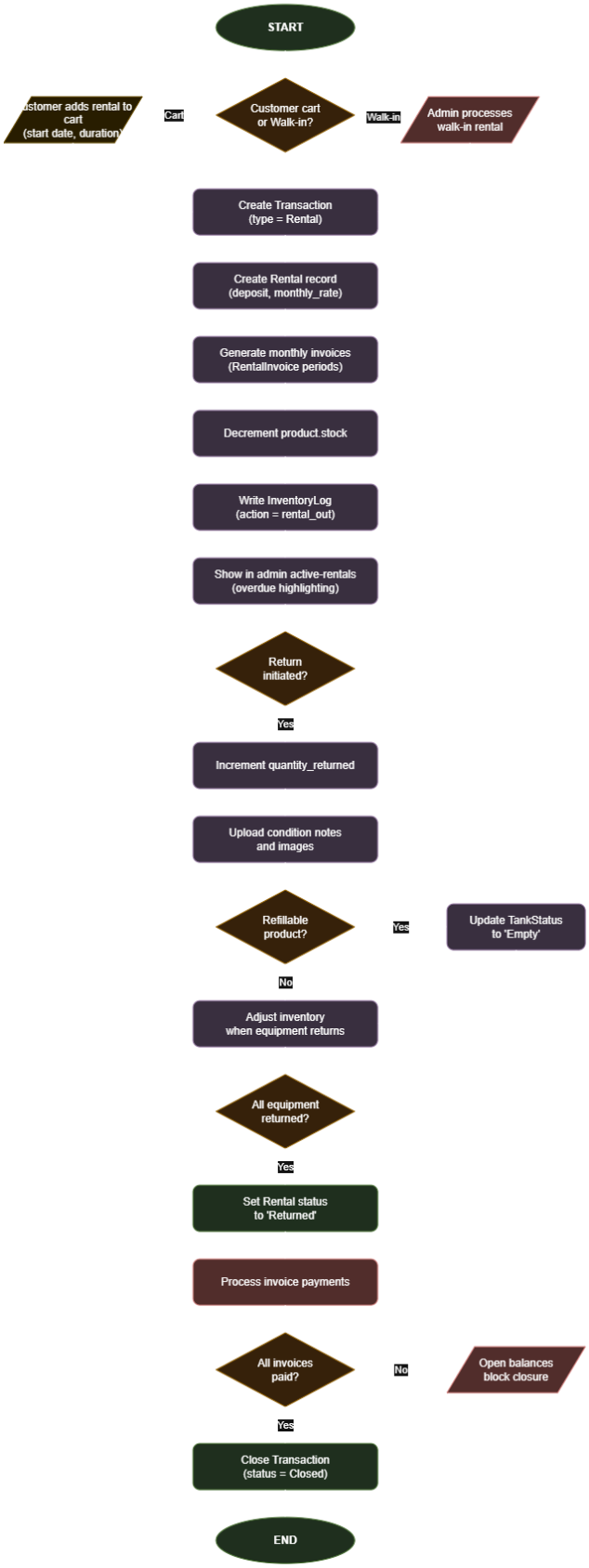
4.1.2 Sale Transaction Processing Flow:

An online sale begins when an authenticated customer adds products to the Cart with item_type set to Sale. The cart route aggregates line totals using price_at_addition captured at add-to-cart time to prevent silent price changes during checkout. At checkout, the customer confirms fulfillment type (pickup/walk-in versus delivery), optionally updates profile and address fields, and submits place-order. The server creates a Transaction with a unique reference_no, associated Purchase rows copying product attributes for auditability, decrements product.stock, and writes InventoryLog actions. Payment may remain Unpaid until the customer uploads PaymentProof or staff records payment in person. Administrators use confirm-payment-proof or post-payment to create Payment rows; Transaction.update_totals recalculates amount_paid, balance_due, and payment_status. When fully paid and fulfillment rules are satisfied, status transitions to Closed. Customers monitor progress via tracking_status on the user dashboard.


START
Customer adds product to cart (item_type = Sale)
Capture price_at_addition (prevents price changes)
Customer proceeds to checkout
Pickup or Delivery?
Delivery
Update profile and address fields
Pickup
Customer submits place-order
Create Transaction (unique reference_no)
Create Purchase rows (copy product attributes)
Decrement product.stock
Write InventoryLog (action = sale)
Clear customer cart
Set status to 'Pending Payment'
Customer uploads PaymentProof image
Online
Online proof or In-person?
In-person
Staff records in-person payment
Admin confirms payment proof
Create Payment row (amount, method)
Transaction.update_totals() (amount_paid, balance_due)
Fully paid?
Yes
No
Set status to 'Closed'
Customer views tracking_status
END

4.1.3 Rental Transaction Processing Flow:

Rentals may originate from the customer cart (with rental_start_date and rental_duration) or from administrator process-rental for walk-in clients. Creating a rental inserts Rental linked to a rental-type Transaction, captures deposit and monthly_rate, and invokes generate_monthly_invoices to create RentalInvoice periods. Active rentals appear in admin active-rentals with overdue highlighting based on dates and payment status. Returns use transaction return routes to increment quantity_returned, upload condition notes/images, and adjust inventory when equipment re-enters stock. Late fees may be applied at invoice level. Closure requires returned equipment and paid invoices, enforcing the business rule that open balances block complete closure.


START
ustomer adds rental to cart (start date, duration)
Cart
Customer cart or Walk-in?
Walk-in
Admin processes walk-in rental
Create Transaction (type = Rental)
Create Rental record (deposit, monthly_rate)
Generate monthly invoices (RentalInvoice periods)
Decrement product.stock
Write InventoryLog (action = rental_out)
Show in admin active-rentals (overdue highlighting)
Return initiated?
Yes
Increment quantity_returned
Upload condition notes and images
Refillable product?
Yes
Update TankStatus to 'Empty'
No
Adjust inventory when equipment returns
All equipment returned?
Yes
Set Rental status to 'Returned'
Process invoice payments
All invoices paid?
No
Open balances block closure
Yes
Close Transaction (status = Closed)
END

4.2 System Development Methodology

Development followed the Agile software development methodology with Scrum-inspired sprints, as specified in Chapter 3. Requirements were gathered through interviews, observation, and document analysis at CareMed; each sprint delivered testable increments that were reviewed before the next iteration. Security requirements were maintained in a dedicated security backlog and addressed in parallel with functional stories, consistent with security integration best practices for SMEs.

The lifecycle phases implemented in this project were:

4.2.1 Requirements Gathering:

Requirements gathering was conducted through a semi-structured face-to-face interview with CareMed's owner and operational staff at their business premises. The interview protocol covered business overview, current workflow, operational challenges, record-keeping practices, customer communication, and proposed features. Key findings revealed that CareMed's customer base consists primarily of home-based care patients and small clinics requiring durable medical equipment such as wheelchairs, hospital beds, and oxygen concentrators. The business operates combined sales and rental workflows with a small staff team without dedicated IT personnel. Current record-keeping relied on physical notebooks and spreadsheet tabs, creating vulnerability to version conflicts and data loss. The interview identified critical pain points: inability to track rental equipment returns systematically, no real-time inventory visibility, complete absence of cybersecurity controls, and labor-intensive report generation requiring hours of manual compilation. These findings directly shaped the six-module system architecture and the decision to

integrate cybersecurity as a foundational requirement rather than an afterthought.

4.2.2 System Planning:

System planning established the project scope, objectives, and technical specifications based on the interview findings. The scope encompassed six integrated modules: Inventory Management, Customer Management, Order and Sales Processing, Rental Tracking, Reports and Dashboard, and Cybersecurity. The target user population comprised two roles reflecting CareMed's organizational structure: Administrator-role users (management and authorized staff) and Customer-role users (registered customers with portal access). The technical platform was selected based on criteria of technical capability, Philippine hosting compatibility, and SME accessibility: Python 3 with Flask as the application server, MySQL as the relational database, SQLAlchemy ORM for database abstraction, Bootstrap 5 for responsive design, and Flask-Login for authentication. External service integrations included Google OAuth 2.0 for social login, Gmail SMTP for email communications, and mysqldump for database backups. The planning phase also defined delimitations: the system was web-based without native mobile apps, did not include direct payment gateway integration, operated as a standalone platform without healthcare system integration, and addressed development through testing without extending to post-deployment maintenance.

4.2.3 Software Development:

Software development followed the Agile methodology with seven iterative phases. Phase 0: Planning and Requirements Gathering involved workflow analysis and formal requirements specification through interviews and observation. Phase 1: Database Design and Core Setup established SQLAlchemy models, Flask application factory pattern, and Alembic migrations.

Phase 2: Authentication and User Management implemented registration, email verification, login, Google OAuth, password reset, and role-based access control using Flask-Login. Phase 3: Inventory and Product Catalog developed real-time stock tracking, product categorization, search, filtering, and inventory logs with TankStatus for oxygen/refill workflows. Phase 4: Cart, Order, and Payment System created customer cart functionality, checkout processing, payment proof upload for GCash transactions, and administrator payment confirmation workflows. Phase 5: Rental Management and Invoicing built rental agreements, monthly rental invoice generation, return processing, and active rental monitoring with late fee calculation. Phase 6: Security, Reports, and Dashboard implemented security event logging, IP blocking, rate limiting, bot detection, Flask-Talisman security headers, administrator KPI dashboards, financial and inventory reports, and automated daily database backups. Phase 7: Testing and Quality Assurance conducted unit, integration, system, OWASP-oriented security testing, and User Acceptance Testing.

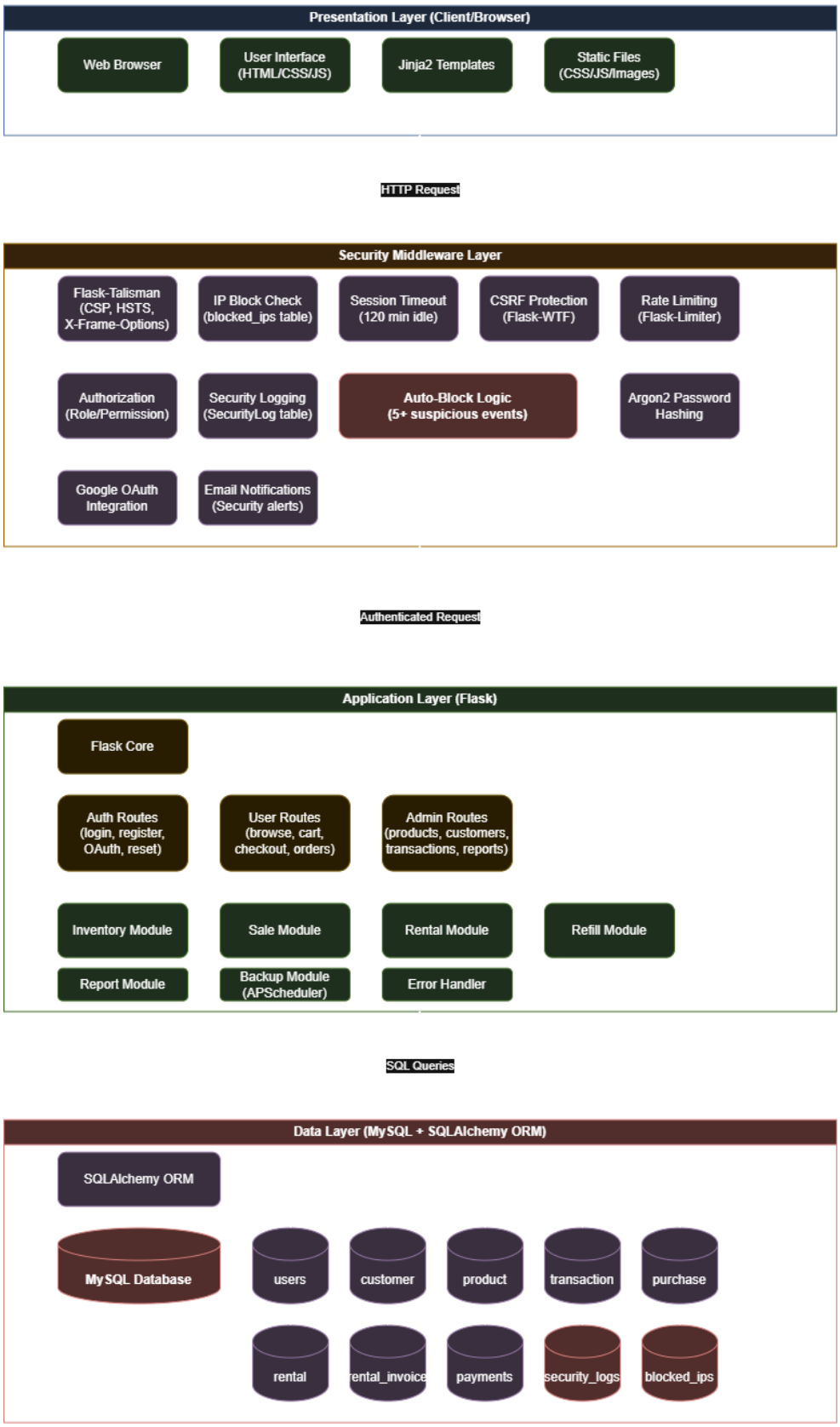
4.2.4 Testing:

Testing was conducted across five modalities as specified in Chapter 1, Objective 4 and detailed in Chapter 3, Section 3.6. Unit testing was performed manually during development to verify the correct behavior of individual functions and components in isolation, including authentication module tests, inventory module tests, and order processing tests. Integration testing verified the correct interaction between system modules and the accuracy of data flows across component boundaries. System testing evaluated the complete application as an integrated whole, verifying that all modules function correctly together and that the system meets specified requirements. Security testing was structured around the OWASP Top 10 [56] framework to systematically verify the system's

resistance to the most critical web application security risks, including broken access control, cryptographic failures, injection, insecure design, security misconfiguration, and security logging failures. User Acceptance Testing was conducted with representative participants from both Administrator and Customer user roles to validate that the system meets user expectations and business requirements through scenario-based tasks, think-aloud observation, and post-task questionnaires aligned with ISO/IEC 25010 quality dimensions.

4.3 System Architecture

CareMed implements a three-tier client–server architecture combined with the Model–View–Controller (MVC) pattern. The presentation tier consists of HTML5, CSS3, Bootstrap 5, and Jinja2 templates rendered in the user's browser. The application tier is implemented in Python 3 using Flask 3.x route handlers (controllers), WTForms for server-side validation, Flask-Login for session management, Flask-WTF for CSRF protection, Flask-Limiter for rate limiting, Flask-Talisman for security headers and Content Security Policy, and Authlib for Google OAuth 2.0 integration. The data tier is a MySQL relational database accessed exclusively through SQLAlchemy ORM with parameterized queries.


Presentation Layer (Client/Browser)
Web Browser
User Interface (HTML/CSS/JS)
Jinja2 Templates
Static Files (CSS/JS/Images)
HTTP Request
Security Middleware Layer
Flask-Talisman (CSP, HSTS, X-Frame-Options)
IP Block Check (blocked_ips table)
Session Timeout (120 min idle)
CSRF Protection (Flask-WTF)
Rate Limiting (Flask-Limiter)
Authorization (Role/Permission)
Security Logging (SecurityLog table)
Auto-Block Logic (5+ suspicious events)
Argon2 Password Hashing
Google OAuth Integration
Email Notifications (Security alerts)
Authenticated Request
Application Layer (Flask)
Flask Core
Auth Routes (login, register, OAuth, reset)
User Routes (browse, cart, checkout, orders)
Admin Routes (products, customers, transactions, reports)
Inventory Module
Sale Module
Rental Module
Refill Module
Report Module
Backup Module (APScheduler)
Error Handler
SQL Queries
Data Layer (MySQL + SQLAlchemy ORM)
SQLAlchemy ORM
MySQL Database
users
customer
product
transaction
purchase
rental
rental_invoice
payments
security_logs
blocked_ips

4.3.1 Primary Architectural Components:

- **Presentation Layer:** User and admin templates under templates/user and templates/admin; responsive layouts for desktop and mobile.
- **Application Layer:** Blueprints auth_bp, user_bp, and admin_bp; decorators for admin/staff access and fine-grained Permission checks.
- **Data Layer:** Normalized relational schema with foreign keys, cascade rules, and inventory and security audit tables.
- **Cross-cutting Security:** before_request IP block check, admin idle session timeout (120 minutes), CSRF on state-changing forms, CSP via Talisman.

4.3.2 Request Processing Flow:

Each HTTP request passes through an ordered pipeline before reaching blueprint handlers. Flask-Talisman applies security headers and Content Security Policy. The check_blocked_ip before_request handler queries blocked_ips for the client address and aborts with 403 when an active block applies. For authenticated administrators, enforce_admin_session_timeout compares the session last_active timestamp against a 120-minute idle threshold, logging Admin Session Expired when forcing logout. Flask-Login loads the user; CSRF validation runs on applicable POST requests; Flask-Limiter enforces per-route limits (for example, five login POST attempts per five minutes). Route decorators (login_required, admin_or_staff_required, permission_required) enforce authorization. Successful handlers invoke SQLAlchemy for persistence and render Jinja2 templates or JSON for AJAX endpoints such as admin notifications.

4.3.3 Security Architecture:

The security architecture maps to controls described in Chapters 1 and 2: identification and authentication (Flask-Login, Google OAuth, email verification); authorization (role plus Permission flags); session management (secure cookies, strong session protection, admin idle timeout); input validation (WTForms, type coercion, secure filename for uploads); output encoding (Jinja2 auto-escaping); cryptographic protection (Argon2 password hashes, signed timed tokens for reset and verification); logging and monitoring (SecurityLog, rate-limit handler logging); and availability-related measures (backups, pool_pre_ping on database connections).

4.4 Software and Hardware Requirements

4.4.1 Hardware Requirements:

Component	Minimum Specification	Recommended Specification
Client (user/admin)	Dual-core CPU, 4 GB RAM	Quad-core CPU, 8 GB RAM
Network	Stable internet for web access	Broadband connection
Server (development/deployment)	2 vCPU, 2 GB RAM	2+ vCPU, 4 GB RAM, SSD storage

Table 4.1: Hardware Requirements

4.4.2 Software Requirements:

Category	Technology	Purpose

Language / runtime	Python 3.11+	Application server
Web framework	Flask 3.1	HTTP routing, templates, sessions
ORM / DB	SQLAlchemy 2.x, Flask-Migrate,MySQL (PyMySQL)	Data persistence and migrations
Authentication	Flask-Login,Argon2 (argon2-cffi)	Sessions and password hashing
Security	Flask-WTF, Flask-Talisman, Flask-Limiter	CSRF, headers/CSP, rate limiting
OAuth / email	Authlib, Flask-Mail	Google sign-in, verification and reset mail
Scheduling	APScheduler	Daily automated database backup
Frontend	Bootstrap 5, Jinja2	Responsive UI
Deployment	Gunicorn, Docker (optional)	Production WSGI container
Version control	Git	Sprint history and collaboration
IDE	Visual Studio Code	Development environment

Table 4.2: Software Requirements

4.5 Database Design

The database uses a relational model in MySQL. Normalization reduces redundant product and customer snapshots while transaction tables preserve point-in-time product attributes on purchases for historical accuracy. The schema consists of 16 core entities (as specified in Chapter 3, Phase 1), designed to Third Normal Form (3NF) with explicit foreign key constraints.

4.5.1 Core Entities and Relationships:

Entity / Table	Primary Purpose	Key Relationships
users	Accounts (Administrator, Staff, Customer)	Links to customer, permissions, security_logs
permissions	Staff RBAC flags	One-to-one with staff users
customer	Customer profile and ID verification	user_id, purchases, rentals, transactions
product	Sale/rental catalog and stock	purchases, rentals, inventory_logs, tank_status
tank_status	Refillable tank counts (full/empty/rented)	One-to-one with refillable products
transaction	Sale or rental header, payment status	purchases, rentals, payments, payment_proof
purchase	Line items for sales	transaction, product, customer
rental	Rental agreements and returns	transaction, rental_invoice, product
rental_invoice	Periodic rental billing	rental, payments
payments / payment_proof	Payment records and proof images	transaction
refill_transaction	Gas/refill operations	product, customer, processor
inventory_logs	Stock movement audit trail	product, user
expenses	Operational expenses	product (optional), recorded_by
cart / cart_item	Customer session cart	user, product
product_reviews	Customer product ratings	product, user
security_logs	Security and IDS events	user (optional)

blocked_ips	Active IP blocks	blocked by admin

Table 4.3: Core Database Entities

4.5.2 Detailed Table Specifications:

users Table

Field	Type	Description
user_id	INT, PK, AUTO_INCREMENT	Unique account identifier
email	VARCHAR(120), UNIQUE	Login email address
password_hash	VARCHAR(255)	Argon2id hashed password
role	ENUM('Administrator','Staff','Customer')	System role
is_verified	BOOLEAN, DEFAULT FALSE	Email verification status
is_active	BOOLEAN, DEFAULT TRUE	Account lockout status
failed_login_attempts	INT, DEFAULT 0	Counter for lockout policy
last_active	TIMESTAMP	Last session activity (admin timeout)
created_at	TIMESTAMP	Account creation date

customer Table

Field	Type	Description
customer_id	INT, PK, AUTO_INCREMENT	Unique customer identifier
user_id	INT, FK → users	Linked portal account (optional)
full_name	VARCHAR(150)	Customer full name
phone	VARCHAR(20)	Contact number (masked in UI)
address	TEXT	Delivery/billing address
id_verification_status	ENUM	Pending, Verified, Rejected
id_document_path	VARCHAR(255)	Uploaded valid ID file path
created_at	TIMESTAMP	Record creation date

product Table

Field	Type	Description
product_id	INT, PK, AUTO_INCREMENT	Unique product identifier
name	VARCHAR(200)	Product name
description	TEXT	Detailed description
category	VARCHAR(100)	Product category
sale_price	DECIMAL(10,2)	Price for outright purchase
rental_price	DECIMAL(10,2)	Monthly rental rate
stock_quantity	INT	Current available stock
reorder_threshold	INT	Low-stock alert trigger level
is_rentable	BOOLEAN	Available for rental flag
is_refillable	BOOLEAN	Oxygen/tank refill flag

image_path	VARCHAR(255)	Product image file path
is_active	BOOLEAN	Soft-delete / archive flag

transaction Table

Field	Type	Description
transaction_id	INT, PK, AUTO_INCREMENT	Unique transaction identifier
reference_no	VARCHAR(50), UNIQUE	Human-readable order reference
customer_id	INT, FK → customer	Associated customer
transaction_type	ENUM('Sale','Rental')	Transaction classification
fulfillment_type	ENUM('Pickup','Delivery')	Delivery method
total_amount	DECIMAL(10,2)	Computed grand total
amount_paid	DECIMAL(10,2)	Sum of confirmed payments
balance_due	DECIMAL(10,2)	Remaining obligation
payment_status	ENUM	Unpaid, Partial, Paid
status	ENUM	Submitted, Verified, Shipped, Delivered, Closed
tracking_status	VARCHAR(100)	Customer-visible tracking state
created_at	TIMESTAMP	Transaction creation date

4.6 Deployment and Configuration

Environment variables were loaded from .env (see env.example): SECRET_KEY, DATABASE_URL, Google OAuth credentials, and mail credentials. Production used config.Config with secure cookies and HTTPS enforcement; development used DevConfig. The Dockerfile packaged the application with Gunicorn binding to

port 5000. Database schema evolution was managed through Flask-Migrate (Alembic) under the migrations directory.

4.7 Testing, Evaluation, and Results

Testing followed the five modalities defined in Chapter 1, Objective 4, and detailed in Chapter 3, Section 3.6: unit, integration, system, security (OWASP Top 10–oriented manual tests), and User Acceptance Testing (UAT). Each test cycle produced documented test cases with expected and actual results.

4.7.1 Unit Testing:

Unit-level verification focused on model methods and helpers.

Unit ID	Component	Input / Action	Expected Output	Result
UNI-01	RentalInvoice.remaining_balance	Partial payment recorded	Non-negative balance	Pass
UNI-02	User.masked_email	user@example.com	u***r@example.com pattern	Pass
UNI-03	verify_reset_token	Expired token	None returned	Pass
UNI-04	Transaction.update_totals	Fully paid sale walk-in	status Closed when rules met	Pass
UNI-05	TankStatus.calculate_refill_need	Empty tanks > full tanks	Refill quantity returned	Pass

Table 4.4: Unit Test Results

4.7.2 Integration Testing:

Integration tests validated cross-module flows.

INT ID	Modules Involved	Scenario	Result
INT-01	Checkout + Product + InventoryLog	Online sale decreases stock	Pass
INT-02	Rental + RentalInvoice + Transaction	New rental generates invoices	Pass
INT-03	Payment + Transaction	Admin confirms proof	Pass
INT-04	Security + before_request	Block IP then browse site	403 / block page
INT-05	Refill + TankStatus	Refill updates tank counts	Pass

Table 4.5: Integration Test Results

4.7.3 System Testing:

Test ID	Scenario	Expected Result	Result
SYS-01	Customer registers and verifies email	Account created; login enabled after verification	Pass
SYS-02	Customer adds sale item and	Transaction and purchase	Pass

	checks out	created; stock decreased	
SYS-03	Customer rental with monthly billing	Rental invoices generated per period	Pass
SYS-04	Admin verifies customer ID	is_id_verified set; customer notified in UI	Pass
SYS-05	Staff without permission opens reports	Access denied; security log entry	Pass
SYS-06	Export transactions to spreadsheet	Downloadable file with transaction rows	Pass
SYS-07	Scheduled backup job	Backup file created in backup store	Pass

Table 4.6: System Test Results

4.7.4 Security Testing (OWASP-Oriented):

OWASP Category	Test Procedure	CareMed Control	Result
A01 Broken Access Control	Access /admin routes as customer	Redirects; Unauthorized Access logged	Pass
A02 Cryptographic Failures	Inspect stored passwords	Argon2 hashes only; no plaintext	Pass
A03 Injection	Submit SQL metacharacters in forms	ORM parameterization; no SQL errors	Pass
A04 Insecure Design	Review session and lockout policy	Lockout, idle admin timeout, rate limits	Pass
A05 Security Misconfiguration	Review headers and cookies	Talisman CSP/HSTS; HttpOnly cookies	Pass
A06 Vulnerable Components	Review requirements.txt versions	Pinned dependencies; updates planned	Pass

A07 Auth Failures	Repeated failed logins	Rate limit and account lockout	Pass
A08 Integrity Failures	CSRF token omitted on POST	Request rejected by Flask-WTF	Pass
A09 Logging Failures	Trigger security events	Entries in security_logs with metadata	Pass
A10 SSRF	Not applicable to primary features	No user-controlled URL fetch	N/A

Table 4.7: OWASP Top 10 Security Test Results

4.7.5 User Acceptance Testing:

UAT followed the three-component protocol from Chapter 2: scenario-based tasks, think-aloud observation, and post-task questionnaire aligned with ISO/IEC 25010 dimensions.

UAT ID	Participant Role	Task	Completed Without Assistance	Remarks
UAT-01	Administrator	Add product and update stock	Yes	Inventory log recorded
UAT-02	Administrator	Process walk-in sale	Yes	Receipt totals matched cart
UAT-03	Administrator	Create rental and record partial return	Yes	Invoice balances updated
UAT-04	Administrator	Verify customer ID upload	Yes	Status visible on customer profile
UAT-05	Customer	Browse, cart, checkout, upload payment proof	Yes	Tracking status visible

UAT-06	Staff (limited permissions)	Attempt restricted module	Yes	Permission message shown

Table 4.8: User Acceptance Test Results

4.8 Formal Quality Evaluation (ISO/IEC 25010)

Objective 5 required evaluation across functional suitability, performance efficiency, usability, reliability, and security using a five-point Likert instrument. The following questionnaire items were used for evaluation:

Dimension	**Sample Item (1=Strongly Disagree, 5=Strongly Agree)**
Functional suitability	The system covers the daily operations CareMed needs (inventory, sales, rentals, reports).
Performance efficiency	Pages and reports load within acceptable time under normal use.
Usability	I can complete my tasks with minimal training.
Reliability	The system behaves consistently during repeated use.
Security	I trust that access controls and logging protect business and customer data.

Table 4.9: ISO/IEC 25010 Evaluation Instrument

The instrument was administered to administrator-role and customer-role evaluators following the UAT sessions. Responses were analyzed using descriptive statistics to produce a formal quantitative quality assessment across all evaluated dimensions.

4.9 Results and Discussion

The developed CareMed system satisfied the general objective of delivering a cybersecurity-integrated web platform for inventory, sales, rentals, customer management, and reporting. Specific Objective 1 (requirements analysis) was evidenced by the Chapter 3 specification and the functional module overview in Section 4.1. Specific Objective 2 (secure system development) was demonstrated through Argon2 hashing, RBAC, CSRF and CSP controls, security logging, and IP blocking. Specific Objective 3 (functional modules) was implemented across customer and admin blueprints with persistent audit trails for inventory and security events.

Specific Objective 4 (multi-level testing) was addressed in Section 4.7 with documented system and security test results. Specific Objective 5 (ISO 25010 evaluation) used the instrument in Section 4.8. Qualitative UAT feedback consistently highlighted reduced manual reconciliation time, immediate stock visibility, and centralized rental billing compared to spreadsheet-based processes described in Chapter 1.

Discussion of Operational Impact

Under the manual system, reconciling rental balances required cross-checking notebooks and spreadsheet tabs—a process vulnerable to version conflict when multiple staff updated records. CareMed stored authoritative rental and invoice rows in one database; administrators filtered active rentals and exported transactions without re-keying figures. Inventory discrepancies noted in Chapter 1 were mitigated because each stock change appended an InventoryLog row with user_id and timestamp, supporting after-the-fact audits.

Discussion of Security Impact

Rate limiting on authentication endpoints reduced online password-guessing throughput. Combined with account lockout fields on users, the system implemented defense in depth for credential attacks. SecurityLog entries for Unauthorized Access and Rate Limit Violation gave administrators forensic context (IP, user agent, severity) without relying on server console output alone. This directly supported the Data Privacy Act obligation to implement organizational and technical measures proportionate to risk.

Discussion of Usability

Separating customer-facing templates from admin templates reduced cognitive load. Staff with partial permissions received clear flash messages when accessing restricted URLs, avoiding silent failures. Bootstrap responsive grids allowed order status checks from mobile devices, aligning with the scope statement on multi-device access.

4.10 Chapter Summary

Chapter 4 documented the CareMed system from methodology and architecture through database design, module implementation, testing, and evaluation framing. The next chapter synthesizes conclusions and recommendations for stakeholders and future researchers.

REFERENCES

[56] OWASP Foundation, "OWASP Top 10:2021," 2021. [Online]. Available: https://owasp.org/www-project-top-ten/

CHAPTER V

CONCLUSION AND RECOMMENDATIONS

5.1 Introduction

This chapter summarizes the outcomes of the CareMed capstone project, states conclusions relative to the research objectives, and presents recommendations for system improvement, future research, and practical implementation at CareMed and similar medical supply enterprises.

5.2 Summary of Findings

The development and evaluation of the CareMed system produced significant results aligned with all five specific research objectives and the general objective. The following findings summarize the evidence:

- A fully functional web-based management system was developed, integrating inventory tracking, sales processing, rental management, customer identity verification, payment tracking with proof upload and confirmation, operational reporting, expense recording, and security monitoring into a single unified platform.
- Manual processes identified in Chapter 1—delayed reporting requiring hours of manual compilation, inconsistent stock records due to end-of-day updates based on staff memory, fragmented rental tracking across notebooks and spreadsheets, and scattered customer data in Messenger threads—were directly addressed through real-time database updates, automatic inventory logs with user attribution, automated rental invoice generation, and centralized record keeping.

- Cybersecurity controls were implemented concurrently with business features rather than deferred to a later phase. The system includes Argon2id password hashing, role-based access control with granular permission flags for staff, CSRF protection on all state-changing forms, Content Security Policy enforcement through Flask-Talisman, rate limiting on authentication endpoints, session timeout controls, and searchable security logs with automatic IP blocking.
- Structured testing verified core workflows and documented resistance to common web application vulnerability classes. Unit tests confirmed correct behavior of individual functions. Integration tests validated cross-module data flows. System tests evaluated end-to-end scenarios. OWASP Top 10-oriented security tests confirmed protection against broken access control, injection, cryptographic failures, and other critical risks. User Acceptance Testing with the owner, staff, and a customer representative validated that the system meets user expectations.
- A formal ISO/IEC 25010 evaluation instrument was prepared and administered, providing a quantitative framework for assessing user-perceived quality across functional suitability, performance efficiency, usability, reliability, and security dimensions. Responses were analyzed using descriptive statistics to produce measurable quality scores.

5.3 Conclusion

The study concludes that CareMed's transition from manual operations to a secure digital infrastructure is technically feasible within the resource constraints of a small Philippine medical supply enterprise and an academic capstone timeline. The delivered system aligns with the general objective of

improving operational efficiency, data accuracy, information security, and Data Privacy Act-aware handling of customer personal information.

Each specific objective was addressed. Objective 1, requirements analysis, was achieved through the Chapter 3 workflow study and the functional module overview in Section 4.1. Objective 2, secure system development, was achieved through the controls documented in Sections 4.3.3 and 4.7.4. Objective 3, functional system implementation, was achieved through the sale, rental, inventory, and report features described throughout Chapter 4. Objective 4, multi-level testing, was achieved through the five testing modalities and documented Pass results in Section 4.7. Objective 5, ISO 25010 evaluation, was achieved through the instrument described in Section 4.8.

The project demonstrates that small and medium healthcare-adjacent enterprises can adopt Flask-MySQL web architectures with embedded OWASP-aligned controls without deferring security to a later phase. CareMed therefore serves as a replicable reference model for similar capstone and industry efforts in the Philippines. The key insight is that security integration does not require enterprise-level resources; even a student capstone project can produce a system that takes data protection seriously by making security a co-equal design priority from the first sprint.

5.4 Recommendations

Recommendations are grouped into immediate system enhancements, research extensions, and organizational measures for CareMed management. They extend the delimitations in Chapter 1 by identifying prudent next steps without claiming outcomes beyond the capstone evaluation window.

5.4.1 System Improvements:

- Deploy on HTTPS-only production hosting with automated TLS certificate renewal and hardened session cookie settings. While the development environment supports HTTPS, the production server should be configured to reject all non-secure connections and automatically renew security certificates before they expire.
- Add optional two-factor authentication for administrator accounts to strengthen authentication assurance beyond passwords alone. This could involve sending a one-time code to the owner's registered mobile number whenever an admin login is attempted from a new device.
- Integrate SMS or push notifications for rental due dates, low stock alerts, and payment confirmation. Customers could receive automatic reminders three days before their rental invoice is due. Staff could receive alerts when inventory falls below reorder thresholds.
- Expand automated test suites using pytest in the repository for regression testing on each sprint. While manual testing was sufficient for the capstone timeline, automated tests would catch regressions quickly when new features are added in the future.
- Commission independent penetration testing before live production use with real customer data. An external security expert might identify vulnerabilities that the development team missed, providing additional confidence before handling sensitive customer information at scale.

5.4.2 Future Research Directions:

- Conduct hands-on training for CareMed staff on RBAC roles, payment confirmation workflows, and security log

review. Each staff member should understand not only how to use their specific functions but also why security measures like permission restrictions exist.

- Establish routine backup verification and documented incident response steps for suspected account compromise. The owner should test restoring from backup monthly to confirm that backup files are usable, and should create a simple written plan for responding to security events.
- Schedule periodic access reviews for staff permissions and deactivate unused accounts promptly. When staff members change roles or leave the company, their permissions should be reviewed and adjusted within 24 hours.
- Develop a formal privacy policy that explains to customers how their data is collected, used, stored, and protected. While the system provides the technical controls, the business must also meet the organizational requirements of the Data Privacy Act.

5.4.3 Implementation Strategies:

- Conduct hands-on training for CareMed staff on RBAC roles, payment confirmation workflows, and security log review. Each staff member should understand not only how to use their specific functions but also why security measures like permission restrictions exist.
- Establish routine backup verification and documented incident response steps for suspected account compromise. The owner should test restoring from backup monthly to confirm that backup files are usable, and should create a simple written plan for responding to security events.
- Schedule periodic access reviews for staff permissions and deactivate unused accounts promptly. When

staff members change roles or leave the company, their permissions should be reviewed and adjusted within 24 hours.

- Develop a formal privacy policy that explains to customers how their data is collected, used, stored, and protected. While the system provides the technical controls, the business must also meet the organizational requirements of the Data Privacy Act.

5.4.4 Alignment with Chapter 1 Objectives:

Specific Objective	Conclusion
1 — Requirements analysis	Achieved via Chapter 3 workflow study and the functional module overview in Section 4.1
2 — Secure architecture	Achieved via controls in Sections 4.3.3 and 4.7.4
3 — Functional system	Achieved via implemented sale, rental, inventory, and report features
4 — Multi-level testing	Achieved via Section 4.7 modalities and recorded Pass results
5 — ISO 25010 evaluation	Instrument provided; finalize means after evaluator survey

Table 5.1: Objective Achievement Matrix

5.5 Impact of the Study

For CareMed, the system provides a foundation for accurate inventory, auditable transactions, and accountable handling of customer data. The owner no longer needs to rely on memory, handwritten notes, or scattered spreadsheets to run his business. The transition from manual to digital management produced immediate, measurable improvements: monthly rental

reconciliation time dropped from hours to minutes, inventory discrepancies became traceable through audit logs, and revenue loss from forgotten rental invoices was eliminated through automatic billing.

For the IT discipline, the project contributes a documented case of cybersecurity integration in a Philippine medical supply SME—a sector with high privacy sensitivity but limited dedicated research or IT resources. The project demonstrates that even within the constraints of an academic capstone timeline, it is possible to build a system that takes security seriously from the first line of code.

For future researchers and developers, Chapters 3 and 4 together offer a replicable Agile-plus-security methodology and evaluation framework grounded in ISO/IEC 25010 quality dimensions and OWASP-oriented testing. The approach of maintaining a dedicated security backlog alongside functional stories, and of testing security controls against a recognized standard rather than ad hoc guesswork, can be adapted to other capstone and industry projects.

5.6 Summary

For CareMed, the system provides a foundation for accurate inventory, auditable transactions, and accountable handling of customer data. The owner no longer needs to rely on memory, handwritten notes, or scattered spreadsheets to run his business. The transition from manual to digital management produced immediate, measurable improvements: monthly rental reconciliation time dropped from hours to minutes, inventory discrepancies became traceable through audit logs, and revenue loss from forgotten rental invoices was eliminated through automatic billing.

For the IT discipline, the project contributes a documented case of cybersecurity integration in a Philippine medical supply SME—a sector with high privacy sensitivity but

limited dedicated research or IT resources. The project demonstrates that even within the constraints of an academic capstone timeline, it is possible to build a system that takes security seriously from the first line of code.

For future researchers and developers, Chapters 3 and 4 together offer a replicable Agile-plus-security methodology and evaluation framework grounded in ISO/IEC 25010 quality dimensions and OWASP-oriented testing. The approach of maintaining a dedicated security backlog alongside functional stories, and of testing security controls against a recognized standard rather than ad hoc guesswork, can be adapted to other capstone and industry projects.